



Fortify Audit Workbench

Developer Workbook

bu-analytics-gen-ai-midas-deployment-dev-jenkins



Table of Contents

[Executive Summary](#)

[Project Description](#)

[Issue Breakdown by Fortify Categories](#)

[Results Outline](#)

[Description of Key Terminology](#)

[About Fortify Solutions](#)

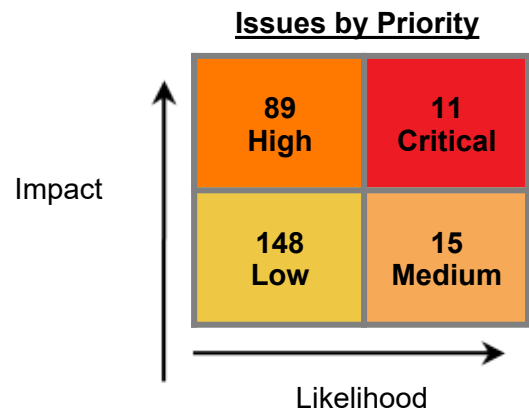


Executive Summary

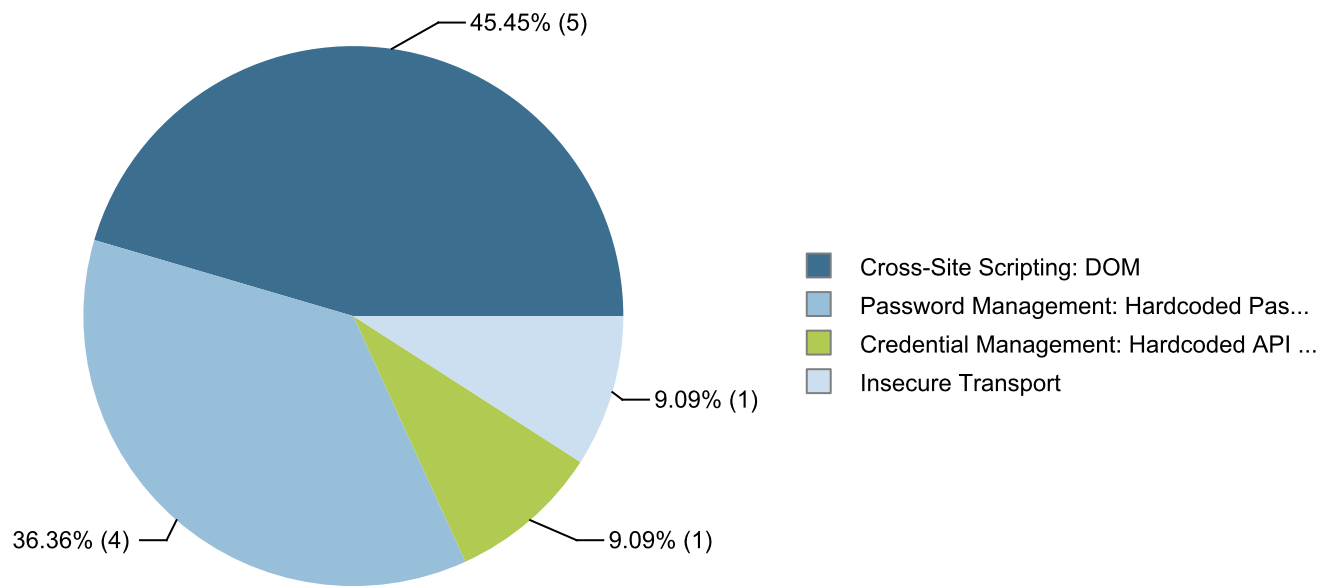
This workbook is intended to provide all necessary details and information for a developer to understand and remediate the different issues discovered during the bu-analytics-gen-ai-midas-deployment-dev-jenkins project audit. The information contained in this workbook is targeted at project managers and developers.

This section provides an overview of the issues uncovered during analysis.

Project Name:	bu-analytics-gen-ai-mida deployment-dev-jenkins
Project Version:	
SCA:	Results Present
WebInspect:	Results Not Present
WebInspect Agent:	Results Not Present
Other:	Results Not Present



Top Ten Critical Categories



Project Description

This section provides an overview of the Fortify scan engines used for this project, as well as the project meta-information.

SCA

Date of Last Analysis:	May 5, 2026 7:13 PM	Engine Version:	25.2.0.0116
Host Name:	eci01syswstorm	Certification:	VALID
Number of Files:	911	Lines of Code:	424,630
Rulepack Name		Rulepack Version	
Fortify Secure Coding Rules, Community, Cloud		2025.3.0.0007	
Fortify Secure Coding Rules, Community, Universal		2025.3.0.0007	
Fortify Secure Coding Rules, Core, Cloud		2025.3.0.0007	
Fortify Secure Coding Rules, Core, JavaScript		2025.3.0.0007	
Fortify Secure Coding Rules, Core, Python		2025.3.0.0007	
Fortify Secure Coding Rules, Core, Universal		2025.3.0.0007	
Fortify Secure Coding Rules, Extended, Configuration		2025.3.0.0007	
Fortify Secure Coding Rules, Extended, Content		2025.3.0.0007	
Fortify Secure Coding Rules, Extended, JavaScript		2025.3.0.0007	



Issue Breakdown by Fortify Categories

The following table depicts a summary of all issues grouped vertically by Fortify Category. For each category, the total number of issues is shown by Fortify Priority Order, including information about the number of audited issues.

Category	Fortify Priority (audited/total)				Total Issues
	Critical	High	Medium	Low	
AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key	0	0	0	0 / 6	0 / 6
AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key	0	0	0	0 / 3	0 / 3
AWS Terraform Misconfiguration: Improper ECR Access Control	0	0 / 2	0	0	0 / 2
AWS Terraform Misconfiguration: Improper EKS Network Access Control	0	0 / 1	0	0	0 / 1
AWS Terraform Misconfiguration: Insecure EC2 Storage	0	0	0 / 1	0	0 / 1
AWS Terraform Misconfiguration: Insecure ECR Storage	0	0	0 / 1	0	0 / 1
AWS Terraform Misconfiguration: Insecure EKS Storage	0	0	0 / 2	0	0 / 2
AWS Terraform Misconfiguration: Insufficient EC2 Logging	0	0	0 / 1	0	0 / 1
AWS Terraform Misconfiguration: Insufficient RDS Backup	0	0	0 / 1	0	0 / 1
AWS Terraform Misconfiguration: Insufficient RDS Monitoring	0	0	0 / 1	0	0 / 1
AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled	0	0 / 3	0	0	0 / 3
AWS Terraform Misconfiguration: Reduced ELB Availability	0	0	0 / 5	0	0 / 5
AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key	0	0	0	0 / 28	0 / 28
Command Injection	0	0 / 39	0	0	0 / 39
Credential Management: Hardcoded API Credentials	0 / 1	0 / 4	0 / 1	0	0 / 6
Cross-Site Request Forgery	0	0	0	0 / 104	0 / 104
Cross-Site Scripting: DOM	0 / 5	0	0	0	0 / 5
Dockerfile Misconfiguration: Default User Privilege	0	0 / 4	0	0	0 / 4
Dockerfile Misconfiguration: Dependency Confusion	0	0 / 4	0	0	0 / 4
Dynamic Code Evaluation: Unsafe Pickle Deserialization	0	0 / 2	0	0	0 / 2
Insecure Transport	0 / 1	0	0	0	0 / 1
Key Management: Empty Encryption Key	0	0 / 2	0	0	0 / 2
Key Management: Hardcoded Encryption Key	0	0 / 1	0	0	0 / 1
Kubernetes Misconfiguration: Improper Deployment Access Control	0	0 / 3	0	0	0 / 3
Password Management: Empty Password	0	0 / 11	0	0	0 / 11
Password Management: Hardcoded Password	0 / 4	0 / 13	0	0	0 / 17
System Information Leak: External	0	0	0 / 2	0	0 / 2
Weak Cryptographic Hash	0	0	0	0 / 7	0 / 7



Results Outline

AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key (6 issues)

Abstract

A configuration does not specify a customer-managed encryption key for data at rest.

Explanation

Customer-managed keys are not used to encrypt data at rest. By default, AWS uses AWS-managed keys to encrypt data at rest if encryption is enabled. Customer-managed keys enable organizations to use cryptographic keys of their choice to encrypt data. This gives organizations better control over and logging of encryption processes. As such, customer-managed keys are often part of the solution to address requirements that include but are not limited to: - Audit logs for sensitive data access - Data residency - Replacing, disabling, or destroying keys Note that keys with the format aws/service-name are reserved for AWS-managed keys. **Example 1:** The following example shows a configuration that defines an aws_cloudwatch_log_group resource with kms_key_id unset.

```
resource "aws_cloudwatch_log_group" "example" {  
  # MISSING kms_key_id ...  
  ...  
}
```

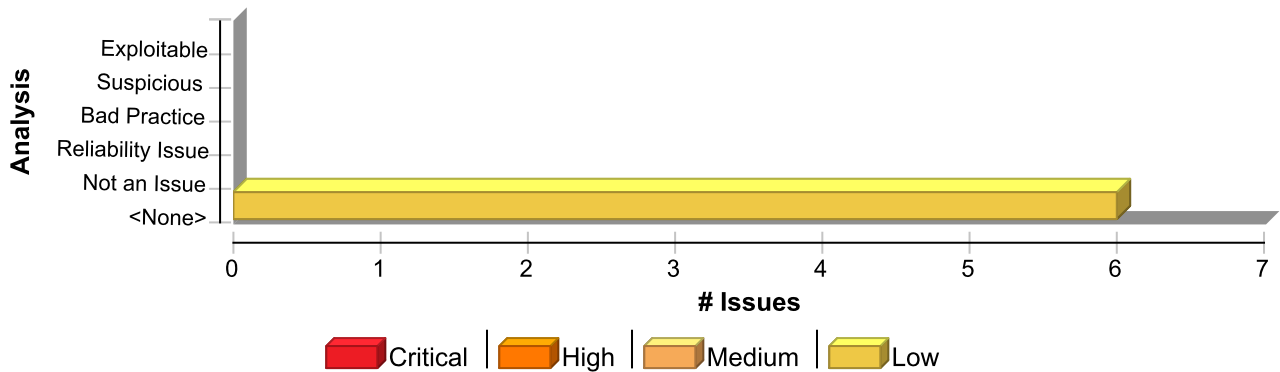
Recommendation

For more control over the encryption process of sensitive data, configure customer-managed keys to encrypt data at rest. Using customer-managed keys requires organizations to fully manage key lifecycle activities including issuance, storage, revocation, and rotation. Organizations should review their compliance requirements and determine whether to use customer-managed keys. **Example 2:** The following improves the configuration in Example 1. It specifies an aws_cloudwatch_log_group resource with kms_key_id configured.

```
resource "aws_cloudwatch_log_group" "example" {  
  kms_key_id = "arn:aws:kms:us-west-2:111122223333:key/  
1234abcd-12ab-34cd-56ef-1234567890ab"  
  ...  
}
```

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key	6	0	0	6
Total	6	0	0	6

AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key	Low
--	-----

Package: local

deploy/ecs-app/modules/observability-app-logs/main.tf, line 20 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Data Flow)

Source Details

Source: RESOURCE Declaration
From: local...\Users\es_achchhelal\Downloads\bu-analytics-gen-ai-midas-deployment-dev-jenkins\deploy\ecs-app\modules\observability-app-logs
File: deploy/ecs-app/modules/observability-app-logs/main.tf:20

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/observability-app-logs/main.tf:20
Taint Flags:

deploy/ecs-app/modules/observability-opensearch/main.tf, line 114 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/observability-opensearch/main.tf:114
Taint Flags:



AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ecs-app/modules/observability-opensearch/main.tf, line 114 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

deploy/ecs-app/modules/observability-app-logs/main.tf, line 23 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Data Flow)

Source Details

Source: RESOURCE Declaration
From: local...\..\..\Users\es_achchhelal\Downloads\bu-analytics-gen-ai-midas-deployment-dev-jenkins\deploy\ecs-app\modules\observability-app-logs
File: deploy/ecs-app/modules/observability-app-logs/main.tf:20

Sink Details

Sink: Object Pair
Enclosing Method: backend_application()
File: deploy/ecs-app/modules/observability-app-logs/main.tf:23
Taint Flags:

deploy/ecs-app/modules/observability-amp/main.tf, line 30 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/observability-amp/main.tf:30
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/cloudwatch.tf, line 1 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Data Flow)

Source Details

Source: RESOURCE Declaration
From: local...\..\..\Users\es_achchhelal\Downloads\bu-analytics-gen-ai-midas-deployment-dev-jenkins\deploy\ai_gateway\terraform\modules-midas
File: deploy/ai_gateway/terraform/modules-midas/cloudwatch.tf:1



AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/cloudwatch.tf, line 1 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/cloudwatch.tf:1

Taint Flags:

deploy/ecs-app/modules/eks/main.tf, line 105 (AWS Terraform Misconfiguration: CloudWatch Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ecs-app/modules/eks/main.tf:105

Taint Flags:



AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key (3 issues)

Abstract

A configuration does not specify a customer-managed encryption key for data at rest.

Explanation

Customer-managed keys are not used to encrypt data at rest. By default, AWS uses AWS-managed keys to encrypt data at rest if encryption is enabled. Customer-managed keys enable organizations to use cryptographic keys of their choice to encrypt data. This gives organizations better control over and logging of encryption processes. As such, customer-managed keys are often part of the solution to address requirements that include but are not limited to: - Audit logs for sensitive data access - Data residency - Replacing, disabling, or destroying keys Note that keys with the format aws/service-name are reserved for AWS-managed keys. **Example 1:** The following example shows a configuration that defines an `aws_elasticache_replication_group` resource with `kms_key_id` set to an empty or null value.

```
resource "aws_elasticache_replication_group" "example" {
  kms_key_id = null
  ...
}
```

Example 2: The following example shows a configuration that defines an `aws_elasticache_replication_group` resource with `kms_key_id` unset.

```
resource "aws_elasticache_replication_group" "example" {
  # MISSING kms_key_id ...
  ...
}
```

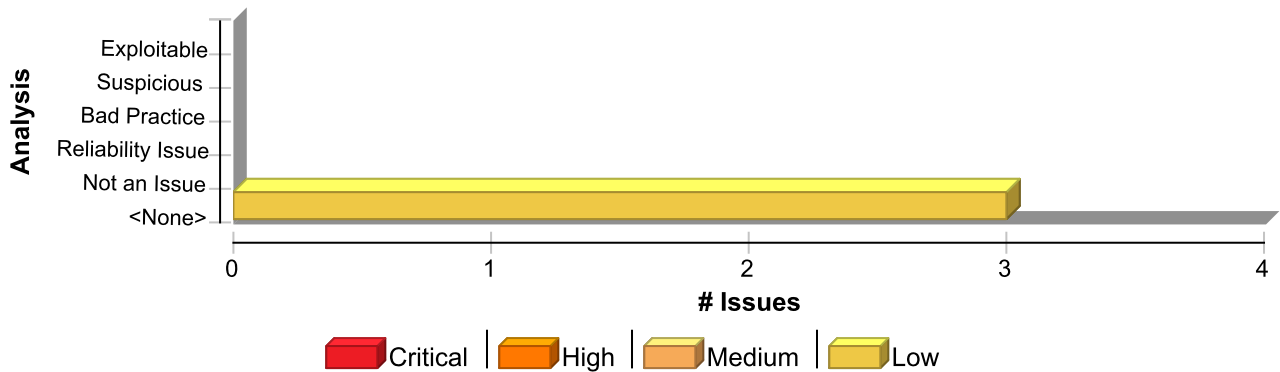
Recommendation

For more control over the encryption process of sensitive data, configure customer-managed keys to encrypt data at rest. Using customer-managed keys requires organizations to fully manage key lifecycle activities including issuance, storage, revocation, and rotation. Organizations should review their compliance requirements and determine whether to use customer-managed keys. **Example 3:** The following improves the configuration in Example 1. It specifies an `aws_elasticache_replication_group` resource with `kms_key_id` set to a secure value.

```
resource "aws_elasticache_replication_group" "example" {
  kms_key_id = "arn:aws:kms:us-west-2:111122223333:key/1234abcd-12ab-34cd-56ef-1234567890ab"
  ...
}
```

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key	3	0	0	3
Total	3	0	0	3

AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/redis.tf, line 56 (AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/redis.tf:56
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/redis.tf, line 13 (AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/redis.tf:13
Taint Flags:

deploy/ecs-app/modules/elasticache/main.tf, line 114 (AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)



AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ecs-app/modules/elasticache/main.tf, line 114 (AWS Terraform Misconfiguration: ElastiCache Missing Customer-Managed Encryption Key)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ecs-app/modules/elasticache/main.tf:114

Taint Flags:



AWS Terraform Misconfiguration: Improper ECR Access Control (2 issues)

Abstract

A configuration does not apply proper access controls.

Explanation

Uncontrolled access to critical or sensitive resources can significantly impact an organization in various ways, including disclosure of or tampering with critical data. By default, the `image_tag_mutability` property is set to "MUTABLE" for ECR resources. **Example 1:** The following example shows a configuration that defines an `aws_ecr_repository` resource with `image_tag_mutability` set to the insecure value "MUTABLE".

```
resource "aws_ecr_repository" "example" {
  image_tag_mutability = "MUTABLE"
  ...
}
```

Example 2: The following example shows a configuration that defines an `aws_ecr_repository` resource with `image_tag_mutability` unset.

```
resource "aws_ecr_repository" "example" {
# MISSING image_tag_mutability ...
  ...
}
```

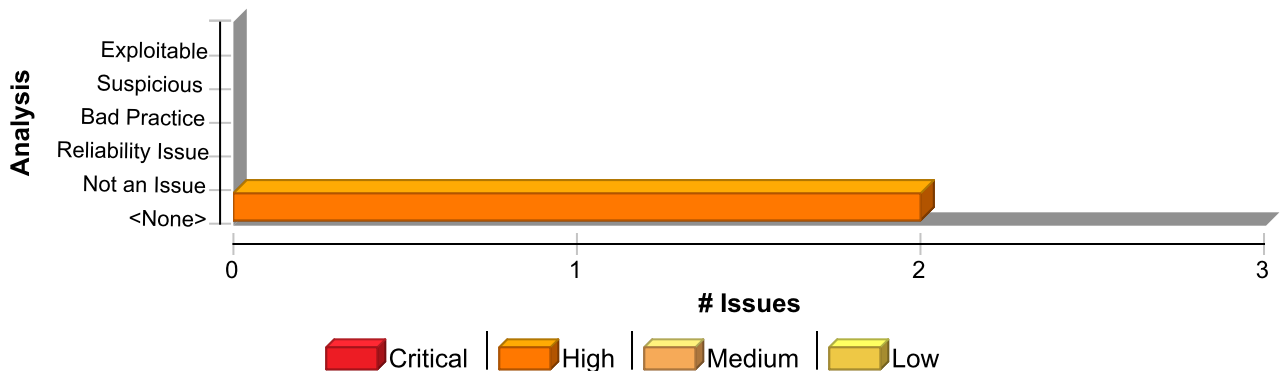
Recommendation

Enforce access controls to protect critical data and prevent unauthorized actions. Review your organization's data handling policies when creating resources that are readable by anonymous users.

When changing access controls, identify all dependent systems to limit potential disruptions. **Example 3:** The following improves the configuration in Example 1. It specifies an `aws_ecr_repository` resource with `image_tag_mutability` no longer set to the insecure value "MUTABLE".

```
resource "aws_ecr_repository" "example" {
  image_tag_mutability = "IMMUTABLE"
  ...
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Improper ECR Access Control	2	0	0	2
Total	2	0	0	2

AWS Terraform Misconfiguration: Improper ECR Access Control

High

Package: local

deploy/ecs-app/modules/ecr/main.tf, line 19 (AWS Terraform Misconfiguration: Improper ECR Access Control)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Data Flow)

Source Details

Source: RESOURCE Declaration
From: local...\..\..\Users\es_achchhelal\Downloads\bu-analytics-gen-ai-midas-deployment-dev-jenkins\deploy\ecs-app\modules\ecr
File: deploy/ecs-app/modules/ecr/main.tf:19

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/ecr/main.tf:19
Taint Flags:

deploy/ecs-app/modules/observability-fluent-bit/main.tf, line 35 (AWS Terraform Misconfiguration: Improper ECR Access Control)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant String
Enclosing Method: fluent_bit()
File: deploy/ecs-app/modules/observability-fluent-bit/main.tf:35
Taint Flags:



AWS Terraform Misconfiguration: Improper EKS Network Access Control (1 issue)

Abstract

A configuration defines a network rule with overly broad access permissions.

Explanation

Loose access configurations can expose systems and broaden an organization's attack surface. Services open to interaction with the public are typically subjected to near-continuous scanning and probing by malicious entities. This is especially problematic when a zero-day exploit for an exposed service is discovered and published, such as Heartbleed. Attackers can actively pursue and search for unpatched and exposed systems to exploit. **Example 1:** The following example shows a configuration that defines an `aws_eks_cluster` resource with `endpoint_public_access` set to the insecure value `true`.

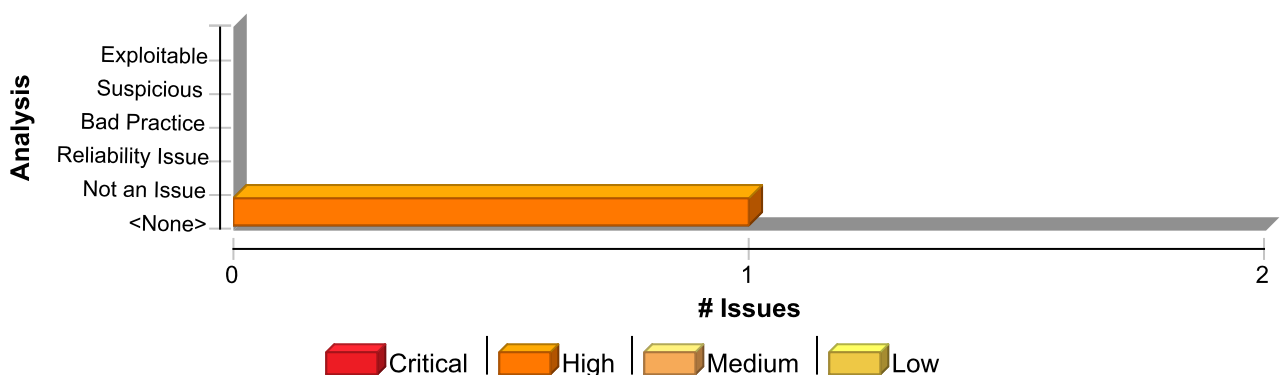
```
resource "aws_eks_cluster" "example" {  
  vpc_config {  
    endpoint_public_access = true  
  }  
  ...  
}
```

Recommendation

Define network rules that restrict access to services and ensure the services are available to as limited an audience as possible. For example, do not make ports for service management activities publicly accessible. Ensure these ports are only available to a restricted pool of systems that require authorized access. **Example 2:** The following improves the configuration in Example 1. It specifies an `aws_eks_cluster` resource with `endpoint_public_access` no longer set to the insecure value `true`.

```
resource "aws_eks_cluster" "example" {  
  vpc_config {  
    endpoint_public_access = false  
  }  
  ...  
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Improper EKS Network Access Control	1	0	0	1
Total	1	0	0	1

AWS Terraform Misconfiguration: Improper EKS Network Access Control

High

Package: local

deploy/ai_gateway/terraform/modules-midas/eks_cluster.tf, line 15 (AWS Terraform Misconfiguration: Improper EKS Network Access Control)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant Boolean
Enclosing Method: exlerate_eks_cluster()
File: deploy/ai_gateway/terraform/modules-midas/eks_cluster.tf:15
Taint Flags:



AWS Terraform Misconfiguration: Insecure EC2 Storage (1 issue)

Abstract

A configuration creates a resource without encryption at rest.

Explanation

Encryption at rest is not enabled. This exposes data to unauthorized access and potential theft. **Example 1:** The following example shows a configuration that defines an `aws_ami` resource with `encrypted` set to the insecure value `false`.

```
resource "aws_ami" "example" {
  ebs_block_device {
    encrypted = false
  }
  ...
}
```

Example 2: The following example shows a configuration that defines an `aws_ami` resource with `encrypted` unset.

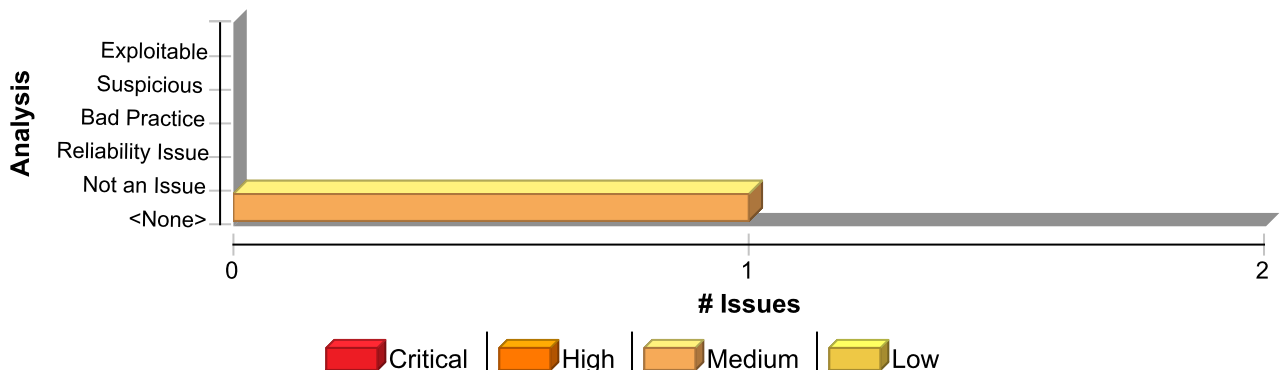
```
resource "aws_ami" "example" {
  ebs_block_device {
    # MISSING encrypted ...
  }
  ...
}
```

Recommendation

Enforce encryption of sensitive data at rest. **Example 3:** The following improves the configuration in Example 1. It specifies an `aws_ami` resource with `encrypted` no longer set to the insecure value `false`.

```
resource "aws_ami" "example" {
  ebs_block_device {
    encrypted = true
  }
  ...
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Insecure EC2 Storage	1	0	0	1
Total	1	0	0	1

AWS Terraform Misconfiguration: Insecure EC2 Storage

Medium

Package: local

deploy/ecs-app/modules/ec2-ssm-test/main.tf, line 8 (AWS Terraform Misconfiguration: Insecure EC2 Storage)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/ec2-ssm-test/main.tf:8
Taint Flags:



AWS Terraform Misconfiguration: Insecure ECR Storage (1 issue)

Abstract

A configuration creates a resource without encryption at rest.

Explanation

Encryption at rest is not enabled. This exposes data to unauthorized access and potential theft. **Example 1:** The following example shows a configuration that defines an `aws_ecr_repository` resource with `encryption_configuration` unset.

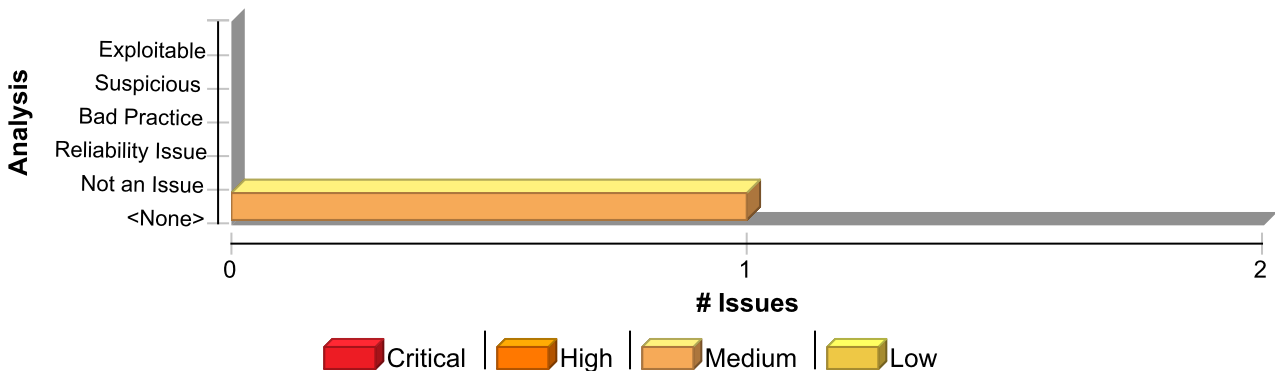
```
resource "aws_ecr_repository" "example" {  
  # MISSING encryption_configuration ...  
  ...  
}
```

Recommendation

Enforce encryption of sensitive data at rest. **Example 2:** The following improves the configuration in Example 1. It specifies an `aws_ecr_repository` resource with `encryption_configuration` configured.

```
resource "aws_ecr_repository" "example" {  
  encryption_configuration { ... }  
  ...  
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Insecure ECR Storage	1	0	0	1
Total	1	0	0	1



AWS Terraform Misconfiguration: Insecure ECR Storage	Medium
Package: local	
deploy/ecs-app/modules/observability-fluent-bit/main.tf, line 33 (AWS Terraform Misconfiguration: Insecure ECR Storage)	
Issue Details	
Kingdom: Environment Scan Engine: SCA (Structural)	
Sink Details	
Sink: RESOURCE Declaration File: deploy/ecs-app/modules/observability-fluent-bit/main.tf:33 Taint Flags:	

AWS Terraform Misconfiguration: Insecure EKS Storage (2 issues)

Abstract

A configuration creates a resource without encryption at rest.

Explanation

Encryption at rest is not enabled. This exposes data to unauthorized access and potential theft. **Example 1:** The following example shows a configuration that defines an `aws_eks_cluster` resource with `key_arn` unset.

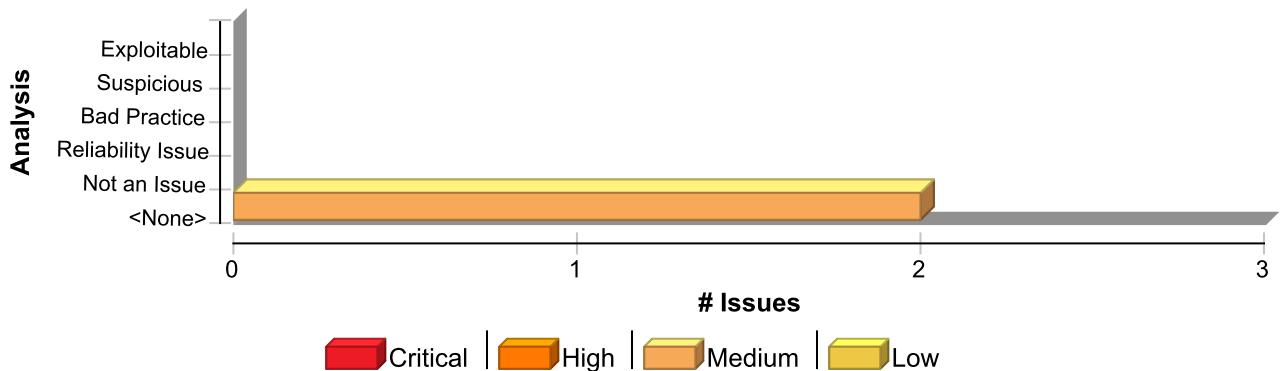
```
resource "aws_eks_cluster" "example" {  
  encryption_config {  
    provider {  
      # MISSING key_arn ...  
    }  
  }  
  ...  
}
```

Recommendation

Enforce encryption of sensitive data at rest. **Example 2:** The following improves the configuration in Example 1. It specifies an `aws_eks_cluster` resource with `key_arn` configured.

```
resource "aws_eks_cluster" "example" {  
  encryption_config {  
    provider {  
      key_arn = "arn:aws:kms:us-west-2:111122223333:key/  
1234abcd-12ab-34cd-56ef-1234567890ab"  
    }  
  }  
  ...  
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Insecure EKS Storage	2	0	0	2
Total	2	0	0	2

AWS Terraform Misconfiguration: Insecure EKS Storage

Medium

Package: local

deploy/ecs-app/modules/eks/main.tf, line 112 (AWS Terraform Misconfiguration: Insecure EKS Storage)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ecs-app/modules/eks/main.tf:112

Taint Flags:

k8s/terraform-app-deploy.tf, line 86 (AWS Terraform Misconfiguration: Insecure EKS Storage)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: k8s/terraform-app-deploy.tf:86

Taint Flags:



AWS Terraform Misconfiguration: Insufficient EC2 Logging (1 issue)

Abstract

The template defines a service with insufficient audit logging.

Explanation

A lack of audit records limits the ability to detect and respond to security-related incidents and prevents forensic investigation. Configuration settings that undermine logging capabilities include but are not limited to: - deliberately disabling audit logging - exempting actions of specific users, groups, or processes from being logged - inadequately protecting log integrity - not enabling optional audit logging - reducing the log sampling rate **Example 1:** The following example shows a configuration that defines an `aws_instance` resource with `monitoring` set to the insecure value `false`.

```
resource "aws_instance" "example" {  
  monitoring = false  
  ...  
}
```

Example 2: The following example shows a configuration that defines an `aws_instance` resource with `monitoring` unset.

```
resource "aws_instance" "example" {  
  # MISSING monitoring ...  
  ...  
}
```

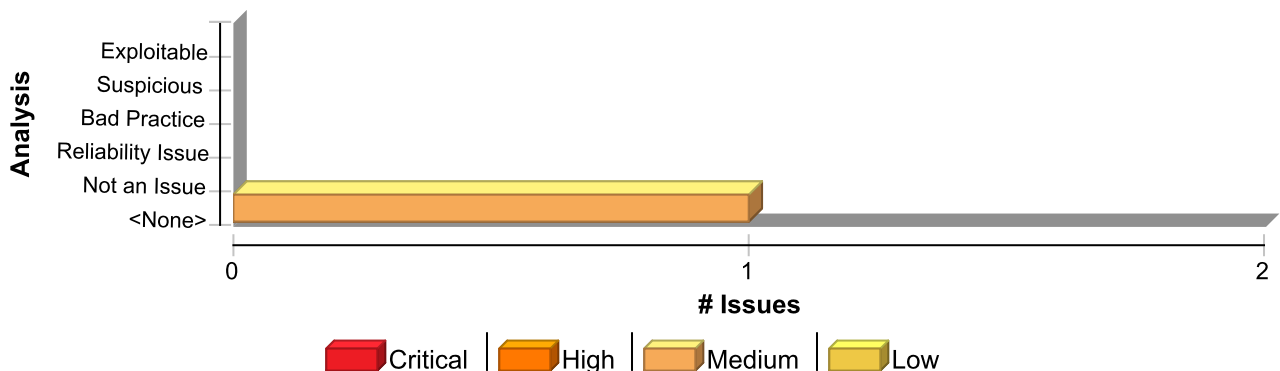
Recommendation

Enable audit logging for all security-sensitive services. Capture logs for all users without exemption.

Example 3: The following improves the configuration in Example 1. It specifies an `aws_instance` resource with `monitoring` no longer set to the insecure value `false`.

```
resource "aws_instance" "example" {  
  monitoring = true  
  ...  
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Insufficient EC2 Logging	1	0	0	1
Total	1	0	0	1

AWS Terraform Misconfiguration: Insufficient EC2 LoggingMedium

Package: local

deploy/ecs-app/modules/ec2-ssm-test/main.tf, line 207 (AWS Terraform Misconfiguration: Insufficient EC2 Logging)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant Boolean
Enclosing Method: this()
File: deploy/ecs-app/modules/ec2-ssm-test/main.tf:207
Taint Flags:



AWS Terraform Misconfiguration: Insufficient RDS Backup (1 issue)

Abstract

A configuration sets up a resource without proper backup settings.

Explanation

Backups are critical to protect against data loss or corruption. Settings that undermine backups include but are not limited to: - Disabling data backup - Failure to back up data regularly - Failure to check the integrity of backups regularly - Insufficient backup retention period By default, the `backup_retention_period` property is set to 0 for RDS resources. **Example 1:** The following example shows a configuration that defines an `aws_db_instance` resource with `backup_retention_period` set to the insecure value 0.

```
resource "aws_db_instance" "example" {  
  backup_retention_period = 0  
  ...  
}
```

Example 2: The following example shows a configuration that defines an `aws_db_instance` resource with `backup_retention_period` unset.

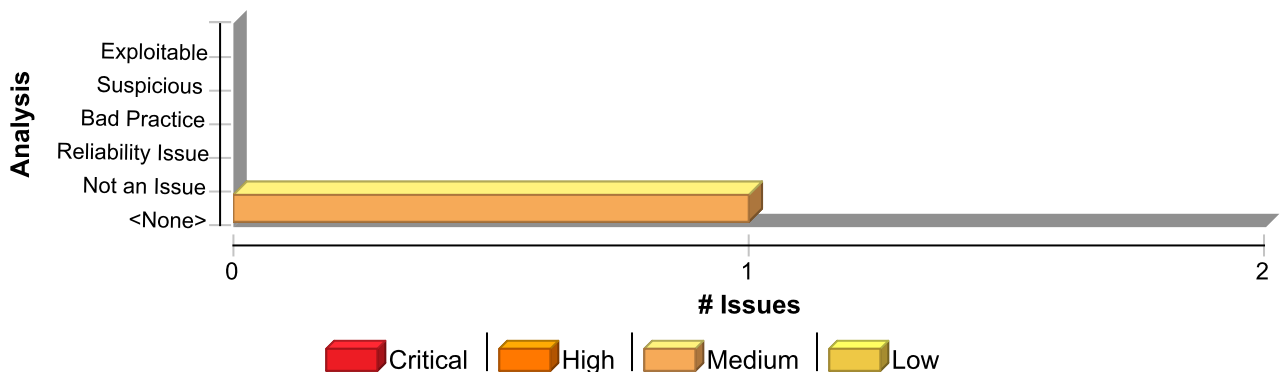
```
resource "aws_db_instance" "example" {  
  # MISSING backup_retention_period ...  
  ...  
}
```

Recommendation

Always explicitly configure and enable automated backups and enforce a proper retention policy of sensitive resources. **Example 3:** The following improves the configuration in Example 1. It specifies an `aws_db_instance` resource with `backup_retention_period` no longer set to the insecure value 0.

```
resource "aws_db_instance" "example" {  
  backup_retention_period = 14  
  ...  
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Insufficient RDS Backup	1	0	0	1
Total	1	0	0	1

AWS Terraform Misconfiguration: Insufficient RDS BackupMedium

Package: local

deploy/ecs-app/modules/rds/main.tf, line 97 (AWS Terraform Misconfiguration: Insufficient RDS Backup)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Data Flow)

Source Details

Source: RESOURCE Declaration
From: local...\..\..\Users\es_achchhelalc\Downloads\bu-analytics-gen-ai-midas-deployment-dev-jenkins\deploy\ecs-app\modules\rds
File: deploy/ecs-app/modules/rds/main.tf:97

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/rds/main.tf:97
Taint Flags:



AWS Terraform Misconfiguration: Insufficient RDS Monitoring (1 issue)

Abstract

A configuration sets up a resource that lacks monitoring.

Explanation

Any delayed response to breaches undermines an organization's ability to limit the impact of a breach. Configuration settings that undermine monitoring capabilities include but are not limited to: - deliberately disabling monitoring - not enabling optional monitoring - not specifying relevant events to export to monitoring services - exempting actions of specific users, groups, processes, and geographical regions from monitoring **Example 1:** The following example shows a configuration that defines an `aws_db_instance` resource with `enabled_cloudwatch_logs_exports` set to an empty or null value.

```
resource "aws_db_instance" "example" {
  enabled_cloudwatch_logs_exports = null
  ...
}
```

Example 2: The following example shows a configuration that defines an `aws_db_instance` resource with `enabled_cloudwatch_logs_exports` unset.

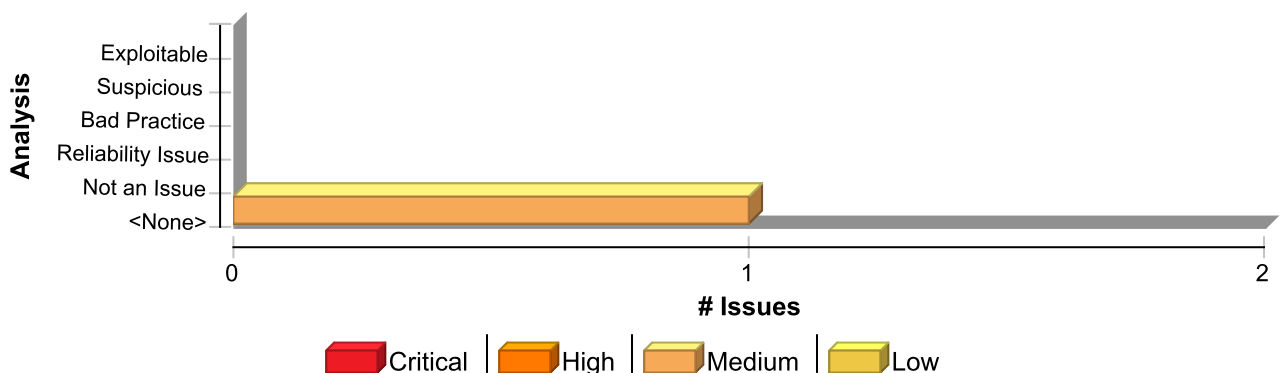
```
resource "aws_db_instance" "example" {
# MISSING enabled_cloudwatch_logs_exports ...
  ...
}
```

Recommendation

Leverage breach detection controls to detect and respond quickly to attacks. **Example 3:** The following improves the configuration in Example 1. It specifies an `aws_db_instance` resource with `enabled_cloudwatch_logs_exports` set to a secure value.

```
resource "aws_db_instance" "example" {
  enabled_cloudwatch_logs_exports = ["error"]
  ...
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Insufficient RDS Monitoring	1	0	0	1
Total	1	0	0	1

AWS Terraform Misconfiguration: Insufficient RDS MonitoringMedium

Package: local

deploy/ecs-app/modules/rds/main.tf, line 97 (AWS Terraform Misconfiguration: Insufficient RDS Monitoring)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/rds/main.tf:97
Taint Flags:



AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled (3 issues)

Abstract

A configuration turns off automatic software upgrades.

Explanation

Automatic software upgrades, which ensure timely patching of known software vulnerabilities, are disabled. By default, the `auto_minor_version_upgrade` property is set to `true` for RDS resources. **Example 1:** The following example shows a configuration that defines an `aws_db_instance` resource with `auto_minor_version_upgrade` not set to the secure value `true`.

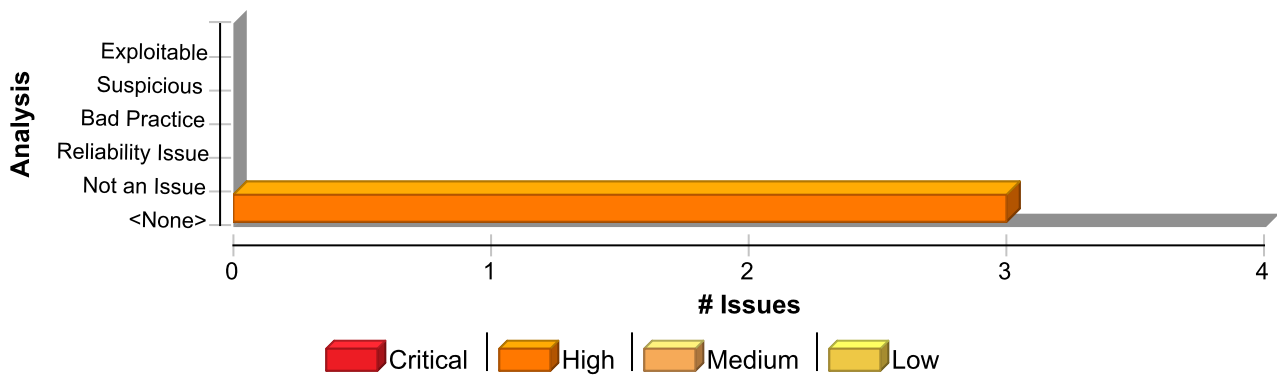
```
resource "aws_db_instance" "example" {  
  auto_minor_version_upgrade = false  
  ...  
}
```

Recommendation

Keep auto-upgrading software enabled. **Example 2:** The following improves the configuration in Example 1. It specifies an `aws_db_instance` resource with `auto_minor_version_upgrade` set to the secure value `true`.

```
resource "aws_db_instance" "example" {  
  auto_minor_version_upgrade = true  
  ...  
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled	3	0	0	3
Total	3	0	0	3



AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled

High

Package: local

deploy/ai_gateway/terraform/modules-midas/rds.tf, line 27 (AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant Boolean
Enclosing Method: rds_pg_eks_db()
File: deploy/ai_gateway/terraform/modules-midas/rds.tf:27
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/rds.tf, line 77 (AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant Boolean
Enclosing Method: rds_pg_eks_db_langfuse()
File: deploy/ai_gateway/terraform/modules-midas/rds.tf:77
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/rds.tf, line 117 (AWS Terraform Misconfiguration: RDS Auto-Upgrade Disabled)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant Boolean
Enclosing Method: rds_pg_eks_db_c1_api()
File: deploy/ai_gateway/terraform/modules-midas/rds.tf:117
Taint Flags:



AWS Terraform Misconfiguration: Reduced ELB Availability (5 issues)

Abstract

A configuration reduces the service availability.

Explanation

Cloud services typically use techniques like caching, replication, and load balancing to facilitate service scalability, deliver content faster, and mitigate the impacts of volumetric attacks. Disabled or misconfigured availability features degrade service performance, but immediate effects are often not apparent until extreme events such as traffic spikes and hardware failures occur. By default, the `enable_deletion_protection` property is set to `false` for ELB resources. **Example 1:** The following example shows a configuration that defines an `aws_lb` resource with `enable_deletion_protection` set to the insecure value `false`.

```
resource "aws_lb" "example" {
  enable_deletion_protection = false
  ...
}
```

Example 2: The following example shows a configuration that defines an `aws_lb` resource with `enable_deletion_protection` unset.

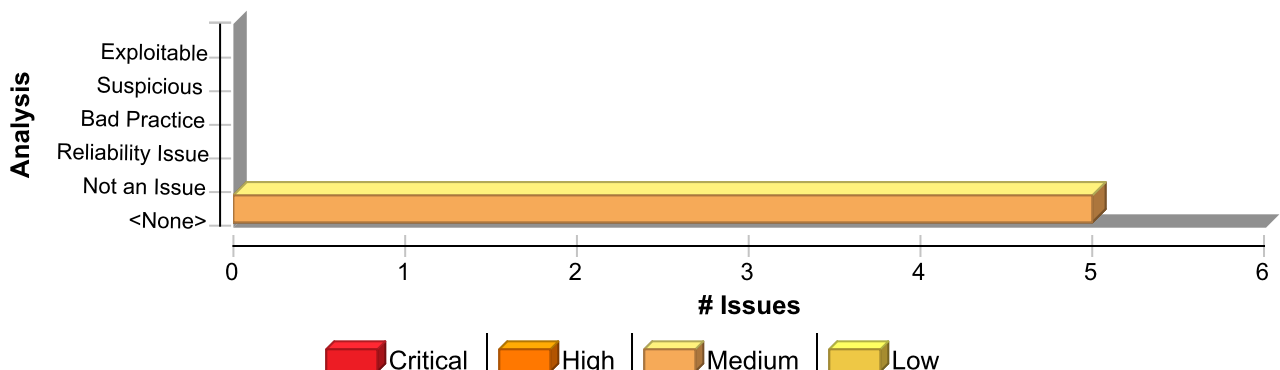
```
resource "aws_lb" "example" {
# MISSING enable_deletion_protection ...
  ...
}
```

Recommendation

Keep availability-enhancing features enabled. **Example 3:** The following improves the configuration in Example 1. It specifies an `aws_lb` resource with `enable_deletion_protection` no longer set to the insecure value `false`.

```
resource "aws_lb" "example" {
  enable_deletion_protection = true
  ...
}
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: Reduced ELB Availability	5	0	0	5
Total	5	0	0	5

AWS Terraform Misconfiguration: Reduced ELB AvailabilityMedium

Package: local

deploy/ai_gateway/terraform/modules-midas/alb.tf, line 232 (AWS Terraform Misconfiguration: Reduced ELB Availability)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/alb.tf:232
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/alb.tf, line 375 (AWS Terraform Misconfiguration: Reduced ELB Availability)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/alb.tf:375
Taint Flags:

deploy/ecs-app/modules/alb-nlb/main.tf, line 281 (AWS Terraform Misconfiguration: Reduced ELB Availability)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Constant Boolean
Enclosing Method: alb()
File: deploy/ecs-app/modules/alb-nlb/main.tf:281
Taint Flags:

deploy/ecs-app/modules/alb-nlb/main.tf, line 448 (AWS Terraform Misconfiguration: Reduced ELB Availability)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)



AWS Terraform Misconfiguration: Reduced ELB Availability

Medium

Package: local

deploy/ecs-app/modules/alb-nlb/main.tf, line 448 (AWS Terraform Misconfiguration: Reduced ELB Availability)

Sink Details

Sink: Constant Boolean

Enclosing Method: nlb()

File: deploy/ecs-app/modules/alb-nlb/main.tf:448

Taint Flags:

deploy/ai_gateway/terraform/modules-midas/alb.tf, line 300 (AWS Terraform Misconfiguration: Reduced ELB Availability)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/alb.tf:300

Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key (28 issues)

Abstract

A configuration does not specify a customer-managed encryption key for data at rest.

Explanation

Customer-managed keys are not used to encrypt data at rest. By default, AWS uses AWS-managed keys to encrypt data at rest if encryption is enabled. Customer-managed keys enable organizations to use cryptographic keys of their choice to encrypt data. This gives organizations better control over and logging of encryption processes. As such, customer-managed keys are often part of the solution to address requirements that include but are not limited to: - Audit logs for sensitive data access - Data residency - Replacing, disabling, or destroying keys Note that keys with the format aws/service-name are reserved for AWS-managed keys. **Example 1:** The following example shows a configuration that defines an aws_secretsmanager_secret resource with kms_key_id set to an empty or null value.

```
resource "aws_secretsmanager_secret" "example" {
  kms_key_id = null
  ...
}
```

Example 2: The following example shows a configuration that defines an aws_secretsmanager_secret resource with kms_key_id unset.

```
resource "aws_secretsmanager_secret" "example" {
# MISSING kms_key_id ...
  ...
}
```

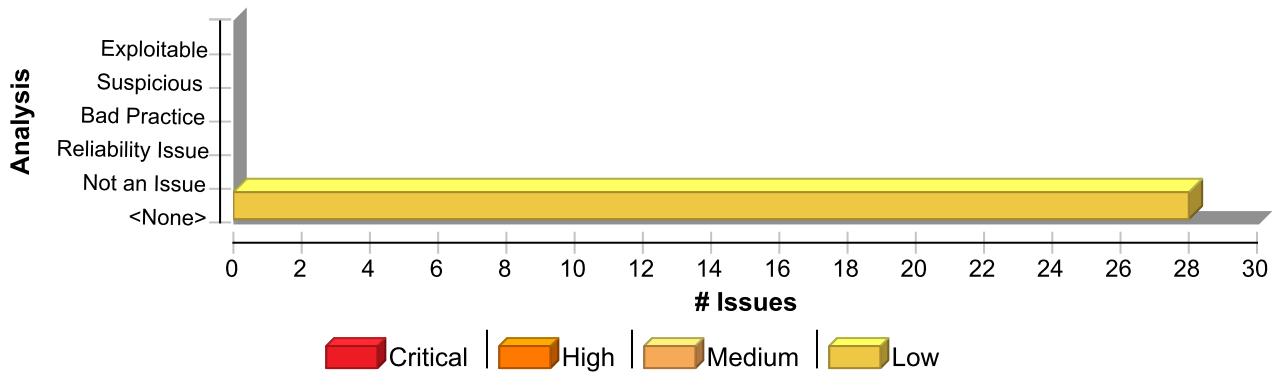
Recommendation

For more control over the encryption process of sensitive data, configure customer-managed keys to encrypt data at rest. Using customer-managed keys requires organizations to fully manage key lifecycle activities including issuance, storage, revocation, and rotation. Organizations should review their compliance requirements and determine whether to use customer-managed keys. **Example 3:** The following improves the configuration in Example 1. It specifies an aws_secretsmanager_secret resource with kms_key_id set to a secure value.

```
resource "aws_secretsmanager_secret" "example" {
  kms_key_id = "arn:aws:kms:us-west-2:111122223333:key/
1234abcd-12ab-34cd-56ef-1234567890ab"
  ...
}
```

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key	28	0	0	28
Total	28	0	0	28

AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key	Low
--	-----

Package: local

deploy/ecs-app/modules/secretsmanager-test-secret/main.tf, line 5 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/secretsmanager-test-secret/main.tf:5
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 438 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:438
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 199 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 199 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:199

Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 218 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:218

Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 473 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:473

Taint Flags:

deploy/ecs-app/modules/elasticache/main.tf, line 86 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ecs-app/modules/elasticache/main.tf:86

Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 361 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:361
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 402 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:402
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 181 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:181
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 130 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:130
Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 4 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:4
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 98 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:98
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 387 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:387
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 237 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:237
Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 330 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:330
Taint Flags:

deploy/ecs-app/modules/secretsmanager/main.tf, line 8 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/secretsmanager/main.tf:8
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 507 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:507
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 112 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:112
Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 451 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:451
Taint Flags:

deploy/ecs-app/modules/secretsmanager-frontend/main.tf, line 29 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ecs-app/modules/secretsmanager-frontend/main.tf:29
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 487 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:487
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 256 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:256
Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 61 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:61
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 148 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:148
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 342 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:342
Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 275 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration
File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:275
Taint Flags:



AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key

Low

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 34 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:34

Taint Flags:

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 169 (AWS Terraform Misconfiguration: SecretsManager Missing Customer-Managed Encryption Key)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Structural)

Sink Details

Sink: RESOURCE Declaration

File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:169

Taint Flags:



Command Injection (39 issues)

Abstract

Executing commands from an untrusted source or in an untrusted environment can cause an application to execute malicious commands on behalf of an attacker.

Explanation

Command injection vulnerabilities take two forms: - An attacker can change the command that the program executes: the attacker explicitly controls what the command is. - An attacker can change the environment in which the command executes: the attacker implicitly controls what the command means. In this case, we are primarily concerned with the first scenario, the possibility that an attacker may be able to control the command that is executed. Command injection vulnerabilities of this type occur when: 1. Data enters the application from an untrusted source. 2. The data is used as or as part of a string representing a command that is executed by the application. 3. By executing the command, the application gives an attacker a privilege or capability that the attacker would not otherwise have. **Example 1:** The following code from a system utility uses the system property APPHOME to determine the directory in which it is installed and then executes an initialization script based on a relative path from the specified directory.

```
...
home = os.getenv('APPHOME')
cmd = home.join(INITCMD)
os.system(cmd);
...
```

The code in Example 1 allows an attacker to execute arbitrary commands with the elevated privilege of the application by modifying the system property APPHOME to point to a different path containing a malicious version of INITCMD. Because the program does not validate the value read from the environment, if an attacker can control the value of the system property APPHOME, then they can fool the application into running malicious code and take control of the system. **Example 2:** The following code is from an administrative web application designed to allow users to kick off a backup of an Oracle database using a batch-file wrapper around the rman utility and then run a cleanup.bat script to delete some temporary files. The script rmanDB.bat accepts a single command line parameter, which specifies the type of backup to perform. Because access to the database is restricted, the application runs the backup as a privileged user.

```
...
btype = req.field('backuptype')
cmd = "cmd.exe /K \"%c:\\util\\rmanDB.bat " + btype + "&&c:\\util\\
\\cleanup.bat\""
os.system(cmd);
...
```

The problem here is that the program does not do any validation on the backuptype parameter read from the user. Typically the Runtime.exec() function will not execute multiple commands, but in this case the program first runs the cmd.exe shell in order to run multiple commands with a single call to Runtime.exec(). After the shell is invoked, it will allow for the execution of multiple commands separated by two ampersands. If an attacker passes a string of the form "&& del c:\\dbms*. *", then the application will execute this command along with the others specified by the program. Because of the nature of the application, it runs with the privileges necessary to interact with the database, which means whatever command the attacker injects will run with those privileges as well. **Example 3:** The following code is from a web application that provides an interface through which users can update their password on the system. Part of the process for updating passwords in certain network environments is to run a make command in the /var/yp directory.

```
...
result = os.system("make");
...
```

The problem here is that the program does not specify an absolute path for make and fails to clean its

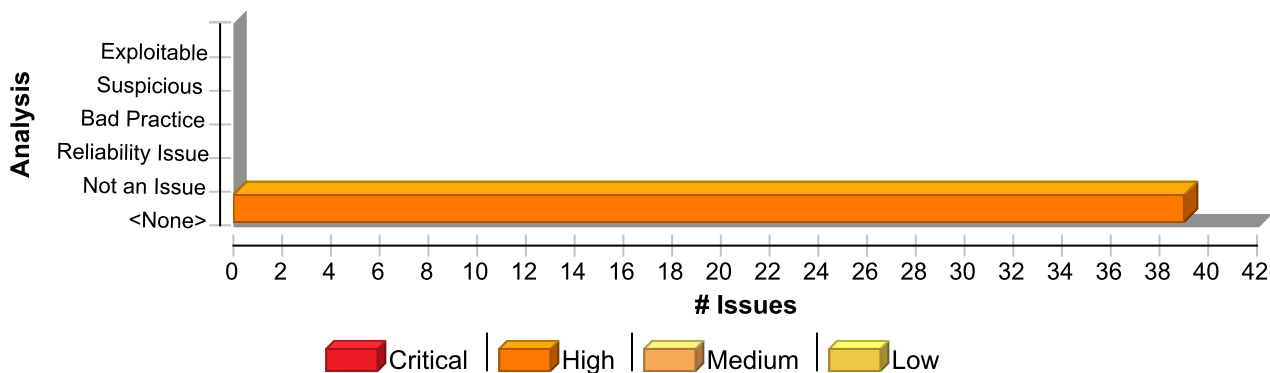


environment prior to executing the call to `os.system()`. If an attacker can modify the `$PATH` variable to point to a malicious binary called `make` and cause the program to be executed in their environment, then the malicious binary will be loaded instead of the one intended. Because of the nature of the application, it runs with the privileges necessary to perform system operations, which means the attacker's `make` will now be run with these privileges, possibly giving the attacker complete control of the system.

Recommendation

Do not allow users to have direct control over the commands executed by the program. In cases where user input must affect the command to be run, use the input only to make a selection from a predetermined set of safe commands. If the input appears to be malicious, the value passed to the command execution function should either default to some safe selection from this set or the program should decline to execute any command at all. In cases where user input must be used as an argument to a command executed by the program, this approach often becomes impractical because the set of legitimate argument values is too large or too hard to keep track of. Developers often fall back on implementing a deny list in these situations. A deny list is used to selectively reject or escape potentially dangerous characters before using the input. Any list of unsafe characters is likely to be incomplete and will be heavily dependent on the system where the commands are executed. A better approach is to create a list of characters that are permitted to appear in the input and accept input composed exclusively of characters in the approved set. An attacker may indirectly control commands executed by a program by modifying the environment in which they are executed. The environment should not be trusted and precautions should be taken to prevent an attacker from using some manipulation of the environment to perform an attack. Whenever possible, commands should be controlled by the application and executed using an absolute path. In cases where the path is not known at compile time, such as for cross-platform applications, an absolute path should be constructed from trusted values during execution. Command values and paths read from configuration files or the environment should be sanity-checked against a set of invariants that define valid values. Other checks can sometimes be performed to detect if these sources may have been tampered with. For example, if a configuration file is world-writable, the program might refuse to run. In cases where information about the binary to be executed is known in advance, the program may perform checks to verify the identity of the binary. If a binary should always be owned by a particular user or have a particular set of access permissions assigned to it, these properties can be verified programmatically before the binary is executed. Although it might be impossible to completely protect a program from an imaginative attacker bent on controlling the commands the program executes, be sure to apply the principle of least privilege wherever the program executes an external command: do not hold privileges that are not essential to the execution of the command.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Command Injection	39	0	0	39
Total	39	0	0	39

Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 379 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: SCA (Data Flow)

Source Details

Source: input()
From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()
Enclosing Method: _x509_text()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:379
Taint Flags: STDIN

```
376
377 def _x509_text(openssl: str, cert_path: Path) -> str:
378     proc = subprocess.run(
379         [openssl, "x509", "-noout", "-text", "-in", str(cert_path)],
380         capture_output=True,
381         text=True,
382     )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 395 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: SCA (Data Flow)



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 395 (Command Injection)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _collect_dns_san_names()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:395

Taint Flags: STDIN

```
392 """Return lowercased DNS names from Subject Alternative Name."""
393 proc = subprocess.run(
394     [
395         openssl,
396         "x509",
397         "-noout",
398         "-ext",
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 334 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 334 (Command Injection)

```
153 raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
155 raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _run_openssl()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:334

Taint Flags: PRIMARY_KEY, STDIN

```
331 "-config",
332 cfg_path,
333 ]
334 proc = subprocess.run(cmd, capture_output=True, text=True)
335 if proc.returncode != 0:
336 sys.exit(
337 "ERROR: openssl req failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 435 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153 raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
155 raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157 print()
158 sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _cert_modulus_md5()



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 435 (Command Injection)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:435

Taint Flags: STDIN

```
432
433 def _cert_modulus_md5(openssl: str, cert_path: Path) -> str:
434     proc = subprocess.run(
435         [openssl, "x509", "-noout", "-modulus", "-in", str(cert_path)],
436         capture_output=True,
437         text=True,
438     )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 205 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:103

```
100     return "default"
101     if raw == "3":
102         try:
103             custom = input(" Profile name: ").strip()
104         except (EOFError, KeyboardInterrupt):
105             print()
106     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _ensure_credentials()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:205

Taint Flags: STDIN

```
202     "json",
203 ]
204
205 cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
206 if cred_check.returncode != 0:
207     print(
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 205 (Command Injection)

```
208  "\nERROR: AWS credentials are invalid or expired.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 222 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aw
w-cert-generate-injector.py:103

```
100  return "default"
101  if raw == "3":
102  try:
103  custom = input(" Profile name: ").strip()
104  except (EOFError, KeyboardInterrupt):
105  print()
106  sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _ensure_credentials()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-
injector.py:222

Taint Flags: STDIN

```
219  login_cmd += ["--profile", profile]
220  subprocess.run(login_cmd)
221  # Re-run STS and use THIS result for JSON parsing (not the failed run above).
222  cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
223  if cred_check.returncode != 0:
224  sys.exit(
225  "\nERROR: Still unable to authenticate after sso login.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 420 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 420 (Command Injection)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _key_modulus_md5()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:420

Taint Flags: PRIMARY_KEY, STDIN

```
417 [openssl, "pkey", "-noout", "-modulus", "-in", str(key_path)],
418 [openssl, "rsa", "-noout", "-modulus", "-in", str(key_path)],
419 ):
420     proc = subprocess.run(args, capture_output=True, text=True)
421     if proc.returncode == 0 and "Modulus=" in (proc.stdout or ""):
422         mod = subprocess.run(
423             [openssl, "md5"],
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 220 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:103

```
100 return "default"
101 if raw == "3":
102     try:
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 220 (Command Injection)

```
103 custom = input(" Profile name: ").strip()
104 except (EOFError, KeyboardInterrupt):
105     print()
106     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _ensure_credentials()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:220

Taint Flags: STDIN

```
217 login_cmd = [aws_exe, "sso", "login"]
218 if profile:
219     login_cmd += ["--profile", profile]
220     subprocess.run(login_cmd)
221 # Re-run STS and use THIS result for JSON parsing (not the failed run above).
222 cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
223 if cred_check.returncode != 0:
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 743 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:103

```
100 return "default"
101 if raw == "3":
102     try:
103         custom = input(" Profile name: ").strip()
104     except (EOFError, KeyboardInterrupt):
105         print()
106         sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _delete_certificate()



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 743 (Command Injection)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:743

Taint Flags: STDIN

```
740 "--certificate-arn",
741 certificate_arn,
742 ]
743 proc = subprocess.run(cmd, capture_output=True, text=True)
744 if proc.returncode != 0:
745     sys.exit(
746         "ERROR: aws acm delete-certificate failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 743 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_line

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:120

```
117 if not sys.stdin.isatty():
118     return default
119 try:
120     raw = input(f"{label} [{default}]: ").strip()
121 except (EOFError, KeyboardInterrupt):
122     print()
123     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _delete_certificate()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:743

Taint Flags: STDIN

```
740 "--certificate-arn",
741 certificate_arn,
742 ]
743 proc = subprocess.run(cmd, capture_output=True, text=True)
744 if proc.returncode != 0:
745     sys.exit(
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 743 (Command Injection)

```
746 "ERROR: aws acm delete-certificate failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 356 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153     raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
155     raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157     print()
158     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _normalize_private_key_pkcs8_pem()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:356

Taint Flags: PRIMARY_KEY, STDIN

```
353 """
354 tmp = key_path.with_name(key_path.name + ".pkcs8.tmp")
355 proc = subprocess.run(
356     [openssl, "pkey", "-in", str(key_path), "-out", str(tmp)],
357     capture_output=True,
358     text=True,
359 )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 486 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 486 (Command Injection)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153     raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
155     raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157     print()
158     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _validate_acm_alb_pem()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:486

Taint Flags: STDIN

```
483 )
484
485 chk = subprocess.run(
486     [openssl, "x509", "-checkend", "0", "-noout", "-in", str(cert_path)],
487     capture_output=True,
488     text=True,
489 )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 420 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153     raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 420 (Command Injection)

```
155 raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157     print()
158     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _key_modulus_md5()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:420

Taint Flags: PRIMARY_KEY, STDIN

```
417 [openssl, "pkey", "-noout", "-modulus", "-in", str(key_path)],
418 [openssl, "rsa", "-noout", "-modulus", "-in", str(key_path)],
419 ):
420 proc = subprocess.run(args, capture_output=True, text=True)
421 if proc.returncode == 0 and "Modulus=" in (proc.stdout or ""):
422     mod = subprocess.run(
423         [openssl, "md5"],
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 205 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_line

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:120

```
117 if not sys.stdin.isatty():
118     return default
119 try:
120     raw = input(f"{label} [{default}]: ").strip()
121 except (EOFError, KeyboardInterrupt):
122     print()
123     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _ensure_credentials()



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 205 (Command Injection)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:205

Taint Flags: STDIN

```
202  "json",
203  ]
204
205  cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
206  if cred_check.returncode != 0:
207  print(
208  "\nERROR: AWS credentials are invalid or expired.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 222 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_line

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:120

```
117  if not sys.stdin.isatty():
118  return default
119  try:
120  raw = input(f"{label} [{default}]: ").strip()
121  except (EOFError, KeyboardInterrupt):
122  print()
123  sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _ensure_credentials()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:222

Taint Flags: STDIN

```
219  login_cmd += ["--profile", profile]
220  subprocess.run(login_cmd)
221  # Re-run STS and use THIS result for JSON parsing (not the failed run above).
222  cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
223  if cred_check.returncode != 0:
224  sys.exit(
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 222 (Command Injection)

```
225  "\nERROR: Still unable to authenticate after sso login.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 570 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152  if dnorm:
153  raw = input(f"{label} [{dnorm}]: ").strip().lower()
154  else:
155  raw = input(f"{label}: ").strip().lower()
156  except (EOFError, KeyboardInterrupt):
157  print()
158  sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _import_certificate()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:570

Taint Flags: PRIMARY_KEY, STDIN

```
567  if profile:
568  cmd += ["--profile", profile]
569
570  proc = subprocess.run(cmd, capture_output=True, text=True)
571  if proc.returncode != 0:
572  sys.exit(
573  "ERROR: aws acm import-certificate failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 356 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 356 (Command Injection)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _normalize_private_key_pkcs8_pem()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:356

Taint Flags: PRIMARY_KEY, STDIN

```
353 """
354 tmp = key_path.with_name(key_path.name + ".pkcs8.tmp")
355 proc = subprocess.run(
356     [openssl, "pkey", "-in", str(key_path), "-out", str(tmp)],
357     capture_output=True,
358     text=True,
359 )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 379 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153     raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 379 (Command Injection)

```
155 raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157     print()
158     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _x509_text()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:379

Taint Flags: STDIN

```
376
377 def _x509_text(openssl: str, cert_path: Path) -> str:
378     proc = subprocess.run(
379         [openssl, "x509", "-noout", "-text", "-in", str(cert_path)],
380         capture_output=True,
381         text=True,
382     )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 615 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_line

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:120

```
117 if not sys.stdin.isatty():
118     return default
119 try:
120     raw = input(f"{label} [{default}]: ").strip()
121 except (EOFError, KeyboardInterrupt):
122     print()
123     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _aws_acm_list_certificates_json()



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 615 (Command Injection)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:615

Taint Flags: STDIN

```
612 ]
613 if token:
614     cmd += ["--starting-token", token]
615     proc = subprocess.run(cmd, capture_output=True, text=True)
616     if proc.returncode != 0:
617         sys.exit(
618             "ERROR: aws acm list-certificates failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 570 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_line

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:120

```
117 if not sys.stdin.isatty():
118     return default
119 try:
120     raw = input(f"{label} [{default}]: ").strip()
121 except (EOFError, KeyboardInterrupt):
122     print()
123     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _import_certificate()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:570

Taint Flags: STDIN

```
567 if profile:
568     cmd += ["--profile", profile]
569
570     proc = subprocess.run(cmd, capture_output=True, text=True)
571     if proc.returncode != 0:
572         sys.exit(
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 570 (Command Injection)

```
573 "ERROR: aws acm import-certificate failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 570 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aw
w-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _import_certificate()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-
injector.py:570

Taint Flags: PRIMARY_KEY, STDIN

```
567 if profile:
568     cmd += ["--profile", profile]
569
570     proc = subprocess.run(cmd, capture_output=True, text=True)
571     if proc.returncode != 0:
572         sys.exit(
573             "ERROR: aws acm import-certificate failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 395 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 395 (Command Injection)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153     raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
155     raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157     print()
158     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _collect_dns_san_names()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:395

Taint Flags: STDIN

```
392 """Return lowercased DNS names from Subject Alternative Name."""
393 proc = subprocess.run(
394     [
395         openssl,
396         "x509",
397         "-noout",
398         "-ext",
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 334 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:155

```
152 if dnorm:
153     raw = input(f"{label} [{dnorm}]: ").strip().lower()
154 else:
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 334 (Command Injection)

```
155 raw = input(f"{label}: ").strip().lower()
156 except (EOFError, KeyboardInterrupt):
157     print()
158     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _run_openssl()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:334

Taint Flags: PRIMARY_KEY, STDIN

```
331 "-config",
332 cfg_path,
333 ]
334 proc = subprocess.run(cmd, capture_output=True, text=True)
335 if proc.returncode != 0:
336     sys.exit(
337         "ERROR: openssl req failed.\n")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 570 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:103

```
100 return "default"
101 if raw == "3":
102     try:
103         custom = input(" Profile name: ").strip()
104     except (EOFError, KeyboardInterrupt):
105         print()
106         sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _import_certificate()



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 570 (Command Injection)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:570

Taint Flags: STDIN

```
567 if profile:
568     cmd += ["--profile", profile]
569
570     proc = subprocess.run(cmd, capture_output=True, text=True)
571     if proc.returncode != 0:
572         sys.exit(
573             "ERROR: aws acm import-certificate failed.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 435 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _cert_modulus_md5()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:435

Taint Flags: STDIN

```
432
433 def _cert_modulus_md5(openssl: str, cert_path: Path) -> str:
434     proc = subprocess.run(
435         [openssl, "x509", "-noout", "-modulus", "-in", str(cert_path)],
436         capture_output=True,
437         text=True,
```



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 435 (Command Injection)

```
438 )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 486 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_primary_dns

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:153

```
150 while True:
151     try:
152         if dnorm:
153             raw = input(f"{label} [{dnorm}]: ").strip().lower()
154         else:
155             raw = input(f"{label}: ").strip().lower()
156     except (EOFError, KeyboardInterrupt):
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _validate_acm_alb_pem()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:486

Taint Flags: STDIN

```
483 )
484
485 chk = subprocess.run(
486     [openssl, "x509", "-checkend", "0", "-noout", "-in", str(cert_path)],
487     capture_output=True,
488     text=True,
489 )
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/
aww-cert-generate-injector.py, line 615 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)



Command Injection

High

Package: .cursor.scripts.aww-cert-generate-injector

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py, line 615 (Command Injection)

Source Details

Source: input()

From: .cursor.scripts.aww-cert-generate-injector._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:103

```
100 return "default"
101 if raw == "3":
102     try:
103         custom = input(" Profile name: ").strip()
104     except (EOFError, KeyboardInterrupt):
105         print()
106     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: _aws_acm_list_certificates_json()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/.cursor/scripts/aww-cert-generate-injector.py:615

Taint Flags: STDIN

```
612 ]
613 if token:
614     cmd += ["--starting-token", token]
615     proc = subprocess.run(cmd, capture_output=True, text=True)
616     if proc.returncode != 0:
617         sys.exit(
618             "ERROR: aws acm list-certificates failed.\n")
```

Package: deploy.scripts.util.aws-ssm-port-forward-all

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 1276 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-all._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:430

```
427 return "default"
428 elif raw == "3":
```



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-all

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 1276 (Command Injection)

```
429 try:
430     custom = input(" Profile name: ").strip()
431 except (EOFError, KeyboardInterrupt):
432     print()
433     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: main()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:1276

Taint Flags: STDIN

```
1273 login_cmd = [aws_exe, "sso", "login"]
1274 if args.profile:
1275     login_cmd += ["--profile", args.profile]
1276     subprocess.run(login_cmd)
1277 # Re-check after login
1278 cred_check2 = subprocess.run(sts_cmd, capture_output=True, text=True)
1279 if cred_check2.returncode != 0:
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 1142 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-all._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:430

```
427 return "default"
428 elif raw == "3":
429     try:
430         custom = input(" Profile name: ").strip()
431     except (EOFError, KeyboardInterrupt):
432         print()
433         sys.exit("Aborted.\n")
```

Sink Details



Command Injection

High

Package: `deploy.scripts.util.aws-ssm-port-forward-all`

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/
`aws-ssm-port-forward-all.py`, line 1142 (Command Injection)

Sink: `subprocess.Popen.__init__()`

Enclosing Method: `start_tunnel()`

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:1142

Taint Flags: STDIN

```
1139
1140 master_fd, slave_fd = pty.openpty()
1141 proc_raw = subprocess.Popen(
1142     cmd,
1143     stdin=slave_fd,
1144     stdout=slave_fd,
1145     stderr=slave_fd,
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/
`aws-ssm-port-forward-all.py`, line 246 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: `input()`

From: `deploy.scripts.util.aws-ssm-port-forward-all._prompt_profile`

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:430

```
427 return "default"
428 elif raw == "3":
429     try:
430         custom = input(" Profile name: ").strip()
431     except (EOFError, KeyboardInterrupt):
432         print()
433     sys.exit("Aborted.\n")
```

Sink Details

Sink: `subprocess.run()`

Enclosing Method: `_ssm_run()`

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:246

Taint Flags: STDIN

```
243 "--query", "Command.CommandId",
244 "--output", "text",
245 ]
246 result = subprocess.run(cmd, capture_output=True, text=True)
```



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-all

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 246 (Command Injection)

```
247 if result.returncode != 0:
248     sys.exit(
249         f"ERROR: ssm send-command failed ({description}, exit {result.returncode}).\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 1261 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: SCA (Data Flow)

Source Details

Source: input()
From: deploy.scripts.util.aws-ssm-port-forward-all._prompt_profile
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:430

```
427 return "default"
428 elif raw == "3":
429     try:
430         custom = input(" Profile name: ").strip()
431     except (EOFError, KeyboardInterrupt):
432         print()
433     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()
Enclosing Method: main()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:1261
Taint Flags: STDIN

```
1258 os.environ["AWS_PROFILE"] = args.profile
1259 sts_cmd += ["sts", "get-caller-identity", "--region", args.region]
1260
1261 cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
1262 if cred_check.returncode != 0:
1263     print(
1264         "\nERROR: AWS credentials are invalid or expired.\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 1278 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-all

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 1278 (Command Injection)

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-all._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:430

```
427 return "default"
428 elif raw == "3":
429     try:
430         custom = input(" Profile name: ").strip()
431     except (EOFError, KeyboardInterrupt):
432         print()
433     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: main()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:1278

Taint Flags: STDIN

```
1275 login_cmd += ["--profile", args.profile]
1276 subprocess.run(login_cmd)
1277 # Re-check after login
1278 cred_check2 = subprocess.run(sts_cmd, capture_output=True, text=True)
1279 if cred_check2.returncode != 0:
1280     sys.exit(
1281         "\nERROR: Still unable to authenticate after sso login.\n")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py, line 268 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-all._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:430

```
427 return "default"
```



Command Injection

High

Package: `deploy.scripts.util.aws-ssm-port-forward-all`

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/
`aws-ssm-port-forward-all.py`, line 268 (Command Injection)

```
428 elif raw == "3":
429     try:
430         custom = input(" Profile name: ").strip()
431     except (EOFError, KeyboardInterrupt):
432         print()
433     sys.exit("Aborted.\n")
```

Sink Details

Sink: `subprocess.run()`

Enclosing Method: `_ssm_run()`

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-all.py:268

Taint Flags: STDIN

```
265 ]
266 for _ in range(poll_attempts):
267     time.sleep(poll_interval)
268     inv = subprocess.run(get_cmd, capture_output=True, text=True)
269     if inv.returncode != 0:
270         continue
271     try:
```

Package: `deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway`

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/
`aws-ssm-port-forward-midas-and-ai-gateway.py`, line 363 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: `input()`

From: `deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway._prompt_profile`

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/
`aws-ssm-port-forward-midas-and-ai-gateway.py`:547

```
544 return "default"
545 elif raw == "3":
546     try:
547         custom = input(" Profile name: ").strip()
548     except (EOFError, KeyboardInterrupt):
549         print()
550     sys.exit("Aborted.\n")
```



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 363 (Command Injection)

Sink Details

Sink: subprocess.run()

Enclosing Method: _ssm_run()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:363

Taint Flags: STDIN

```
360  "--query", "Command.CommandId",
361  "--output", "text",
362  ]
363  result = subprocess.run(cmd, capture_output=True, text=True)
364  if result.returncode != 0:
365  sys.exit(
366  f"ERROR: ssm send-command failed ({description}, exit {result.returncode}).\n"
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1898 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:547

```
544  return "default"
545  elif raw == "3":
546  try:
547  custom = input(" Profile name: ").strip()
548  except (EOFError, KeyboardInterrupt):
549  print()
550  sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: main()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:1898

Taint Flags: STDIN

```
1895  login_cmd = [aws_exe, "sso", "login"]
1896  if args.profile:
1897  login_cmd += ["--profile", args.profile]
```



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1898 (Command Injection)

```
1898 subprocess.run(login_cmd)
1899 # Re-check after login
1900 cred_check2 = subprocess.run(sts_cmd, capture_output=True, text=True)
1901 if cred_check2.returncode != 0:
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1715 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:547

```
544 return "default"
545 elif raw == "3":
546 try:
547 custom = input(" Profile name: ").strip()
548 except (EOFError, KeyboardInterrupt):
549 print()
550 sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.Popen.__init__()

Enclosing Method: start_tunnel()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:1715

Taint Flags: STDIN

```
1712
1713 master_fd, slave_fd = pty.openpty()
1714 proc_raw = subprocess.Popen(
1715 cmd,
1716 stdin=slave_fd,
1717 stdout=slave_fd,
1718 stderr=slave_fd,
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1883 (Command Injection)

Issue Details



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1883 (Command Injection)

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:547

```
544 return "default"
545 elif raw == "3":
546     try:
547         custom = input(" Profile name: ").strip()
548     except (EOFError, KeyboardInterrupt):
549         print()
550     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: main()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:1883

Taint Flags: STDIN

```
1880 os.environ["AWS_PROFILE"] = args.profile
1881 sts_cmd += ["sts", "get-caller-identity", "--region", args.region]
1882
1883 cred_check = subprocess.run(sts_cmd, capture_output=True, text=True)
1884 if cred_check.returncode != 0:
1885     print(
1886         "\nERROR: AWS credentials are invalid or expired.\n")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1900 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:547



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 1900 (Command Injection)

```
544 return "default"
545 elif raw == "3":
546     try:
547         custom = input(" Profile name: ").strip()
548     except (EOFError, KeyboardInterrupt):
549         print()
550     sys.exit("Aborted.\n")
```

Sink Details

Sink: subprocess.run()

Enclosing Method: main()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:1900

Taint Flags: STDIN

```
1897 login_cmd += ["--profile", args.profile]
1898 subprocess.run(login_cmd)
1899 # Re-check after login
1900 cred_check2 = subprocess.run(sts_cmd, capture_output=True, text=True)
1901 if cred_check2.returncode != 0:
1902     sys.exit(
1903         "\nERROR: Still unable to authenticate after sso login.\n")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 385 (Command Injection)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: input()

From: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway._prompt_profile

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:547

```
544 return "default"
545 elif raw == "3":
546     try:
547         custom = input(" Profile name: ").strip()
548     except (EOFError, KeyboardInterrupt):
549         print()
550     sys.exit("Aborted.\n")
```



Command Injection

High

Package: deploy.scripts.util.aws-ssm-port-forward-midas-and-ai-gateway

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py, line 385 (Command Injection)

Sink Details

Sink: subprocess.run()

Enclosing Method: _ssm_run()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/scripts/util/aws-ssm-port-forward-midas-and-ai-gateway.py:385

Taint Flags: STDIN

```
382 |  
383 for _ in range(poll_attempts):  
384     time.sleep(poll_interval)  
385     inv = subprocess.run(get_cmd, capture_output=True, text=True)  
386     if inv.returncode != 0:  
387         continue  
388     try:
```

Credential Management: Hardcoded API Credentials (6 issues)

Abstract

Hardcoded API credentials can compromise system security in a way that is not easy to remedy.

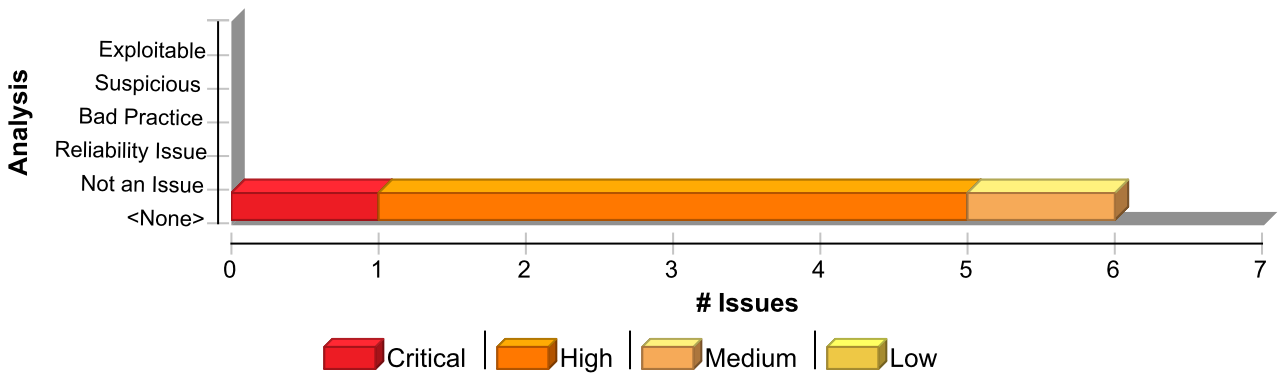
Explanation

Never hardcode credentials, including usernames, passwords, API keys, API secrets, and API Tokens. Not only are hardcoded credentials visible to all of the project developers, they are extremely difficult to update. After the code is in production, the credentials cannot be changed without patching the software. If the credentials are compromised, the organization must choose between security and system availability.

Recommendation

Make sure that API credentials are either loaded from a configuration file that is only available in the runtime environment or from environment variables.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Credential Management: Hardcoded API Credentials	6	0	0	6
Total	6	0	0	6

Credential Management: Hardcoded API Credentials

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
token.txt, line 1 (Credential Management: Hardcoded API Credentials)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/token.txt:1
Taint Flags:



Credential Management: Hardcoded API Credentials**Critical****Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend****Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
token.txt, line 1 (Credential Management: Hardcoded API Credentials)**

```
1 eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJ0ZXN0dXNlciIsImV4cCI6MTc2MTI0Njk3M30.3kj4GdGi8F  
dlelTmlNYy  
2  
3 undefined  
4 undefined  
5 undefined  
6 undefined  
7 undefined
```

Credential Management: Hardcoded API Credentials**High****Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend.app.core.session****Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/core/
session/path_policy.py, line 2 (Credential Management: Hardcoded API
Credentials)****Issue Details**

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/core/session/path_policy.py:2
Taint Flags:

```
1 ""  
2 Which URL paths skip optional Bearer validation in session middleware (Open/Closed: add  
rules via new policy subclasses).  
3 ""  
4  
5 from __future__ import annotations  
6  
7 undefined
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend.Readme**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_CLASSIFICATION_FILE_BASED_UPDATE.md, line 58
(Credential Management: Hardcoded API Credentials)****Issue Details**

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:



Credential Management: Hardcoded API Credentials

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend.Readme

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_CLASSIFICATION_FILE_BASED_UPDATE.md, line 58
(Credential Management: Hardcoded API Credentials)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_CLASSIFICATION_FILE_BASED_UPDATE.md:58

Taint Flags:

```
55 ### New API Call
56 ```bash
57 curl -X POST "http://localhost:8000/api/v1/dataset-type-classification" \
58 -H "Authorization: Bearer YOUR_TOKEN" \
59 -F "file=@dataset.csv"
60 ```
61
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_INTEGRATION_GUIDE.md, line 153 (Credential Management:
Hardcoded API Credentials)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Configuration)

Sink Details

Sink:

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_INTEGRATION_GUIDE.md:153

Taint Flags:

```
150 # Test the API directly
151 curl -X POST "http://localhost:8000/api/v1/dataset-type-classification" \
152 -H "Content-Type: application/json" \
153 -H "Authorization: Bearer YOUR_TOKEN" \
154 -d '{"dataset_id": "your_dataset_id"}'
155 ```
156
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_CLASSIFICATION_IMPLEMENTATION_SUMMARY.md, line 105
(Credential Management: Hardcoded API Credentials)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Configuration)

Sink Details

Sink:

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/
DATASET_TYPE_CLASSIFICATION_IMPLEMENTATION_SUMMARY.md:105



Credential Management: Hardcoded API Credentials	High
Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend.Readme	
Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Readme/DATASET_TYPE_CLASSIFICATION_IMPLEMENTATION_SUMMARY.md, line 105 (Credential Management: Hardcoded API Credentials)	

Taint Flags:

```
102 ```bash
103 curl -X POST "http://localhost:8000/api/v1/dataset-type-classification" \
104 -H "Content-Type: application/json" \
105 -H "Authorization: Bearer YOUR_TOKEN" \
106 -d '{"dataset_id": "your_dataset_id"}'
107 ```
108
```

Credential Management: Hardcoded API Credentials	Medium
Package: .src.components	
Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx, line 370 (Credential Management: Hardcoded API Credentials)	

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx:370
Taint Flags:

```
367 type="text"
368 value={formData.accessKey}
369 onChange={(e) => handleInputChange('accessKey', e.target.value)}
370 placeholder="AKIAIOSFODNN7EXAMPLE"
371 className="w-full px-3 py-2 border border-gray-300 rounded-lg focus:outline-none focus:ring-2 focus:ring-blue-500/20 focus:border-blue-500"
372 />
373 </div>
```



Cross-Site Request Forgery (104 issues)

Abstract

HTTP requests must contain a user-specific secret to prevent an attacker from making unauthorized requests.

Explanation

A cross-site request forgery (CSRF) vulnerability occurs when: 1. A web application uses session cookies. 2. The application acts on an HTTP request without verifying that the request was made with the user's consent. A nonce is a cryptographic random value that is sent with a message to prevent replay attacks. If the request does not contain a nonce that proves its provenance, the code that handles the request is vulnerable to a CSRF attack (unless it does not change the state of the application). This means a web application that uses session cookies has to take special precautions to ensure that an attacker can't trick users into submitting bogus requests. Imagine a web application that allows administrators to create new accounts as follows:

```
var req = new XMLHttpRequest();
req.open("POST", "/new_user", true);
body = addToPost(body, new_username);
body = addToPost(body, new_passwd);
req.send(body);
```

An attacker might set up a malicious web site that contains the following code.

```
var req = new XMLHttpRequest();
req.open("POST", "http://www.example.com/new_user", true);
body = addToPost(body, "attacker");
body = addToPost(body, "haha");
req.send(body);
```

If an administrator for example.com visits the malicious page while she has an active session on the site, she will unwittingly create an account for the attacker. This is a CSRF attack. It is possible because the application does not have a way to determine the provenance of the request. Any request could be a legitimate action chosen by the user or a faked action set up by an attacker. The attacker does not get to see the Web page that the bogus request generates, so the attack technique is only useful for requests that alter the state of the application. Applications that pass the session identifier in the URL rather than as a cookie do not have CSRF problems because there is no way for the attacker to access the session identifier and include it as part of the bogus request.

Recommendation

Applications that use session cookies must include some piece of information in every form post that the back-end code can use to validate the provenance of the request. One way to do that is to include a random request identifier or nonce, as follows:

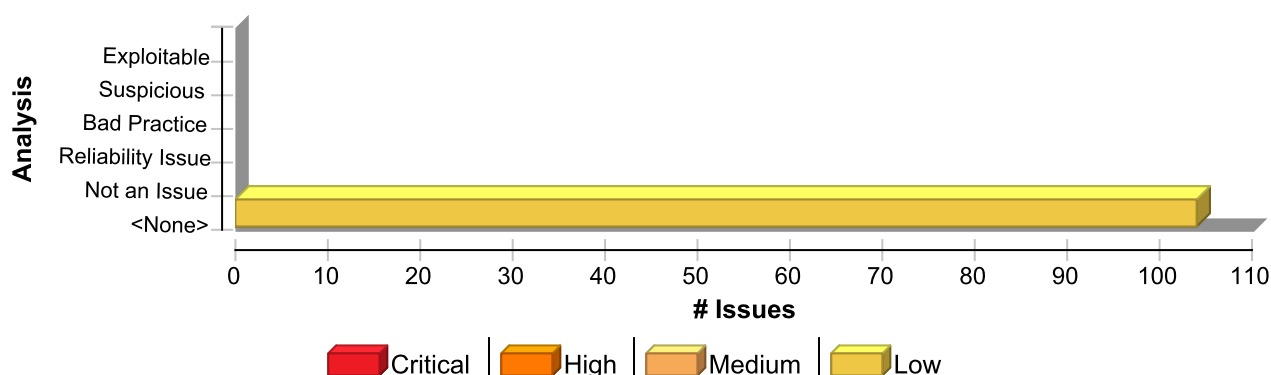
```
RequestBuilder rb = new RequestBuilder(RequestBuilder.POST, "/new_user");
body = addToPost(body, new_username);
body = addToPost(body, new_passwd);
body = addToPost(body, request_id);
rb.sendRequest(body, new NewAccountCallback(callback));
```

Then the back-end logic can validate the request identifier before processing the rest of the form data. When possible, the request identifier should be unique to each server request rather than shared across every request for a particular session. As with session identifiers, the harder it is for an attacker to guess the request identifier, the harder it is to conduct a successful CSRF attack. The token should not be easily guessed and it should be protected in the same way that session tokens are protected, such as using SSLv3. Additional mitigation techniques include: **Framework protection:** Most modern web application frameworks embed CSRF protection and they will automatically include and verify CSRF tokens. **Use a Challenge-Response control:** Forcing the customer to respond to a challenge sent by the server is a



strong defense against CSRF. Some of the challenges that can be used for this purpose are: CAPTCHAs, password re-authentication and one-time tokens. **Check HTTP Referer/Origin headers:** An attacker won't be able to spoof these headers while performing a CSRF attack. This makes these headers a useful method to prevent CSRF attacks. **Double-submit Session Cookie:** Sending the session ID Cookie as a hidden form value in addition to the actual session ID Cookie is a good protection against CSRF attacks. The server will check both values and make sure they are identical before processing the rest of the form data. If an attacker submits a form in behalf of a user, he won't be able to modify the session ID cookie value as per the same-origin-policy. **Limit Session Lifetime:** When accessing protected resources using a CSRF attack, the attack will only be valid as long as the session ID sent as part of the attack is still valid on the server. Limiting the Session lifetime will reduce the probability of a successful attack. The techniques described here can be defeated with XSS attacks. Effective CSRF mitigation includes XSS mitigation techniques.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Cross-Site Request Forgery	104	0	0	104
Total	104	0	0	104

Cross-Site Request Forgery

Low

Package: .src.components.steps

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/steps/Step2DataQC.tsx, line 308 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: handleDownloadTemplate()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/steps/Step2DataQC.tsx:308

Taint Flags:

```

305 // Call backend API to generate template with proper Excel data validation
306 const authHeaders = buildMidasAuthHeaders();
307 const response = await fetch(`/api/upload/generate-qc-template/${templateKey}`, {

```



Cross-Site Request Forgery

Low

Package: .src.components.steps

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/steps/Step2DataQC.tsx, line 308 (Cross-Site Request Forgery)

```
308 method: 'POST',
309 headers: {
310   'Content-Type': 'application/json',
311   ...authHeaders,
```

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts, line 244 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: startPreprocessing()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts:244
Taint Flags:

```
241 // Start data preprocessing
242 async startPreprocessing(datasetId: string, config: PreprocessingConfig):
Promise<ProcessingJob> {
243   const response = await this.request<{ data: ProcessingJob }>('/model-builder/
preprocessing/start', {
244     method: 'POST',
245     body: JSON.stringify({ datasetId, config })
246   });
247   return response.data;
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1038 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getVariableDefinitions()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1038
Taint Flags:

```
1035 console.log('Fetching variable definitions for dataset:', datasetId, 'columns:',
columns);
1036
1037 const response = await fetch(`${this.baseUrl}/datasets/${datasetId}/variable-
definitions`, {
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1038 (Cross-Site Request Forgery)

```
1038 method: 'POST',
1039 headers: {
1040   'Content-Type': 'application/json',
1041   ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4997 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: getSamplingPlan()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4997

Taint Flags:

```
4994 }> {
4995   try {
4996     const response = await fetch(`${this.baseUrl}/documentation/get-sampling-plan`, {
4997       method: 'POST',
4998       headers: {
4999         'Content-Type': 'application/json',
5000         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5320 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateDecileProgressionWriteup()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5320

Taint Flags:

```
5317 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
5318   try {
5319     const response = await fetch(`${this.baseUrl}/documentation/generate-decile-progression-
writeup`, {
5320       method: 'POST',
5321       headers: {
5322         'Content-Type': 'application/json',
5323         ...this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5320 (Cross-Site Request Forgery)

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1604 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getExclusionPreview()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1604
Taint Flags:

```
1601 formData.append('target_variable', targetVariable.trim());
1602
1603 const response = await fetch(`${this.baseUrl}/exclusion-preview`, {
1604   method: 'POST',
1605   body: formData,
1606   headers: this.getAuthHeaders(),
1607 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3983 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: lockTrainingVariables()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3983
Taint Flags:

```
3980 this.startKeepalive();
3981 try {
3982   const response = await fetch(`${this.baseUrl}/training/lock-variables`, {
3983     method: 'POST',
3984     headers: {
3985       'Content-Type': 'application/json',
3986       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5034 (Cross-Site Request Forgery)

Issue Details



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5034 (Cross-Site Request Forgery)

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getModelPerformance()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5034
Taint Flags:

```
5031 }> {  
5032 try {  
5033   const response = await fetch(`${this.baseUrl}/documentation/get-model-performance`, {  
5034     method: 'POST',  
5035     headers: {  
5036       'Content-Type': 'application/json',  
5037       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1553 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: partitionPreviewById()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1553
Taint Flags:

```
1550 }  
1551  
1552 const response = await fetch(`${this.baseUrl}/partition-preview-by-id`, {  
1553   method: 'POST',  
1554   body: formData,  
1555   headers: this.getAuthHeaders(),  
1556 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3341 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3341 (Cross-Site Request Forgery)

Sink: AssignmentStatement

Enclosing Method: applyFeatureTransformation()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3341

Taint Flags:

```
3338 }
3339
3340 const response = await fetch(`${this.baseUrl}/feature-transformation`, {
3341   method: 'POST',
3342   headers: this.getAuthHeaders(),
3343   body: formData
3344 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2672 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: validateSegmentationRules()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2672

Taint Flags:

```
2669 async validateSegmentationRules(request: UnifiedSegmentationRequest):
Promise<RuleValidationResult> {
2670   try {
2671     const response = await fetch(`${this.baseUrl}/segmentation/validate-rules`, {
2672       method: 'POST',
2673       headers: {
2674         'Content-Type': 'application/json',
2675         ...this.getAuthHeaders()
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5348 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateSamplingPlanWriteup()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5348

Taint Flags:



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5348 (Cross-Site Request Forgery)

```
5345 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
5346   try {
5347     const response = await fetch(`${this.baseUrl}/documentation/generate-sampling-plan-
writeup`, {
5348       method: 'POST',
5349       headers: {
5350         'Content-Type': 'application/json',
5351         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1824 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: crossAlgorithmRecommendation()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1824
Taint Flags:

```
1821 const response = await this.fetchWithAutoRefresh(
1822   `${this.baseUrl}/datasets/${datasetId}/cross-algorithm-recommendation`,
1823   {
1824     method: 'POST',
1825     headers: {
1826       'Content-Type': 'application/json',
1827       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5387 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateModelValidationWriteup()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5387
Taint Flags:

```
5384 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
5385   try {
5386     const response = await fetch(`${this.baseUrl}/documentation/generate-model-validation-
writeup`, {
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5387 (Cross-Site Request Forgery)

```
5387 method: 'POST',
5388 headers: {
5389   'Content-Type': 'application/json',
5390   ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts, line 229 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: startDataCollection()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts:229
Taint Flags:

```
226 // Start data collection
227 async startDataCollection(config: DataCollectionConfig): Promise<ProcessingJob> {
228   const response = await this.request<{ data: ProcessingJob }>('/model-builder/data-
collection', {
229     method: 'POST',
230     body: JSON.stringify(config)
231   });
232   return response.data;
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/authService.ts, line 180 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: verifyTokenStatus()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/authService.ts:180
Taint Flags:

```
177
178 try {
179   const response = await fetch(`${API_BASE_URL}/verify-token`, {
180     method: 'POST',
181     headers: {
182       'Authorization': `Bearer ${this.token}`,
183     },
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/authService.ts, line 180 (Cross-Site Request Forgery)

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3451 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: autoTrainModel()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3451
Taint Flags:

```
3448 console.log('^?? Starting auto training for dataset:', request.dataset_id);
3449
3450 const response = await fetch(`${this.baseUrl}/auto-train-model`, {
3451   method: 'POST',
3452   headers: {
3453     'Content-Type': 'application/json',
3454     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5525 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: identifyDuplicates()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5525
Taint Flags:

```
5522 columns.forEach(col => formData.append('columns', col));
5523
5524 const response = await fetch(`${this.baseUrl}/datasets/${datasetId}/identify-
duplicates`, {
5525   method: 'POST',
5526   headers: this.getAuthHeaders(),
5527   body: formData,
5528 });
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 744 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: post()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:744

Taint Flags:

```
741  }
742  console.log("Base url new from frontend",import.meta.env.VITE_BASE_URL)
743  const response = await this.fetchWithAutoRefresh(`${this.baseUrl}${url}`, {
744  method: 'POST',
745  body: data,
746  headers,
747  ...options
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2408 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: uploadUserKnowledge()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2408

Taint Flags:

```
2405  formData.append('files', file);
2406  }
2407  const response = await fetch(`${this.baseUrl}/user-knowledge/upload`, {
2408  method: 'POST',
2409  headers: { ...this.getAuthHeaders() },
2410  body: formData,
2411  });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4869 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4869 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateDataQualitySummary()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4869

Taint Flags:

```
4866 }): Promise<{ success: boolean; summary?: string; error?: string }> {
4867   try {
4868     const response = await fetch(`${this.baseUrl}/documentation/generate-data-quality-summary`, {
4869       method: 'POST',
4870       headers: {
4871         'Content-Type': 'application/json',
4872         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1447 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: analyzeDataset()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1447

Taint Flags:

```
1444 for (let attempt = 1; attempt <= MAX_RETRIES; attempt++) {
1445   try {
1446     const response = await this.fetchWithTimeout(`${this.baseUrl}/analyze-dataset`, {
1447       method: 'POST',
1448       body: formData,
1449       headers: this.getAuthHeaders(),
1450     }, timeoutMs);
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5568 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: removeDuplicates()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5568



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5568 (Cross-Site Request Forgery)

Taint Flags:

```
5565 columns.forEach(col => formData.append('columns', col));
5566
5567 const response = await fetch(`${this.baseUrl}/datasets/${datasetId}/remove-duplicates`, {
5568   method: 'POST',
5569   headers: this.getAuthHeaders(),
5570   body: formData,
5571 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2327 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateKnowledgeGraph()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2327
Taint Flags:

```
2324 console.log('^?? Generating knowledge graph for dataset:', datasetId);
2325
2326 const response = await fetch(`${this.baseUrl}/generate-knowledge-graph`, {
2327   method: 'POST',
2328   headers: {
2329     'Content-Type': 'application/json',
2330     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4788 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: cancelTrainMultipleModelsJob()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4788
Taint Flags:

```
4785
4786 try {
4787   await fetch(`${this.baseUrl}/train-multiple-models/cancel/${jobId}`, {
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4788 (Cross-Site Request Forgery)

```
4788 method: 'POST',
4789 headers: {
4790   'Content-Type': 'application/json',
4791   ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4893 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateTargetDefinition()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4893

Taint Flags:

```
4890 }): Promise<{ success: boolean; definition?: string; error?: string }> {
4891   try {
4892     const response = await fetch(`${this.baseUrl}/documentation/generate-target-definition`,
4893     {
4894       method: 'POST',
4895       headers: {
4896         'Content-Type': 'application/json',
4897         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3211 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: classifyDatasetType()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3211

Taint Flags:

```
3208 const enqueueTimeoutMs = this.computeIngestTimeoutMs(request.file.size);
3209 // POST returns immediately with a job_id - no longer blocks the upload flow
3210 const postResp = await this.fetchWithTimeout(`${this.baseUrl}/dataset-type-
classification`, {
3211   method: 'POST',
3212   headers: { ...this.getAuthHeaders() },
3213   body: formData,
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3211 (Cross-Site Request Forgery)

```
3214 }, enqueueTimeoutMs);
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2131 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: classifyDatasetVariables()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2131

Taint Flags:

```
2128
2129 // POST returns immediately with queued/cached status - no long connection held open
2130 const postResp = await fetch(`${this.baseUrl}/datasets/${datasetId}/classify-variables`,
2131 {
2132   method: 'POST',
2133   headers: this.getAuthHeaders(),
2134 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3251 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: classifyDatasetTypeById()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3251

Taint Flags:

```
3248 const postResp = await this.fetchWithTimeout(
3249   `${this.baseUrl}/dataset-type-classification-by-id`,
3250   {
3251     method: 'POST',
3252     headers: {
3253       'Content-Type': 'application/json',
3254       ...this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3917 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: analyzeDatasetForAutoTraining()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3917

Taint Flags:

```
3914 this.startKeepalive();
3915 try {
3916   const response = await fetch(`${this.baseUrl}/auto-training/analyze`, {
3917     method: 'POST',
3918     headers: {
3919       'Content-Type': 'application/json',
3920       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1719 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: getVariableReviewPreview()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1719

Taint Flags:

```
1716 formData.append('enable_llm_reasoning', enableLlmReasoning ? 'true' : 'false');
1717
1718 const response = await this.fetchWithAutoRefresh(`${this.baseUrl}/variable-review/
preview`, {
1719   method: 'POST',
1720   body: formData,
1721   headers: this.getAuthHeaders(),
1722 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1186 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1186 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: uploadDataset()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1186

Taint Flags:

```
1183 ?? (request.files && request.files.length > 0 ? Math.max(...request.files.map(f =>
f.size)) : 0);
1184 const timeoutMs = this.computeIngestTimeoutMs(primarySize);
1185 const response = await this.fetchWithTimeout(`${this.baseUrl}/upload`, {
1186 method: 'POST',
1187 body: formData,
1188 headers: this.getAuthHeaders(),
1189 }, timeoutMs);
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1936 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: reinitializeVectorStore()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1936

Taint Flags:

```
1933 console.log('Reinitializing vector store...');
1934
1935 const response = await fetch(`${this.baseUrl}/vector-store/reinitialize`, {
1936 method: 'POST',
1937 headers: this.getAuthHeaders()
1938 });
1939
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4317 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: detectSegments()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4317



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4317 (Cross-Site Request Forgery)

Taint Flags:

```
4314 this.startKeepalive();
4315 try {
4316   const response = await fetch(`${this.baseUrl}/detect-segments`, {
4317     method: 'POST',
4318     headers: {
4319       'Content-Type': 'application/json',
4320       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4597 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: startCalculateVifCorrelation()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4597
Taint Flags:

```
4594 this.startKeepalive();
4595 try {
4596   const response = await fetch(`${this.baseUrl}/calculate-vif-correlation/start`, {
4597     method: 'POST',
4598     headers: {
4599       'Content-Type': 'application/json',
4600       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1005 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateDqsRecommendations()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1005
Taint Flags:

```
1002 try {
1003   console.log('Generating DQS recommendations for dataset:', datasetId);
1004   const response = await fetch(`${this.baseUrl}/datasets/${datasetId}/dqs-
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1005 (Cross-Site Request Forgery)

```
recommendations`, {  
1005  method: 'POST',  
1006  headers: {  
1007    'Content-Type': 'application/json',  
1008    ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4969 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: calculateEventRate()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4969
Taint Flags:

```
4966  }): Promise<{ success: boolean; event_count?: number; total_count?: number; percentage?:  
number; error?: string }> {  
4967  try {  
4968    const response = await fetch(`${this.baseUrl}/documentation/calculate-event-rate`, {  
4969    method: 'POST',  
4970    headers: {  
4971      'Content-Type': 'application/json',  
4972      ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3648 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: runLrBackwardElimination()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3648
Taint Flags:

```
3645  segment_column?: string;  
3646  }): Promise<{ success: boolean; lr_backward_elimination: Record<string, unknown> }> {  
3647  const response = await fetch(`${this.baseUrl}/model-training/lr-backward-elimination`, {  
3648  method: 'POST',  
3649  headers: {  
3650    'Content-Type': 'application/json',
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3648 (Cross-Site Request Forgery)

```
3651 ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts, line 239 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: put()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts:239
Taint Flags:

```
236 options: ApiRequestOptions = {}  
237 ): Promise<ApiResponse<T>> {  
238   const body = data instanceof FormData ? data : JSON.stringify(data);  
239   return this.request<T>(endpoint, { ...options, method: 'PUT', body });  
240 }  
241  
242 /**
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2810 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: addSegmentationToData()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2810
Taint Flags:

```
2807 async addSegmentationToData(request: AddToDataRequest): Promise<AddToDataResponse> {  
2808   try {  
2809     const response = await fetch(`${this.baseUrl}/segmentation/add-to-data`, {  
2810       method: 'POST',  
2811       headers: {  
2812         'Content-Type': 'application/json',  
2813         ...this.getAuthHeaders()
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2545 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: runSegmentation()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2545

Taint Flags:

```
2542 this.startKeepalive();
2543 try {
2544   const response = await fetch(`${this.baseUrl}/run-segmentation`, {
2545     method: 'POST',
2546     headers: {
2547       'Content-Type': 'application/json',
2548       ...this.getAuthHeaders()
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/rfeService.ts, line 168 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: jsonPost()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/rfeService.ts:168

Taint Flags:

```
165
166 async function jsonPost<TReq, TResp>(path: string, body: TReq): Promise<TResp> {
167   const resp = await fetch(`${getBaseUrl()}${path}`, {
168     method: 'POST',
169     headers: { 'Content-Type': 'application/json', ...authHeaders() },
170     body: JSON.stringify(body),
171   });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1876 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1876 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: deleteDataset()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1876

Taint Flags:

```
1873 console.log('^?? Deleting dataset:', datasetId);
1874
1875 const response = await fetch(`${this.baseUrl}/datasets/${datasetId}`, {
1876   method: 'DELETE',
1877   headers: this.getAuthHeaders()
1878 });
1879
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5258 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateAIExplainabilityWriteup()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5258

Taint Flags:

```
5255 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
5256   try {
5257     const response = await fetch(`${this.baseUrl}/documentation/generate-ai-explainability-
writeup`, {
5258       method: 'POST',
5259       headers: {
5260         'Content-Type': 'application/json',
5261         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3543 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: trainMultipleModels()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3543



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3543 (Cross-Site Request Forgery)

Taint Flags:

```
3540 try {
3541 // Step 1: Start the training job
3542 const startResponse = await fetch(`${this.baseUrl}/train-multiple-models`, {
3543 method: 'POST',
3544 headers: {
3545 'Content-Type': 'application/json',
3546 ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5432 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getTransformedVariables()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5432
Taint Flags:

```
5429
5430 // Fallback to API
5431 const response = await fetch(`${this.baseUrl}/documentation/get-transformed-variables`, {
5432 method: 'POST',
5433 headers: {
5434 'Content-Type': 'application/json',
5435 ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts, line 227 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: post()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts:227
Taint Flags:

```
224 options: ApiRequestOptions = {}
225 ): Promise<ApiResponse<T>> {
226 const body = data instanceof FormData ? data : JSON.stringify(data);
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts, line 227 (Cross-Site Request Forgery)

```
227 return this.request<T>(endpoint, { ...options, method: 'POST', body });
228 }
229
230 /**
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5149 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateQualityChangesWriteup()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5149

Taint Flags:

```
5146 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
5147   try {
5148     const response = await fetch(`${this.baseUrl}/documentation/generate-quality-changes-
writeup`, {
5149       method: 'POST',
5150       headers: {
5151         'Content-Type': 'application/json',
5152         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5476 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: downloadDocumentation()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5476

Taint Flags:

```
5473 async downloadDocumentation(documentationData: any): Promise<Blob> {
5474   try {
5475     const response = await fetch(`${this.baseUrl}/documentation/download`, {
5476       method: 'POST',
5477       headers: {
5478         'Content-Type': 'application/json',
5479         ...this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5476 (Cross-Site Request Forgery)

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2842 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateSegmentationNarrative()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2842
Taint Flags:

```
2839 formData.append('context_data', JSON.stringify(contextData));
2840
2841 const response = await fetch(`${this.baseUrl}/segmentation/generate-narrative`, {
2842   method: 'POST',
2843   headers: this.getAuthHeaders(),
2844   body: formData,
2845 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1300 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: finalizePreSplitDataset()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1300
Taint Flags:

```
1297 }
1298
1299 const response = await fetch(`${this.baseUrl}/finalize-presplit`, {
1300   method: 'POST',
1301   body: formData,
1302   headers: this.getAuthHeaders(),
1303 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2043 (Cross-Site Request Forgery)

Issue Details



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2043 (Cross-Site Request Forgery)

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: updateDatasetConfig()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2043

Taint Flags:

```
2040  }
2041
2042  const response = await fetch(`${this.baseUrl}/datasets/${datasetId}/config`, {
2043    method: 'PUT',
2044    body: formData,
2045    headers: this.getAuthHeaders(),
2046  });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts, line 268 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: cancelJob()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts:268

Taint Flags:

```
265  // Cancel job
266  async cancelJob(jobId: string): Promise<boolean> {
267    const response = await this.request<{ data: { cancelled: boolean } }>(`/model-builder/
jobs/${jobId}/cancel`, {
268    method: 'POST'
269  });
270  return response.data.cancelled;
271  }
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4381 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4381 (Cross-Site Request Forgery)

Sink: AssignmentStatement

Enclosing Method: runSegmentAutoTraining()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4381

Taint Flags:

```
4378
4379 // Step 1: Start the training job
4380 const startResponse = await fetch(`${this.baseUrl}/segment-auto-training/run`, {
4381   method: 'POST',
4382   headers: {
4383     'Content-Type': 'application/json',
4384     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4813 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: cancelSegmentTrainingJob()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4813

Taint Flags:

```
4810
4811 try {
4812   await fetch(`${this.baseUrl}/segment-training/cancel/${jobId}`, {
4813     method: 'POST',
4814     headers: {
4815       'Content-Type': 'application/json',
4816       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1363 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: chunkedUpload()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1363

Taint Flags:



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1363 (Cross-Site Request Forgery)

```
1360 while (true) {
1361   try {
1362     const res = await fetch(`${this.baseUrl}/upload-chunked/${upload_id}`, {
1363       method: 'PATCH',
1364       headers: {
1365         'Content-Type': 'application/octet-stream',
1366         'Content-Range': `bytes ${start}-${end}/${file.size}`,
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3167 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: updateCustomTreatments()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3167
Taint Flags:

```
3164 console.log('^^? Updating custom treatments for dataset:', request.dataset_id);
3165
3166 const response = await fetch(`${this.baseUrl}/update-custom-treatments`, {
3167   method: 'POST',
3168   headers: {
3169     'Content-Type': 'application/json',
3170     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5080 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateSegmentationUnderstanding()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5080
Taint Flags:

```
5077 }): Promise<{ success: boolean; understanding?: string; error?: string }> {
5078   try {
5079     const response = await fetch(`${this.baseUrl}/documentation/generate-segmentation-
understanding`, {
5080       method: 'POST',
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5080 (Cross-Site Request Forgery)

```
5081 headers: {  
5082   'Content-Type': 'application/json',  
5083   ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5102 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getQualityCheckPlan()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5102
Taint Flags:

```
5099 async getQualityCheckPlan(datasetId: string): Promise<{ success: boolean; plan?:  
{ table: Array<{ Issue: string; Variable: string; Observation: string; Treatment: string }> };  
error?: string }> {  
5100   try {  
5101     const response = await fetch(`${this.baseUrl}/documentation/get-quality-check-plan`, {  
5102       method: 'POST',  
5103       headers: {  
5104         'Content-Type': 'application/json',  
5105         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1740 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: runVariableReview()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1740
Taint Flags:

```
1737 */  
1738 async runVariableReview(request: VariableReviewRequest): Promise<VariableReviewResponse>  
{  
1739   const response = await this.fetchWithAutoRefresh(`${this.baseUrl}/variable-review/run`, {  
1740     method: 'POST',  
1741     headers: {  
1742       'Content-Type': 'application/json',
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1740 (Cross-Site Request Forgery)

```
1743 ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3681 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: runSegmentTraining()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3681
Taint Flags:

```
3678 try {  
3679 // Step 1: Start the training job  
3680 const startResponse = await fetch(`${this.baseUrl}/segment-training/run`, {  
3681 method: 'POST',  
3682 headers: {  
3683 'Content-Type': 'application/json',  
3684 ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3946 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: autoSelectVariables()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3946
Taint Flags:

```
3943 this.startKeepalive();  
3944 try {  
3945 const response = await fetch(`${this.baseUrl}/auto-training/select-variables`, {  
3946 method: 'POST',  
3947 headers: {  
3948 'Content-Type': 'application/json',  
3949 ...this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5124 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getColumnStats()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5124
Taint Flags:

```
5121 async getColumnStats(datasetId: string): Promise<{ success: boolean; stats?: Array<any>;  
error?: string }> {  
5122   try {  
5123     const response = await fetch(`${this.baseUrl}/documentation/get-column-stats`, {  
5124       method: 'POST',  
5125       headers: {  
5126         'Content-Type': 'application/json',  
5127         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4836 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateDataSummary()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4836
Taint Flags:

```
4833 }): Promise<{ success: boolean; summary?: string; error?: string }> {  
4834   try {  
4835     const response = await fetch(`${this.baseUrl}/documentation/generate-data-summary`, {  
4836       method: 'POST',  
4837       headers: {  
4838         'Content-Type': 'application/json',  
4839         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1231 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1231 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: combinePreSplitFiles()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1231

Taint Flags:

```
1228 formData.append('target_variable', request.target_variable);
1229
1230 const response = await fetch(`${this.baseUrl}/combine-presplit`, {
1231   method: 'POST',
1232   body: formData,
1233   headers: this.getAuthHeaders(),
1234 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4947 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateMonotonicitySummary()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4947

Taint Flags:

```
4944 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
4945   try {
4946     const response = await fetch(`${this.baseUrl}/documentation/generate-monotonicity-
summary`, {
4947       method: 'POST',
4948       headers: {
4949         'Content-Type': 'application/json',
4950         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/cognitoAuthService.ts, line 237 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: logout()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/cognitoAuthService.ts, line 237 (Cross-Site Request Forgery)

cognitoAuthService.ts:237

Taint Flags:

```
234 try {
235   if (token) {
236     const resp = await fetch(`${COGNITO_API_BASE}/logout`, {
237       method: 'POST',
238       credentials: 'include',
239       headers: { Authorization: `Bearer ${token}` },
240     });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2434 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: updateUserKnowledgePreferences()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2434

Taint Flags:

```
2431 formData.append('use_across_midas', String(params.use_across_midas));
2432 formData.append('use_exl_expertise', String(params.use_exl_expertise));
2433 const response = await fetch(`${this.baseUrl}/user-knowledge/preferences`, {
2434   method: 'POST',
2435   headers: { ...this.getAuthHeaders() },
2436   body: formData,
2437 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiServices.ts, line 251 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: sendMessage()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiServices.ts:251

Taint Flags:

```
248 async sendMessage(messages: MoonshotMessage[], model: string = 'moonshot-v1-8k'):
Promise<MoonshotResponse> {
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiServices.ts, line 251 (Cross-Site Request Forgery)

```
249 try {
250   const response = await fetch(`${this.baseUrl}/chat/completions`, {
251     method: 'POST',
252     headers: {
253       'Authorization': `Bearer ${this.apiKey}`,
254       'Content-Type': 'application/json'
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4011 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: autoSelectAlgorithms()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4011
Taint Flags:

```
4008 this.startKeepalive();
4009 try {
4010   const response = await fetch(`${this.baseUrl}/auto-training/select-algorithms`, {
4011     method: 'POST',
4012     headers: {
4013       'Content-Type': 'application/json',
4014       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3394 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: startFeatureTransformationJob()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3394
Taint Flags:

```
3391 }
3392
3393 const response = await fetch(`${this.baseUrl}/feature-transformation/start`, {
3394   method: 'POST',
3395   headers: this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3394 (Cross-Site Request Forgery)

```
3396 body: formData
3397 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts, line 249 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: delete()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiInterceptor.ts:249
Taint Flags:

```
246 endpoint: string,
247 options: ApiRequestOptions = {}
248 ): Promise<ApiResponse<T>> {
249   return this.request<T>(endpoint, { ...options, method: 'DELETE' });
250 }
251
252 /**
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2766 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: editSegmentCutoff()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2766
Taint Flags:

```
2763 const response = await this.fetchWithTimeout(
2764   `${this.baseUrl}/segmentation/edit-cutoff`,
2765   {
2766     method: 'POST',
2767     headers: {
2768       'Content-Type': 'application/json',
2769     },
2770     ...this.getAuthHeaders()
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5454 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getVariableAnalysis()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5454
Taint Flags:

```
5451 async getVariableAnalysis(datasetId: string): Promise<{ success: boolean;  
variable_analysis?: any; variable_statistics?: Array<any>; error?: string }> {  
5452   try {  
5453     const response = await fetch(`${this.baseUrl}/documentation/get-variable-analysis`, {  
5454       method: 'POST',  
5455       headers: {  
5456         'Content-Type': 'application/json',  
5457         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/cognitoAuthService.ts, line 194 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: refresh()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/cognitoAuthService.ts:194
Taint Flags:

```
191 if (!COGNITO_DOMAIN) return false; // pure-client dev without Cognito configured  
192 try {  
193   const resp = await fetch(`${COGNITO_API_BASE}/refresh`, {  
194     method: 'POST',  
195     credentials: 'include',  
196     headers: { 'Content-Type': 'application/json' },  
197   });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2572 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2572 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: runAutoSegmentation()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2572

Taint Flags:

```
2569 this.startKeepalive();
2570 try {
2571   const response = await fetch(`${this.baseUrl}/run-auto-segmentation`, {
2572     method: 'POST',
2573     headers: {
2574       'Content-Type': 'application/json',
2575       ...this.getAuthHeaders()
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2292 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: regenerateQCTreatmentCode()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2292

Taint Flags:

```
2289 this.startKeepalive();
2290 try {
2291   const response = await this.fetchWithAutoRefresh(`${this.baseUrl}/qc/regenerate-code`, {
2292     method: 'POST',
2293     headers: {
2294       'Content-Type': 'application/json',
2295       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4918 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateModelObjective()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4918



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4918 (Cross-Site Request Forgery)

Taint Flags:

```
4915 }): Promise<{ success: boolean; objective?: string; error?: string }> {  
4916   try {  
4917     const response = await fetch(`${this.baseUrl}/documentation/generate-model-objective`, {  
4918       method: 'POST',  
4919       headers: {  
4920         'Content-Type': 'application/json',  
4921         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/cognitoAuthService.ts, line 161 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: completeLogin()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/cognitoAuthService.ts:161
Taint Flags:

```
158 }  
159  
160 const resp = await fetch(`${COGNITO_API_BASE}/exchange`, {  
161   method: 'POST',  
162   credentials: 'include',  
163   headers: { 'Content-Type': 'application/json' },  
164   body: JSON.stringify({
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2231 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: qcNextStep()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2231
Taint Flags:

```
2228 console.log(`^?^? QC Next Step: dataset=${datasetId}, action=${action}, treatment=${  
{treatmentType}`);
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2231 (Cross-Site Request Forgery)

```
2229
2230 const response = await this.fetchWithAutoRefresh(`${this.baseUrl}/qc/next-step`, {
2231   method: 'POST',
2232   headers: {
2233     'Content-Type': 'application/json',
2234     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2455 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: trainGlobalModel()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2455
Taint Flags:

```
2452 console.log('Request payload:', request);
2453
2454 const response = await fetch(`${this.baseUrl}/train-global-model`, {
2455   method: 'POST',
2456   headers: {
2457     'Content-Type': 'application/json',
2458     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1763 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: applyVariableRemoval()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1763
Taint Flags:

```
1760 */
1761 async applyVariableRemoval(request: ApplyVariableRemovalRequest):
Promise<ApplyVariableRemovalResponse> {
1762   const response = await this.fetchWithAutoRefresh(`${this.baseUrl}/variable-review/
apply`, {
1763     method: 'POST',
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1763 (Cross-Site Request Forgery)

```
1764 headers: {  
1765   'Content-Type': 'application/json',  
1766   ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5203 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: generateColumnDistributionInsights()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5203
Taint Flags:

```
5200 ): Promise<{ success: boolean; insights?: Array<{ title: string; description: string;  
type: 'info' | 'warning' | 'success' }>; error?: string }> {  
5201   try {  
5202     const response = await fetch(`${this.baseUrl}/datasets/${datasetId}/column-insights`, {  
5203     method: 'POST',  
5204     headers: {  
5205       'Content-Type': 'application/json',  
5206       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4737 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: cancelAutoTrainingJob()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4737
Taint Flags:

```
4734 /* ignore */  
4735 }  
4736 await fetch(`${this.baseUrl}/auto-training/cancel/${jobId}`, {  
4737 method: 'POST',  
4738 headers: {  
4739   'Content-Type': 'application/json',  
4740   ...this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4664 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: calculateVifCorrelation()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4664
Taint Flags:

```
4661 this.startKeepalive();  
4662 try {  
4663   const response = await fetch(`${this.baseUrl}/calculate-vif-correlation`, {  
4664     method: 'POST',  
4665     headers: {  
4666       'Content-Type': 'application/json',  
4667       ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5171 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: getDataInsights()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5171
Taint Flags:

```
5168 async getDataInsights(datasetId: string): Promise<{ success: boolean; insights?: any;  
error?: string }> {  
5169   try {  
5170     const response = await fetch(`${this.baseUrl}/documentation/get-data-insights`, {  
5171       method: 'POST',  
5172       headers: {  
5173         'Content-Type': 'application/json',  
5174         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2715 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2715 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: mergeSegments()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2715

Taint Flags:

```
2712 const response = await this.fetchWithTimeout(  
2713   `${this.baseUrl}/segmentation/merge-segments`,  
2714   {  
2715     method: 'POST',  
2716     headers: {  
2717       'Content-Type': 'application/json',  
2718       ...this.getAuthHeaders()
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 3856 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: startAnalyzeDatasetForAutoTraining()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:3856

Taint Flags:

```
3853 }): Promise<{ success: boolean; job_id: string; status: string; message?: string }> {  
3854   try {  
3855     const response = await fetch(`${this.baseUrl}/auto-training/analyze/start`, {  
3856       method: 'POST',  
3857       headers: {  
3858         'Content-Type': 'application/json',  
3859         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5232 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: generateFeatureEngineeringWriteup()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5232



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5232 (Cross-Site Request Forgery)

Taint Flags:

```
5229 }): Promise<{ success: boolean; writeup?: string; error?: string }> {
5230   try {
5231     const response = await fetch(`${this.baseUrl}/documentation/generate-feature-engineering-writeup`, {
5232       method: 'POST',
5233       headers: {
5234         'Content-Type': 'application/json',
5235         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1342 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: chunkedUpload()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1342
Taint Flags:

```
1339   }
1340
1341   const initRes = await fetch(`${this.baseUrl}/upload-chunked/init`, {
1342     method: 'POST',
1343     headers: { 'Content-Type': 'application/json', ...this.getAuthHeaders() },
1344     body: JSON.stringify({ filename: file.name, total_size: file.size }),
1345   });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1388 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: chunkedUpload()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1388
Taint Flags:

```
1385   }
1386
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1388 (Cross-Site Request Forgery)

```
1387 const finalRes = await fetch(`${this.baseUrl}/upload-chunked/${upload_id}/finalize`, {
1388   method: 'POST',
1389   headers: this.getAuthHeaders(),
1390 });
1391 if (!finalRes.ok) {
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1789 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: chatWithDataset()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1789
Taint Flags:

```
1786 console.log('^?? Sending chat request to FastAPI backend:', request.query.substring(0,
50) + '...');
1787
1788 const response = await this.fetchWithAutoRefresh(`${this.baseUrl}/chat`, {
1789   method: 'POST',
1790   headers: {
1791     'Content-Type': 'application/json',
1792     ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2191 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: executeCode()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2191
Taint Flags:

```
2188 formData.append('code', code);
2189
2190 const response = await fetch(`${this.baseUrl}/execute-code`, {
2191   method: 'POST',
2192   body: formData,
2193   headers: this.getAuthHeaders(),
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2191 (Cross-Site Request Forgery)

```
2194  });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4763 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: cancelSegmentAutoTrainingJob()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4763
Taint Flags:

```
4760  
4761  try {  
4762    await fetch(`${this.baseUrl}/segment-auto-training/cancel/${jobId}`, {  
4763      method: 'POST',  
4764      headers: {  
4765        'Content-Type': 'application/json',  
4766        ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1084 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: validateUniquelds()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1084
Taint Flags:

```
1081  formData.append('unique_id_columns', JSON.stringify(uniqueIdColumns));  
1082  
1083  const response = await fetch(`${this.baseUrl}/validate-unique-ids`, {  
1084    method: 'POST',  
1085    body: formData,  
1086    headers: this.getAuthHeaders(),  
1087  });
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 4135 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: runCompleteAutoTraining()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:4135

Taint Flags:

```
4132 for (let attempt = 1; attempt <= MAX_START_RETRIES; attempt++) {
4133   try {
4134     startResponse = await fetch(`${this.baseUrl}/auto-training/run`, {
4135       method: 'POST',
4136       headers: {
4137         'Content-Type': 'application/json',
4138         ...this.getAuthHeaders(),
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1660 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: getExclusionPreviewById()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1660

Taint Flags:

```
1657 formData.append('target_variable', targetVariable.trim());
1658
1659 const response = await fetch(`${this.baseUrl}/exclusion-preview-by-id`, {
1660   method: 'POST',
1661   body: formData,
1662   headers: this.getAuthHeaders(),
1663 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts, line 253 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts, line 253 (Cross-Site Request Forgery)

Sink Details

Sink: AssignmentStatement

Enclosing Method: startFeatureEngineering()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/creditRiskApi.ts:253

Taint Flags:

```
250 // Start feature engineering
251 async startFeatureEngineering(datasetId: string, config: FeatureEngineeringConfig):
Promise<ProcessingJob> {
252   const response = await this.request<{ data: ProcessingJob }>('/model-builder/features/
generate', {
253     method: 'POST',
254     body: JSON.stringify({ datasetId, config })
255   });
256   return response.data;
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 1508 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: partitionPreview()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:1508

Taint Flags:

```
1505 }
1506
1507 const response = await fetch(`${this.baseUrl}/partition-preview`, {
1508   method: 'POST',
1509   body: formData,
1510   headers: this.getAuthHeaders(),
1511 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiServices.ts, line 297 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: sendMessage()



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiServices.ts, line 297 (Cross-Site Request Forgery)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/apiServices.ts:297

Taint Flags:

```
294 async sendMessage(messages: any[], model: string = 'gemini-2.0-flash'): Promise<any> {
295   try {
296     const response = await fetch(`https://generativelanguage.googleapis.com/v1beta/models/${
297       {model}:generateContent?key=${this.apiKey}`, {
298       method: 'POST',
299       headers: {
300         'Content-Type': 'application/json'
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 2614 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: runUnifiedSegmentation()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:2614

Taint Flags:

```
2611 const response = await this.fetchWithTimeout(
2612   `${this.baseUrl}/segmentation/run`,
2613   {
2614     method: 'POST',
2615     headers: {
2616       'Content-Type': 'application/json',
2617     ...this.getAuthHeaders()
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5288 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: evaluatePrunedModel()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts:5288

Taint Flags:

```
5285 const parts = data.pruned_model_id.split('_pruned_');
```



Cross-Site Request Forgery

Low

Package: .src.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/fastApiService.ts, line 5288 (Cross-Site Request Forgery)

```
5286 const original_model_id = parts[0];
5287 const response = await fetch(`${this.baseUrl}/model-evaluation/${original_model_id}/
evaluate-pruned`, {
5288   method: 'POST',
5289   headers: {
5290     'Content-Type': 'application/json',
5291     ...this.getAuthHeaders(),
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test_project_integration.html, line 76 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: go()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test_project_integration.html:76
Taint Flags:

```
73
74 try {
75   const response = await fetch('http://localhost:8000/api/v1/auth/login', {
76     method: 'POST',
77     headers: {
78       'Content-Type': 'application/json',
79     },
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test_project_integration.html, line 116 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement
Enclosing Method: go()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test_project_integration.html:116
Taint Flags:

```
113
114 try {
115   const response = await fetch('http://localhost:8000/api/v1/projects', {
```



Cross-Site Request Forgery

Low

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
test_project_integration.html, line 116 (Cross-Site Request Forgery)

```
116 method: 'POST',
117 headers: {
118   'Content-Type': 'application/json',
119   'Authorization': `Bearer ${authToken}`
```



Cross-Site Scripting: DOM (5 issues)

Abstract

Sending unvalidated data to a web browser can result in the browser executing malicious code.

Explanation

Cross-site scripting (XSS) vulnerabilities occur when: 1. Data enters a web application through an untrusted source. In the case of DOM-based XSS, data is read from a URL parameter or other value within the browser and written back into the page with client-side code. In the case of reflected XSS, the untrusted source is typically a web request, while in the case of persisted (also known as stored) XSS it is typically a database or other back-end data store. 2. The data is included in dynamic content that is sent to a web user without validation. In the case of DOM-based XSS, malicious content is executed as part of DOM (Document Object Model) creation, whenever the victim's browser parses the HTML page. The malicious content sent to the web browser often takes the form of a JavaScript segment, but can also include HTML, Flash or any other type of code that the browser executes. The variety of attacks based on XSS is almost limitless, but they commonly include transmitting private data such as cookies or other session information to the attacker, redirecting the victim to web content controlled by the attacker, or performing other malicious operations on the user's machine under the guise of the vulnerable site. **Example 1:** The following JavaScript code segment reads an employee ID, `eid`, from a URL and displays it to the user.

```
<SCRIPT>
var pos=document.URL.indexOf("eid=")+4;
document.write(document.URL.substring(pos,document.URL.length));
</SCRIPT>
```

Example 2: Consider the HTML form:

```
<div id="myDiv">
Employee ID: <input type="text" id="eid"><br>
...
<button>Show results</button>
</div>
<div id="resultsDiv">
...
</div>
```

The following jQuery code segment reads an employee ID from the form, and displays it to the user.

```
$(document).ready(function(){
$("#myDiv").on("click", "button", function(){
var eid = $("#eid").val();
$("#resultsDiv").append(eid);
...
});
});
```

These code examples operate correctly if the employee ID from the text input with ID `eid` contains only standard alphanumeric text. If `eid` has a value that includes metacharacters or source code, then the code will be executed by the web browser as it displays the HTTP response. **Example 3:** The following code shows an example of a DOM-based XSS within a React application:

```
let element = JSON.parse(getUntrustedInput());
ReactDOM.render(<App>
{element}
</App>);
```

In Example 3, if an attacker can control the entire JSON object retrieved from `getUntrustedInput()`, they may be able to make React render `element` as a component, and therefore can pass an object with `dangerouslySetInnerHTML` with their own controlled value, a typical cross-site scripting attack. Initially these might not appear to be much of a vulnerability. After all, why would someone provide input containing malicious code to run on their own computer? The real danger is that an attacker will create the malicious



URL, then use email or social engineering tricks to lure victims into visiting a link to the URL. When victims click the link, they unwittingly reflect the malicious content through the vulnerable web application back to their own computers. This mechanism of exploiting vulnerable web applications is known as Reflected XSS. As the example demonstrates, XSS vulnerabilities are caused by code that includes unvalidated data in an HTTP response. There are three vectors by which an XSS attack can reach a victim: - Data is read directly from the HTTP request and reflected back in the HTTP response. Reflected XSS exploits occur when an attacker causes a user to supply dangerous content to a vulnerable web application, which is then reflected back to the user and executed by the web browser. The most common mechanism for delivering malicious content is to include it as a parameter in a URL that is posted publicly or emailed directly to victims. URLs constructed in this manner constitute the core of many phishing schemes, whereby an attacker convinces victims to visit a URL that refers to a vulnerable site. After the site reflects the attacker's content back to the user, the content is executed and proceeds to transfer private information, such as cookies that might include session information, from the user's machine to the attacker or perform other nefarious activities. - The application stores dangerous data in a database or other trusted data store. The dangerous data is subsequently read back into the application and included in dynamic content. Persistent XSS exploits occur when an attacker injects dangerous content into a data store that is later read and included in dynamic content. From an attacker's perspective, the optimal place to inject malicious content is in an area that is displayed to either many users or particularly interesting users. Interesting users typically have elevated privileges in the application or interact with sensitive data that is valuable to the attacker. If one of these users executes malicious content, the attacker may be able to perform privileged operations on behalf of the user or gain access to sensitive data belonging to the user. - A source outside the application stores dangerous data in a database or other data store, and the dangerous data is subsequently read back into the application as trusted data and included in dynamic content.

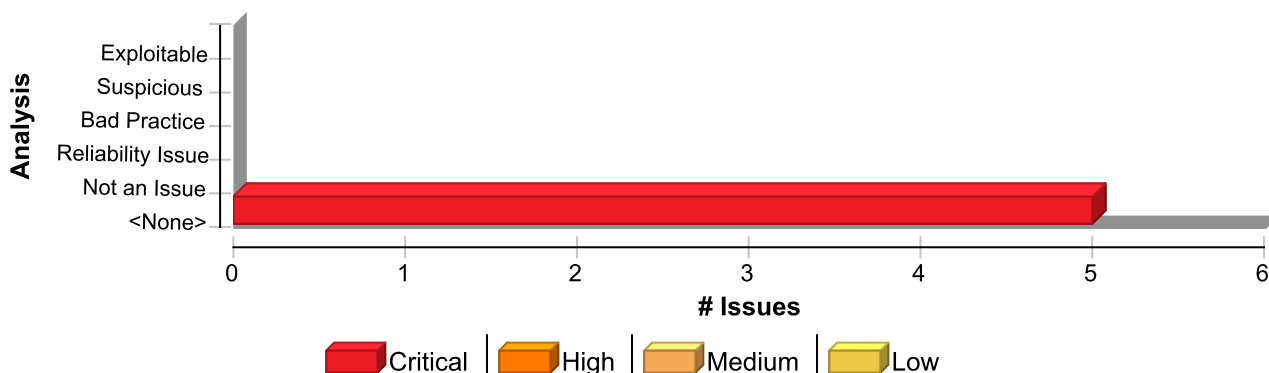
Recommendation

The solution to prevent XSS is to ensure that validation occurs in the required places and that relevant properties are set to prevent vulnerabilities. Because XSS vulnerabilities occur when an application includes malicious data in its output, one logical approach is to validate data immediately before it leaves the application. However, because web applications often have complex and intricate code for generating dynamic content, this method is prone to errors of omission (missing validation). An effective way to mitigate this risk is to also perform input validation for XSS. Web applications must validate all input to prevent other vulnerabilities, such as SQL injection, so augmenting an application's existing input validation mechanism to include checks for XSS is generally relatively easy. Despite its value, input validation for XSS does not take the place of rigorous output validation. An application might accept input through a shared data store or other trusted source, and that data store might accept input from a source that does not perform adequate input validation. Therefore, the application cannot implicitly rely on the safety of this or any other data. This means that the best way to prevent XSS vulnerabilities is to validate everything that enters the application and leaves the application destined for the user. The most secure approach to validation for XSS is to create an allow list of safe characters that can appear in HTTP content and accept input composed exclusively of characters in the approved set. For example, a valid username might only include alphanumeric characters or a phone number might only include digits 0-9. However, this solution is often infeasible in web applications because many characters that have special meaning to the browser must be considered valid input after they are encoded, such as a web design bulletin board that must accept HTML fragments from its users. A more flexible, but less secure approach is to implement a deny list, which selectively rejects or escapes potentially dangerous characters before using the input. To form such a list, you first need to understand the set of characters that hold special meaning for web browsers. Although the HTML standard defines which characters have special meaning, many web browsers try to correct common mistakes in HTML and might treat other characters as special in certain contexts. This is why we do not recommend the use of deny lists as a means to prevent XSS. The CERT(R) Coordination Center at the Software Engineering Institute at Carnegie Mellon University provides the following details about special characters in various contexts [1]: In the content of a block-level element (in the middle of a paragraph of text): - "<" is special because it introduces a tag. - "&" is special because it introduces a character entity. - ">" is special because some browsers treat it as special, on the assumption that the author of the page intended to include an opening "<", but omitted it in error. The following principles apply to attribute values: - In attribute values enclosed in double quotes, the double quotes are special because



they mark the end of the attribute value. - In attribute values enclosed in single quote, the single quotes are special because they mark the end of the attribute value. - In attribute values without any quotes, white-space characters, such as space and tab, are special. - "&" is special when used with certain attributes, because it introduces a character entity. In URLs, for example, a search engine might provide a link within the results page that the user can click to re-run the search. This can be implemented by encoding the search query inside the URL, which introduces additional special characters: - Space, tab, and new line are special because they mark the end of the URL. - "&" is special because it either introduces a character entity or separates CGI parameters. - Non-ASCII characters (that is, everything greater than 127 in the ISO-8859-1 encoding) are not allowed in URLs, so they are considered to be special in this context. - The "%" symbol must be filtered from input anywhere parameters encoded with HTTP escape sequences are decoded by server-side code. For example, "%" must be filtered if input such as "%68%65%6C%6C%6F" becomes "hello" when it appears on the web page. Within the body of a : - Semicolons, parentheses, curly braces, and new line characters must be filtered out in situations where text could be inserted directly into a pre-existing script tag. Server-side scripts: - Server-side scripts that convert any exclamation characters (!) in input to double-quote characters (") on output might require additional filtering. Other possibilities: - If an attacker submits a request in UTF-7, the special character '<' appears as '+ADw-' and might bypass filtering. If the output is included in a page that does not explicitly specify an encoding format, then some browsers try to intelligently identify the encoding based on the content (in this case, UTF-7). After you identify the correct points in an application to perform validation for XSS attacks and what special characters the validation should consider, the next challenge is to identify how your validation handles special characters. If special characters are not considered valid input to the application, then you can reject any input that contains special characters as invalid. A second option is to remove special characters with filtering. However, filtering has the side effect of changing any visual representation of the filtered content and might be unacceptable in circumstances where the integrity of the input must be preserved for display. If input containing special characters must be accepted and displayed accurately, validation must encode any special characters to remove their significance. A complete list of ISO 8859-1 encoded values for special characters is provided as part of the official HTML specification [2]. Many application servers attempt to limit an application's exposure to cross-site scripting vulnerabilities by providing implementations for the functions responsible for setting certain specific HTTP response content that perform validation for the characters essential to a cross-site scripting attack. Do not rely on the server running your application to make it secure. For any developed application, there are no guarantees about which application servers it will run on during its lifetime. As standards and known exploits evolve, there are no guarantees that application servers will continue to stay in sync.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Cross-Site Scripting: DOM	5	0	0	5
Total	5	0	0	5



Cross-Site Scripting: DOM

Critical

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/SessionExpiredModal.tsx, line 61 (Cross-Site Scripting: DOM)

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: SCA (Data Flow)

Source Details

Source: getItem()
From: AuthService
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/services/authService.ts:76

```
73 // Load internal access token from localStorage on initialization.  
74 // Note: the legacy `refresh_token` key is intentionally no longer read  
or written here – the Cognito  
75 // refresh token lives in a backend-issued HttpOnly cookie and is never  
exposed to JS.  
76 this.token = localStorage.getItem('auth_token');  
77 // Clean up any legacy refresh token previously written by the username/  
password flow.  
78 localStorage.removeItem('refresh_token');  
79 }
```

Sink Details

Sink: Assignment to onClick
Enclosing Method: SessionExpiredModal()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/SessionExpiredModal.tsx:61
Taint Flags: DATABASE, XSS

```
58 <div className="mt-6 flex justify-end">  
59 <button  
60 type="button"  
61 onClick={onConfirm}  
62 className="rounded-md bg-blue-600 px-4 py-2 text-sm font-medium text-white hover:bg-  
blue-700 focus:outline-none focus:ring-2 focus:ring-blue-500"  
63 >  
64 OK
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.docs.html_diagram.final.requirements

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/final/requirements/index.html, line 128 (Cross-Site Scripting: DOM)

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: SCA (Data Flow)



Cross-Site Scripting: DOM

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.docs.html_diagram.final.requirements

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/final/requirements/index.html, line 128 (Cross-Site Scripting: DOM)

Source Details

Source: Read window.location.search

From: lambda

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/final/requirements/index.html:112

```
109 if (p === "should") return "pri-should";
110 return "pri-could";
111 }
112 const params = new URLSearchParams(window.location.search);
113 const node = params.get("node");
114 const all = window.MIDAS_REQUIREMENTS || [];
115 const labels = window.MIDAS_NODE_LABELS || {};
```

Sink Details

Sink: Assignment to filterText.innerHTML

Enclosing Method: lambda()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/final/requirements/index.html:128

Taint Flags: VALIDATED_OPEN_REDIRECT, WEB, XSS

```
125 totalEl.textContent = all.length + " requirements in register";
126 if (node) {
127   bar.style.display = "flex";
128   filterText.innerHTML =
129     "Filtered to <strong>" +
130     esc(labels[node] || node) +
131     "</strong> (" +
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.docs.html_diagram.future.decisions

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/decisions/index.html, line 109 (Cross-Site Scripting: DOM)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: Read window.location.search

From: lambda

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/decisions/index.html:94



Cross-Site Scripting: DOM

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.docs.html_diagram.future.decisions

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/decisions/index.html, line 109 (Cross-Site Scripting: DOM)

```
91 .replace(>/g, "&gt;");
92 .replace(/"/g, "&quot;");
93 }
94 const params = new URLSearchParams(window.location.search);
95 const node = params.get("node");
96 const all = window.MIDAS_DECISIONS || [];
97 const labels = window.MIDAS_NODE_LABELS || {};
```

Sink Details

Sink: Assignment to filterText.innerHTML

Enclosing Method: lambda()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/decisions/index.html:109

Taint Flags: VALIDATED_OPEN_REDIRECT, WEB, XSS

```
106 const filterText = document.getElementById("filter-text");
107 if (node) {
108   bar.style.display = "flex";
109   filterText.innerHTML =
110     "Filtered to <strong>" +
111     esc(labels[node] || node) +
112     "</strong> - " +
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.docs.html_diagram.future.requirements

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/requirements/index.html, line 129 (Cross-Site Scripting: DOM)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: Read window.location.search

From: lambda

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/requirements/index.html:111

```
108 if (p === "should") return "pri-should";
109 return "pri-could";
110 }
111 const params = new URLSearchParams(window.location.search);
```



Cross-Site Scripting: DOM

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.docs.html_diagram.future.requirements

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/requirements/index.html, line 129 (Cross-Site Scripting: DOM)

```
112 const node = params.get("node");
113 const all = window.MIDAS_REQUIREMENTS || [];
114 const labels = window.MIDAS_NODE_LABELS || {};
```

Sink Details

Sink: Assignment to filterText.innerHTML

Enclosing Method: lambda()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docs/html_diagram/future/requirements/index.html:129

Taint Flags: VALIDATED_OPEN_REDIRECT, WEB, XSS

```
126 if (node) {
127   bar.style.display = "flex";
128   var cxTier = (cxMap[node] || "").toUpperCase();
129   filterText.innerHTML =
130     "Filtered to <strong>" +
131     esc(labels[node] || node) +
132     "</strong> (" +
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test-auth.html, line 26 (Cross-Site Scripting: DOM)

Issue Details

Kingdom: Input Validation and Representation

Scan Engine: SCA (Data Flow)

Source Details

Source: getItem()

From: checkAuth

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test-auth.html:24

```
21 }
22
23 function checkAuth() {
24   const userData = localStorage.getItem('userData');
25   const status = userData ? 'User is authenticated' : 'User is NOT
authenticated';
26   document.getElementById('status').innerHTML = status + '<br>User data: '
+ userData;
27 }
```



Cross-Site Scripting: DOM

Critical

Package: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test-auth.html, line 26 (Cross-Site Scripting: DOM)

Sink Details

Sink: Assignment to innerHTML

Enclosing Method: checkAuth()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/test-auth.html:26

Taint Flags: DATABASE, XSS

```
23 function checkAuth() {  
24   const userData = localStorage.getItem('userData');  
25   const status = userData ? 'User is authenticated' : 'User is NOT authenticated';  
26   document.getElementById('status').innerHTML = status + '<br>User data: ' + userData;  
27 }  
28  
29 function goToApp() {
```

Dockerfile Misconfiguration: Default User Privilege (4 issues)

Abstract

The Dockerfile does not specify a USER, so it defaults to running with a root user.

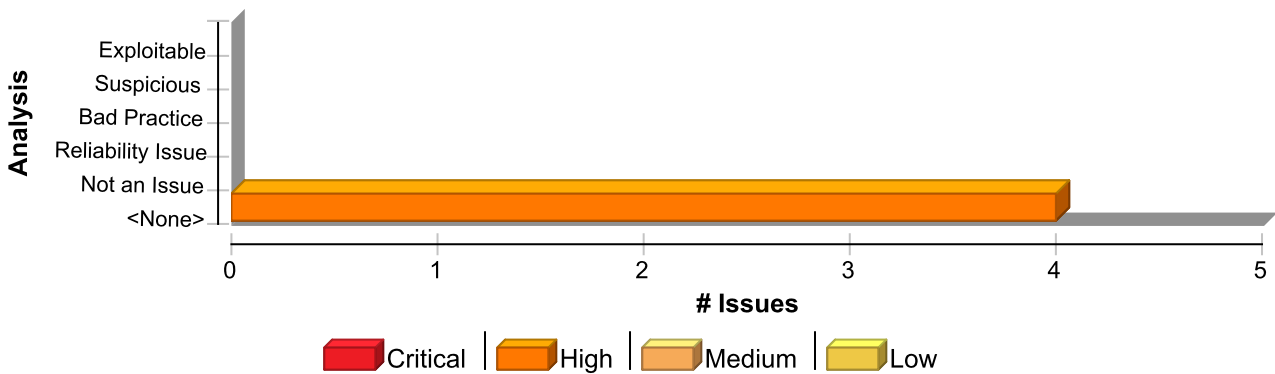
Explanation

When a Dockerfile does not specify a USER, Docker containers run with super user privileges by default. These super user privileges are propagated to the code running inside the container, which is usually more permission than necessary. Running the Docker container with super user privileges broadens the attack surface which might enable attackers to perform more serious forms of exploitation.

Recommendation

It is good practice to run your containers as a non-root user when possible. To modify a docker container to use a non-root user, the Dockerfile needs to specify a different user, such as:
RUN useradd myLowPrivilegeUser
USER myLowPrivilegeUser

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Dockerfile Misconfiguration: Default User Privilege	4	0	0	4
Total	4	0	0	4

Dockerfile Misconfiguration: Default User Privilege	High
---	------

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/ Dockerfile.graphrag, line 1 (Dockerfile Misconfiguration: Default User Privilege)
--

Issue Details

Kingdom: Environment
Scan Engine: SCA (Configuration)

Sink Details



Dockerfile Misconfiguration: Default User Privilege

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/
Dockerfile.graphrag, line 1 (Dockerfile Misconfiguration: Default User Privilege)

Sink: FROM

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/Dockerfile.graphrag:1

Taint Flags:

```
1 FROM python:3.12-slim
2
3 ENV PYTHONDONTWRITEBYTECODE=1 \
4   PYTHONUNBUFFERED=1 \
5
6
7
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ecs-app.docker.midas-api-backend-svc

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/
docker/midas-api-backend-svc/Dockerfile, line 2 (Dockerfile Misconfiguration:
Default User Privilege)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details

Sink: FROM

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/docker/midas-api-backend-svc/Dockerfile:2

Taint Flags:

```
1 # Stub image for pipeline validation; replace with application image when ready.
2 FROM nginx:1.25-alpine
3 LABEL org.opencontainers.image.title="midas-api-backend-svc"
4
5 undefined
6 undefined
7 undefined
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ecs-app.docker.midas-graph-svc

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/
docker/midas-graph-svc/Dockerfile, line 2 (Dockerfile Misconfiguration: Default
User Privilege)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)



Dockerfile Misconfiguration: Default User Privilege

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ecs-app.docker.midas-graph-svc

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/docker/midas-graph-svc/Dockerfile, line 2 (Dockerfile Misconfiguration: Default User Privilege)

Sink Details

Sink: FROM

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/docker/midas-graph-svc/Dockerfile:2

Taint Flags:

```
1 # Stub image for pipeline validation; replace with application image when ready.
2 FROM nginx:1.25-alpine
3 LABEL org.opencontainers.image.title="midas-graph-svc"
4
5 undefined
6 undefined
7 undefined
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ecs-app.docker.midas-web-frontend-svc

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/docker/midas-web-frontend-svc/Dockerfile, line 3 (Dockerfile Misconfiguration: Default User Privilege)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details

Sink: FROM

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/docker/midas-web-frontend-svc/Dockerfile:3

Taint Flags:

```
1 # Stub image for pipeline validation; replace with application image when ready.
2 # Prefer production builds from deploy/ecs-app/docker/build-registry/images.yaml (context: frontend).
3 FROM nginx:1.25-alpine
4 LABEL org.opencontainers.image.title="midas-web-frontend-svc"
5
6 # Kubernetes HTTP probes expect GET /health; default nginx root has no such file → 404 → SIGQUIT.
7
```



Dockerfile Misconfiguration: Dependency Confusion (4 issues)

Abstract

Retrieving build dependencies using a non-specific version can leave the build system vulnerable to malicious binaries or cause the system to experience unexpected behavior.

Explanation

Dockerfiles can specify an unbound range of versions for dependencies and base images. If an attacker is able to add malicious versions of dependencies to a repository or trick the build system into downloading dependencies from a repository under the attacker's control, if docker is configured without specific versions of dependencies, then docker will silently download and run the compromised dependency. This type of weakness would be exploitable as a result of a supply chain attack where attackers can leverage misconfiguration by developers, typosquatting and can add malicious packages to open source repositories. An attack of this type exploits the trust in the published packages to gain access and exfiltrate data. In docker, the latest tag automatically indicates the version level of an image that doesn't use a digest or unique tag to provide a version for it. Docker automatically assigns the latest tag as mechanism to point to the most recent image manifest file. Because tags are mutable, an attacker can replace an image or layer using a latest (or weak tags such as imagename-lst, imagename-last, myimage).

Example 1: The following configuration instructs Docker to pick the base image using the latest version of ubuntu.

```
FROM ubuntu:Latest
```

```
...
```

Docker does not validate whether the repository configured to support the package manager is trustworthy.

Example 2: The following configuration instructs the package manager zypper to retrieve the latest version of the given package.

```
...
```

```
zypper install package
```

```
...
```

In Example 2, if the repository is compromised, an attacker could simply upload a version that meets the dynamic criteria and cause zypper to download a malicious version of the dependency.

Recommendation

Perform version pinning or simple pinning. Version pinning explicitly specifies the version of images, libraries and support packages an application or system depends on. The primary goal of pinning is to ensure system stability to achieve repeatable deployments. Pinning ensures that end-users, developers, and testers all use the same code base. Pinning can additionally ensure the use of safe dependencies; those which have gone through the rigorous process of application security validation and malware detection. When you invoke zypper (or other package managers) from docker, use the following formats:

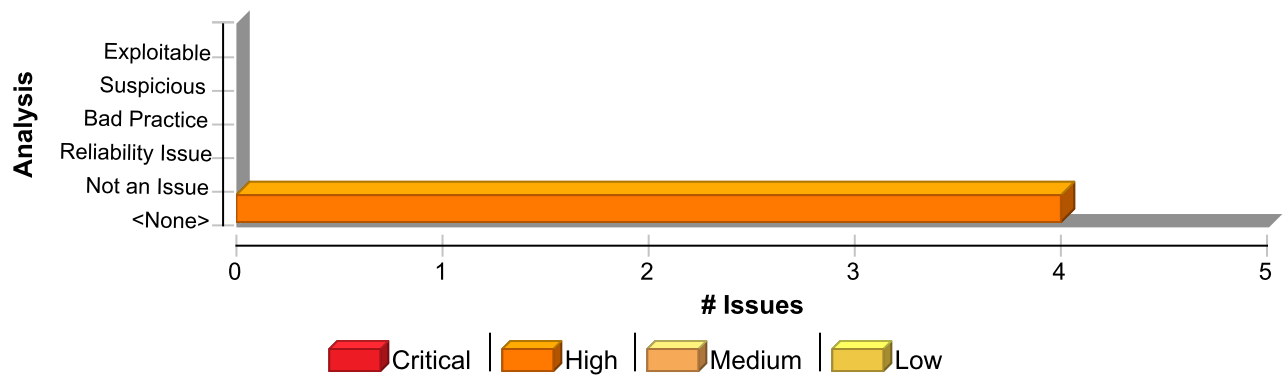
```
RUN zypper install <package_name>=<version> \  
RUN gem install <package_name> --version <version>  
RUN gem install <package_name> -v <version>  
RUN apk add <package_name>=<version>  
RUN apt-get update && apt-get install -y \  
<package_name>=<version> \  
<package_name>=<version> \  
<package_name>=<version> \  
&& rm -rf /var/lib/apt/lists/*
```

Where is the name of the dependency to install and is the exact version or release the application should use. Fortify also recommends: - Ensure the repositories that the package managers use are trustworthy or that they are properly kept, and there is no install package substitution possible, including the addition of malicious code onto the package. - Avoid using public or untrusted repositories. - Scan packages for



malware and security vulnerabilities prior to executing any regression tests. - Use digitally signed images. - Avoid using image tags such as latest or weak tags such as `imagename-lst`, `imagename-last`, `myimage` for deployments in production environments. - Stick to more stable tags, like specific version tags, although there is no guarantee that these cannot mutate either. - Do not create mutant tags. - Implement strict control over the source of images and their layers.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Dockerfile Misconfiguration: Dependency Confusion	4	0	0	4
Total	4	0	0	4

Dockerfile Misconfiguration: Dependency Confusion

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/
Dockerfile.graphrag, line 10 (Dockerfile Misconfiguration: Dependency Confusion)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Configuration)

Sink Details

Sink: RUN
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/Dockerfile.graphrag:10
Taint Flags:

```
7
8 WORKDIR /app
9
10 RUN apt-get update \
11   && apt-get install -y --no-install-recommends curl build-essential \
12   && rm -rf /var/lib/apt/lists/*
13
```



Dockerfile Misconfiguration: Dependency Confusion

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/
Dockerfile, line 7 (Dockerfile Misconfiguration: Dependency Confusion)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details

Sink: RUN

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/Dockerfile:7

Taint Flags:

```
4 WORKDIR /app
5
6 # Install system dependencies
7 RUN apt-get update && apt-get install -y \
8 gcc \
9 g++ \
10 curl \
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ai_gateway.CI

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/
ai_gateway/CI/Dockerfile.c1-api-midas, line 37 (Dockerfile Misconfiguration:
Dependency Confusion)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details

Sink: RUN

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ai_gateway/CI/Dockerfile.c1-api-midas:37

Taint Flags:

```
34
35 ARG SPACY_MODEL_WHEEL="https://github.com/explosion/spacy-models/releases/download/
en_core_web_lg-3.8.0/en_core_web_lg-3.8.0-py3-none-any.whl"
36
37 RUN apt-get update \
38 && apt-get install -y --no-install-recommends curl ca-certificates \
39 && rm -rf /var/lib/apt/lists/* \
40 && groupadd -r appgroup \
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
Dockerfile, line 62 (Dockerfile Misconfiguration: Dependency Confusion)

Issue Details



Dockerfile Misconfiguration: Dependency Confusion	High
Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend	
Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/ Dockerfile, line 62 (Dockerfile Misconfiguration: Dependency Confusion)	

Kingdom: Environment
Scan Engine: SCA (Configuration)

Sink Details

Sink: RUN
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/Dockerfile:62
Taint Flags:

```
59 PORT=8080 \  
60 BACKEND_UPSTREAM=http://midas-api-backend-svc.midas-apps.svc.cluster.local:8000  
61  
62 RUN apk add --no-cache curl  
63  
64 COPY prod-runtime-package.json ./package.json  
65 RUN npm install --omit=dev && rm -f package.json
```



Dynamic Code Evaluation: Unsafe Pickle Deserialization (2 issues)

Abstract

Deserializing user-controlled data at run-time can allow attackers to execute arbitrary code.

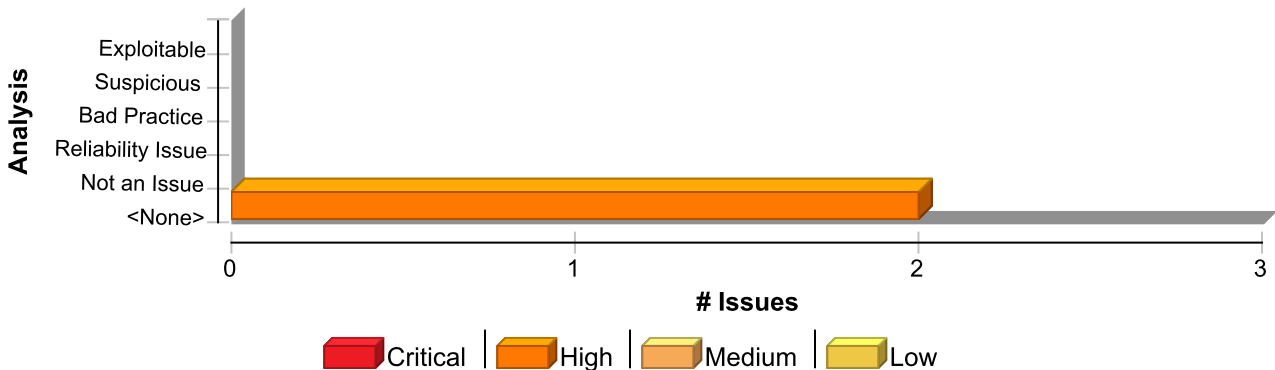
Explanation

Python Official documentation states that: The pickle module is not intended to be secure against erroneous or maliciously constructed data. Never unpickle data received from an untrusted or unauthenticated source. Pickle is a powerful serializing library that provides developers with an easy way to transmit objects, serializing them to a custom Pickle representation. Pickle allows arbitrary objects to declare how they should be deserialized by defining a `__reduce__` method. This method should return a callable and the arguments for it. Pickle will call the callable with the provided arguments to construct the new object allowing the attacker to execute arbitrary commands.

Recommendation

The best way to prevent arbitrary object deserialization is to avoid unpickling user-controlled data. If user-controlled data needs to be deserialized, a custom Pickle subclass should be used to control exactly what gets unpickled and what gets called. Please refer to the Python Library Reference for details.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Dynamic Code Evaluation: Unsafe Pickle Deserialization	2	0	0	2
Total	2	0	0	2

Dynamic Code Evaluation: Unsafe Pickle DeserializationHigh

Package: backend.app.services.user_knowledge_service

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/user_knowledge_service.py, line 273 (Dynamic Code Evaluation: Unsafe Pickle Deserialization)

Issue Details

Kingdom: Input Validation and Representation



Dynamic Code Evaluation: Unsafe Pickle Deserialization**High****Package:** backend.app.services.user_knowledge_service**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/user_knowledge_service.py, line 273 (Dynamic Code Evaluation: Unsafe Pickle Deserialization)****Scan Engine:** SCA (Data Flow)**Source Details****Source:** open()**From:** backend.app.services.user_knowledge_service.UserKnowledgeService._load_store**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/user_knowledge_service.py:272

```
269 if index_path.exists() and docs_path.exists():
270     try:
271         store.index = faiss.read_index(str(index_path))
272         with open(docs_path, "rb") as f:
273             store.documents = pickle.load(f)
274         except Exception as exc:
275             logger.warning(f"Failed to load user knowledge index: {exc}")
```

Sink Details**Sink:** pickle.load()**Enclosing Method:** _load_store()**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/user_knowledge_service.py:273**Taint Flags:** FILE_SYSTEM

```
270     try:
271         store.index = faiss.read_index(str(index_path))
272         with open(docs_path, "rb") as f:
273             store.documents = pickle.load(f)
274         except Exception as exc:
275             logger.warning(f"Failed to load user knowledge index: {exc}")
276
```

Package: backend.app.services.vector_store**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/vector_store.py, line 313 (Dynamic Code Evaluation: Unsafe Pickle Deserialization)****Issue Details****Kingdom:** Input Validation and Representation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** open()**From:** backend.app.services.vector_store.VectorStore.load_index

Dynamic Code Evaluation: Unsafe Pickle Deserialization**High****Package:** backend.app.services.vector_store**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/vector_store.py, line 313 (Dynamic Code Evaluation: Unsafe Pickle Deserialization)****File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/vector_store.py:312

```
309 if self.index_path.exists() and self.documents_path.exists():
310     self.logger.debug("Loading existing vector store...")
311     self.index = faiss.read_index(str(self.index_path))
312     with open(self.documents_path, 'rb') as f:
313         self.documents = pickle.load(f)
314     self.logger.info(f"Vector store loaded successfully with {len(self.documents)} documents")
315 else:
```

Sink Details**Sink:** pickle.load()**Enclosing Method:** load_index()**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/vector_store.py:313**Taint Flags:** FILE_SYSTEM

```
310 self.logger.debug("Loading existing vector store...")
311 self.index = faiss.read_index(str(self.index_path))
312 with open(self.documents_path, 'rb') as f:
313     self.documents = pickle.load(f)
314 self.logger.info(f"Vector store loaded successfully with {len(self.documents)} documents")
315 else:
316 self.logger.warning("Vector store files not found")
```

Insecure Transport (1 issue)

Abstract

The call uses an insecure protocol instead of a secure protocol to communicate with the server.

Explanation

All communication over HTTP, FTP, or gopher is unauthenticated and unencrypted. It is therefore subject to compromise, especially in the mobile environment where devices frequently connect to unsecured, public, wireless networks using WiFi connections. **Example 1:** The following example reads data using the HTTP protocol (instead of using HTTPS).

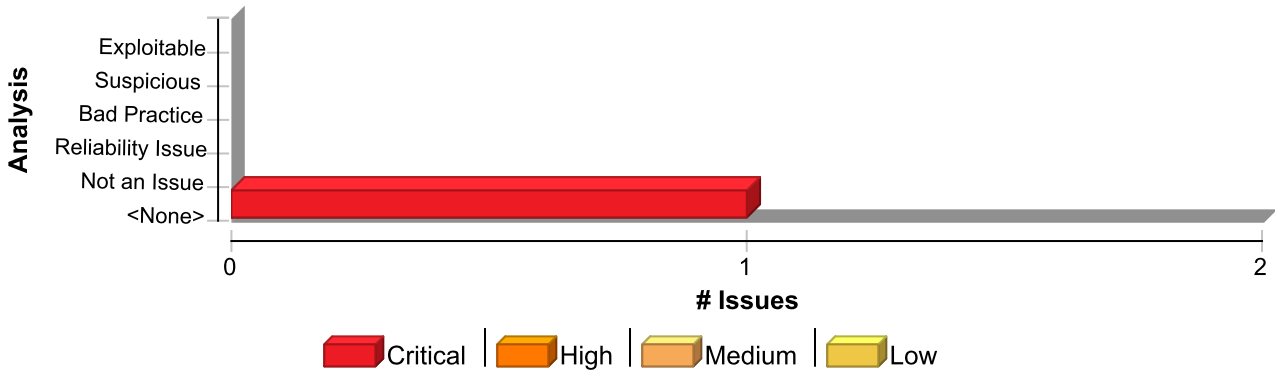
```
var http = require('http');  
  
...  
http.request(options, function(res){  
  ...  
});  
...
```

The incoming http.IncomingMessage object, res, may have been compromised as it is delivered over an unencrypted and unauthenticated channel.

Recommendation

Use secure protocols such as HTTPS to exchange data with the server whenever possible.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Insecure Transport	1	0	0	1
Total	1	0	0	1

Insecure Transport

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
production-server.cjs, line 98 (Insecure Transport)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)



Insecure Transport

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
production-server.cjs, line 98 (Insecure Transport)

Sink Details

Sink: FunctionPointerCall: createServer

Enclosing Method: ~file_function()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/production-server.cjs:98

Taint Flags:

```
95  }  
96  });  
97  
98  const server = http.createServer((req, res) => {  
99    const u = req.url || "/";  
100    if (u === "/kube-health" || u.startsWith("/kube-health?")) {  
101      res.writeHead(200, { "Content-Type": "text/plain; charset=utf-8" });
```

Key Management: Empty Encryption Key (2 issues)

Abstract

Empty encryption keys can compromise security in a way that is not easy to remedy.

Explanation

It is never a good idea to use an empty encryption key because it significantly reduces the protection afforded by a good encryption algorithm, and it also makes fixing the problem extremely difficult. After the offending code is in production, the empty encryption key cannot be changed without patching the software. If an account that is protected by the empty encryption key is compromised, the owners of the system must choose between security and availability. **Example 1:** The following code performs AES encryption using an empty encryption key:

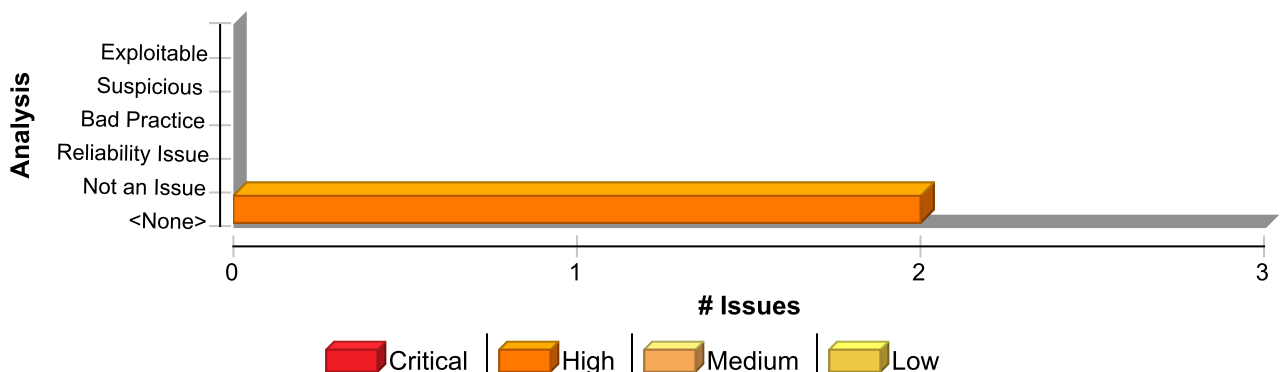
```
...  
var crypto = require('crypto');  
var encryptionKey = "";  
var algorithm = 'aes-256-ctr';  
var cipher = crypto.createCipher(algorithm, encryptionKey);  
...
```

Not only will anyone who has access to the code be able to determine that it uses an empty encryption key, but anyone with even basic cracking techniques is much more likely to successfully decrypt any encrypted data. After the application has shipped, a software patch is required to change the empty encryption key. An employee with access to this information can use it to break into the system. Even if attackers only had access to the application's executable, they could extract evidence of the use of an empty encryption key.

Recommendation

Encryption keys should never be empty and should be obfuscated and managed in an external source. Storing encryption keys in plain text, empty or otherwise, anywhere on the system allows anyone with sufficient permissions to read and potentially misuse the encryption key.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Key Management: Empty Encryption Key	2	0	0	2
Total	2	0	0	2



Key Management: Empty Encryption Key

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 130 (Key Management: Empty Encryption Key)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: secretKey
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:130
Taint Flags:

```
127 };  
128  
129 const athenaStrategy: ConnectionStrategy = {  
130   getInitialConfig: () => ({ region: '', database: '', s3OutputLocation: '', accessKey: '',  
    secretKey: '' }),  
131   getRequiredFields: () => ['region', 'database'],  
132   validate: (config) => {  
133     const errors: string[] = [];
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceModal.tsx, line 53 (Key Management: Empty Encryption Key)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: secretKey
Enclosing Method: DataSourceModal()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceModal.tsx:53
Taint Flags:

```
50   account: '',  
51   region: '',  
52   accessKey: '',  
53   secretKey: '',  
54   spreadsheetId: '',  
55   sheetName: '',  
56   baseId: '',
```



Key Management: Hardcoded Encryption Key (1 issue)

Abstract

Hardcoded encryption keys could compromise system security in a way that is not easy to remedy.

Explanation

It is never a good idea to hardcode an encryption key. Not only does hardcoding an encryption key allow all of the project's developers to view the encryption key, it also makes fixing the problem extremely difficult. After the code is in production, a software patch is required to change the encryption key. If the account protected by the encryption key is compromised, the owners of the system must choose between security and availability. **Example 1:** The following code uses a hardcoded encryption key to encrypt information:

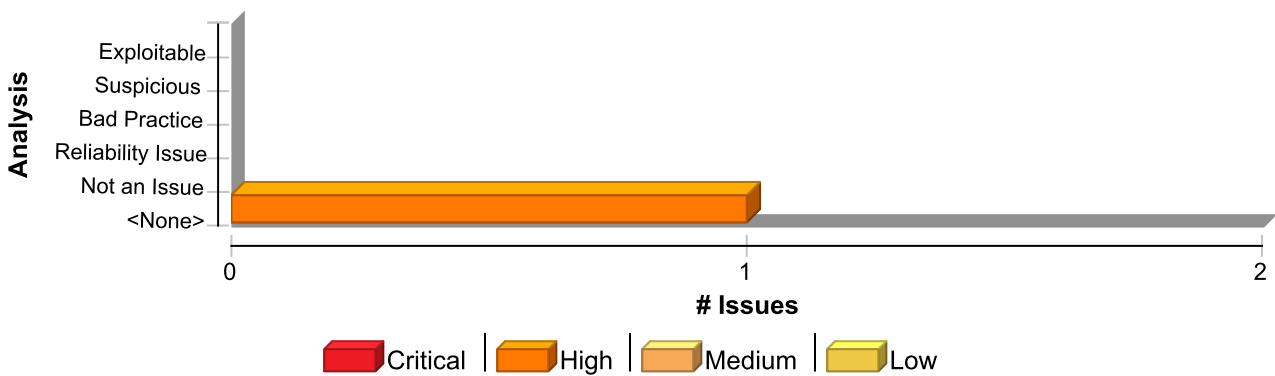
```
...
from Crypto.Ciphers import AES
encryption_key = b'_hardcoded__key_'
cipher = AES.new(encryption_key, AES.MODE_CFB, iv)
msg = iv + cipher.encrypt(b'Attack at dawn')
...
```

This code will run successfully, but anyone who has access to it will have access to the encryption key. After the program ships, there is likely no way to change the hardcoded encryption key `_hardcoded__key_` unless the program is patched. A devious employee with access to this information can use it to compromise data encrypted by the system.

Recommendation

Encryption keys should never be hardcoded and should generally be obfuscated and managed in an external source. Storing encryption keys in plain text anywhere on the system allows anyone with sufficient permissions to read and potentially misuse the encryption key.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Key Management: Hardcoded Encryption Key	1	0	0	1
Total	1	0	0	1



Key Management: Hardcoded Encryption Key

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend.app.services

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/auth_service.py, line 20 (Key Management: Hardcoded Encryption Key)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: VariableAccess: SECRET_KEY
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/auth_service.py:20
Taint Flags:

```
17 pwd_context = CryptContext(schemes=["bcrypt"], deprecated="auto")
18
19 # JWT settings
20 SECRET_KEY = "your-secret-key-here-change-in-production" # In production, use environment variable
21 ALGORITHM = "HS256"
22 ACCESS_TOKEN_EXPIRE_MINUTES = 45
23 REFRESH_TOKEN_EXPIRE_DAYS = 3
```



Kubernetes Misconfiguration: Improper Deployment Access Control (3 issues)

Abstract

A configuration does not apply proper access controls.

Explanation

Uncontrolled access to critical or sensitive resources can significantly impact an organization in various ways, including disclosure of or tampering with critical data. By default, the `type` property is set to "Unconfined" for Deployment resources. **Example 1:** The following example shows a configuration that defines a Deployment resource with `type` not set to the secure value "RuntimeDefault".

```
kind: Deployment
spec:
  template:
    spec:
      containers:
      - name: example
        securityContext:
          seccompProfile:
            type: "Unconfined"
...

```

Recommendation

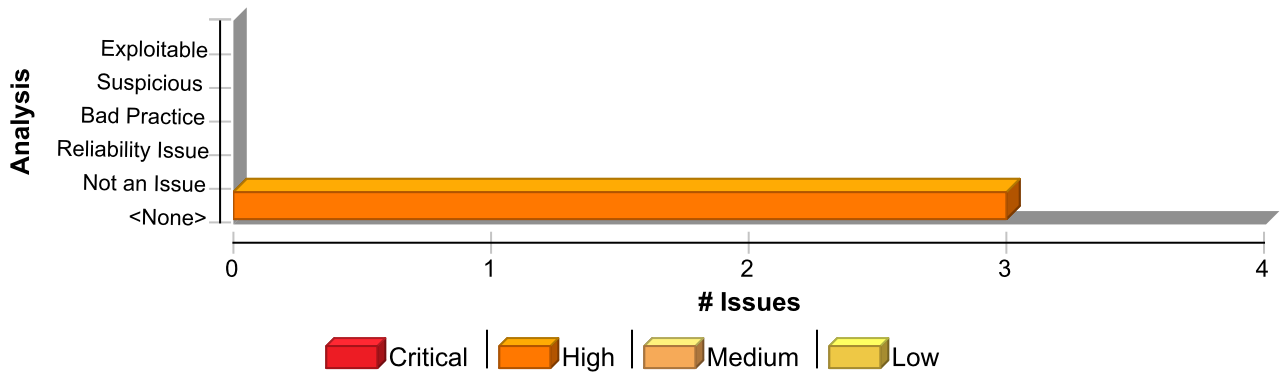
Enforce access controls to protect critical data and prevent unauthorized actions. Review your organization's data handling policies when creating resources that are readable by anonymous users. When changing access controls, identify all dependent systems to limit potential disruptions. **Example 2:** The following improves the configuration in Example 1. It specifies a Deployment resource with `type` set to the secure value "RuntimeDefault".

```
kind: Deployment
spec:
  template:
    spec:
      containers:
      - name: example
        securityContext:
          seccompProfile:
            type: "RuntimeDefault"
...

```

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Kubernetes Misconfiguration: Improper Deployment Access Control	3	0	0	3
Total	3	0	0	3

Kubernetes Misconfiguration: Improper Deployment Access Control

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.k8s

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/k8s/frontend-deployment.yaml, line 1 (Kubernetes Misconfiguration: Improper Deployment Access Control)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Configuration
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/k8s/frontend-deployment.yaml:1
Taint Flags:
No snippet available

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/k8s/backend-deployment.yaml, line 1 (Kubernetes Misconfiguration: Improper Deployment Access Control)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Configuration
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/k8s/backend-deployment.yaml:1
Taint Flags:
No snippet available



Kubernetes Misconfiguration: Improper Deployment Access Control	High
---	------

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.k8s
Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/k8s/rfe-worker-deployment.yaml, line 12 (Kubernetes Misconfiguration: Improper Deployment Access Control)

Issue Details

Kingdom: Environment
Scan Engine: SCA (Structural)

Sink Details

Sink: Configuration
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/k8s/rfe-worker-deployment.yaml:12
Taint Flags:

No snippet available



Password Management: Empty Password (11 issues)

Abstract

Empty passwords may compromise system security in a way that is not easy to remedy.

Explanation

It is never a good idea to have an empty password. It also makes fixing the problem extremely difficult once the code is in production. The password cannot be changed without patching the software. If the account protected by the empty password is compromised, the owners of the system must choose between security and availability. **Example 1:** The following code has an empty password to connect to an application and retrieve address book entries:

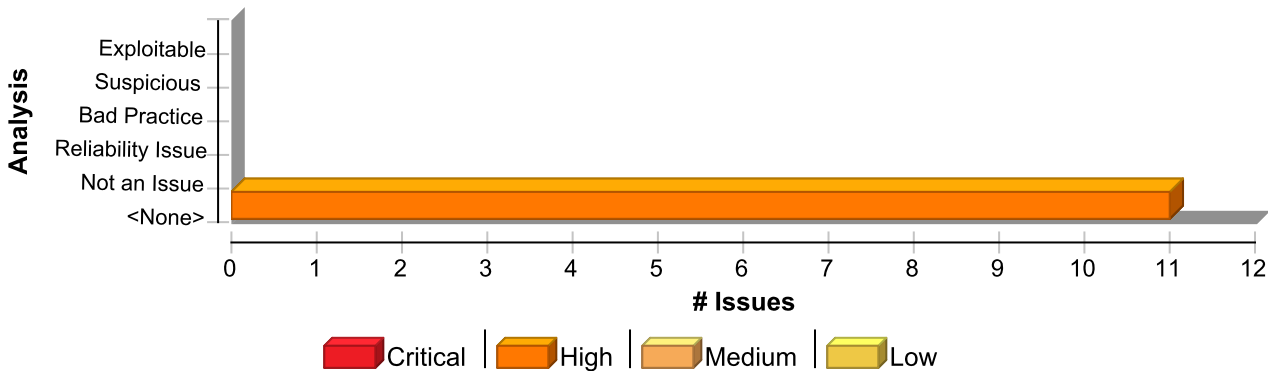
```
...  
obj = new XMLHttpRequest();  
obj.open('GET', '/fetchusers.jsp?id='+form.id.value,'true','scott','');  
...
```

This code will run successfully, but anyone can access when they know the username.

Recommendation

Passwords should never be empty and should generally be obfuscated and managed in an external source. Storing passwords in plain text anywhere on the web site allows anyone with sufficient permissions to read and potentially misuse the password. For JavaScript calls that require passwords, it is better to prompt the user for the password at connection time.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Password Management: Empty Password	11	0	0	11
Total	11	0	0	11

Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceModal.tsx, line 42 (Password Management: Empty Password)

Issue Details



Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceModal.tsx, line 42 (Password Management: Empty Password)

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password

Enclosing Method: DataSourceModal()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceModal.tsx:42

Taint Flags:

```
39 port: '',  
40 database: '',  
41 username: '',  
42 password: '',  
43 connectionString: '',  
44 apiKey: '',  
45 projectId: '',
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx, line 153 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password

Enclosing Method: handleSaveConnection()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx:153

Taint Flags:

```
150 port: '',  
151 database: '',  
152 username: '',  
153 password: '',  
154 ssl: false,  
155 account: '',  
156 warehouse: '',
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/APIConnectionModal.tsx, line 206 (Password Management: Empty Password)

Issue Details



Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/APIConnectionModal.tsx, line 206 (Password Management: Empty Password)

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: clientSecret

Enclosing Method: handleSaveConnection()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/APIConnectionModal.tsx:206

Taint Flags:

```
203 apiKey: '',  
204 apiSecret: '',  
205 clientId: '',  
206 clientSecret: '',  
207 environment: 'sandbox',  
208 baseUrl: ''  
209 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/APIConnectionModal.tsx, line 29 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: clientSecret

Enclosing Method: APIConnectionModal()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/APIConnectionModal.tsx:29

Taint Flags:

```
26 apiKey: '',  
27 apiSecret: '',  
28 clientId: '',  
29 clientSecret: '',  
30 environment: 'sandbox' as 'sandbox' | 'production',  
31 baseUrl: ''  
32 });
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx, line 30 (Password Management: Empty Password)

Issue Details



Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx, line 30 (Password Management: Empty Password)

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: DatabaseConnectionModal()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DatabaseConnectionModal.tsx:30
Taint Flags:

```
27 port: '',  
28 database: '',  
29 username: '',  
30 password: '',  
31 ssl: false,  
32 // Snowflake specific  
33 account: '',
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 55 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:55
Taint Flags:

```
52  
53 const databaseStrategy: ConnectionStrategy = {  
54   getInitialConfig: () => ({  
55     host: '', port: '5432', database: '', username: '', password: '', connectionString: '',  
56   } ),  
57   getRequiredFields: () => ['host', 'database', 'username', 'password'],  
58   validate: (config) => {
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 70 (Password Management: Empty Password)

Issue Details



Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 70 (Password Management: Empty Password)

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:70
Taint Flags:

```
67
68 const mysqlStrategy: ConnectionStrategy = {
69   ...databaseStrategy,
70   getInitialConfig: () => ({ host: '', port: '3306', database: '', username: '', password:
'' })),
71 };
72
73 const sqlServerStrategy: ConnectionStrategy = {
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 75 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:75
Taint Flags:

```
72
73 const sqlServerStrategy: ConnectionStrategy = {
74   ...databaseStrategy,
75   getInitialConfig: () => ({ host: '', port: '1433', database: '', username: '', password:
'', schema: 'dbo' })),
76 };
77
78 const redshiftStrategy: ConnectionStrategy = {
```



Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 80 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:80
Taint Flags:

```
77
78 const redshiftStrategy: ConnectionStrategy = {
79   ...databaseStrategy,
80   getInitialConfig: () => ({ host: '', port: '5439', database: '', username: '', password:
'', schema: 'public' }),
81 };
82
83 const mongodbStrategy: ConnectionStrategy = {
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 116 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:116
Taint Flags:

```
113 };
114
115 const snowflakeStrategy: ConnectionStrategy = {
116   getInitialConfig: () => ({ account: '', warehouse: '', database: '', schema: 'PUBLIC',
username: '', password: '' }),
117   getRequiredFields: () => ['account', 'warehouse', 'database', 'username', 'password'],
118   validate: (config) => {
119     const errors: string[] = [];
```



Password Management: Empty Password

High

Package: .src.components

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx, line 165 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FieldAccess: password
Enclosing Method: getInitialConfig()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/components/DataSourceSelection.tsx:165
Taint Flags:

```
162 };  
163  
164 const defaultStrategy: ConnectionStrategy = {  
165   getInitialConfig: () => ({ host: '', port: '', database: '', username: '', password: '',  
    connectionString: '', apiKey: '' })),  
166   getRequiredFields: () => [],  
167   validate: () => ({ valid: true, errors: [] })),  
168 };
```



Password Management: Hardcoded Password (17 issues)

Abstract

Hardcoded passwords can compromise system security in a way that is difficult to remedy.

Explanation

Never hardcode passwords. Not only does it expose the password to all of the project's developers, it also makes fixing the problem extremely difficult. After the code is in production, a program patch is probably the only way to change the password. If the account protected by the password is compromised, the organization must choose between security and system availability. **Example 1:** The following URL uses a hardcoded password:

```
...
https://user:secretpassword@example.com
...
```

Example 2: The following ODBC connection string uses a hardcoded password:

```
...
server=Server;database=Database;UID=UserName;PWD=Password;Encrypt=yes;
...
```

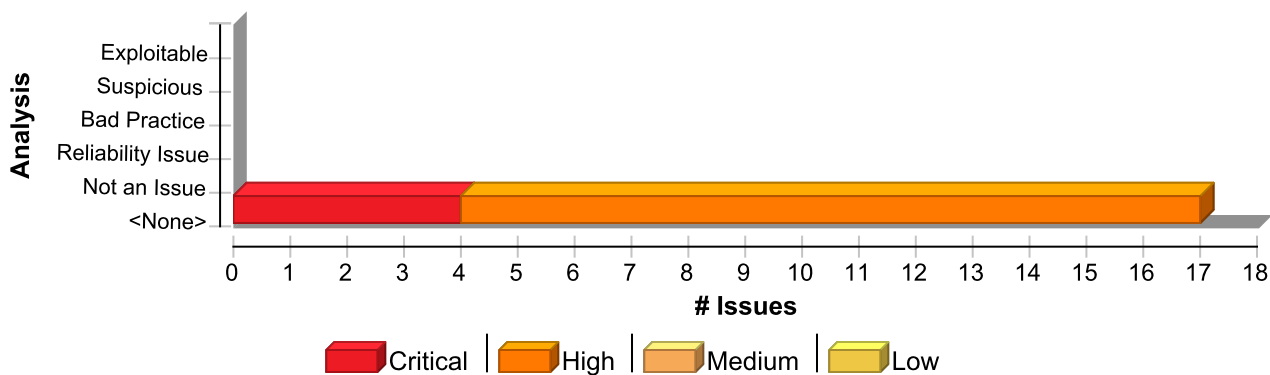
Recommendation

Example 3: The following ODBC connection string addresses the hardcoded password issue in Example 2 by implementing Integrated Windows Authentication:

```
...
server=Server;database=Database;Trusted_Connection=yes;Encrypt=yes;
...
```

Never use hardcoded passwords. Always obfuscate and manage passwords in an external source. Storing passwords in plain text anywhere on the system enables anyone with sufficient permissions to read and potentially misuse the password.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Password Management: Hardcoded Password	17	0	0	17
Total	17	0	0	17



Password Management: Hardcoded Password

Critical

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/
JENKINS_DEPLOYMENT_10April.md, line 101 (Password Management:
Hardcoded Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/JENKINS_DEPLOYMENT_10April.md:101
Taint Flags:

```
98
99 The `backend` service was updated to `depends_on` all three and gets these injected at
runtime:
100 ```
101 DATABASE_URL=postgresql://midas_pg:midas_local@postgres:5432/midas_dev
102 REDIS_URL=redis://redis:6379/0
103 SESSION_REDIS_URL=redis://redis:6379/0
104 GRAPHRAG_SERVICE_URL=http://graphrag:8001
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-
compose.yml, line 100 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-compose.yml:100
Taint Flags:

```
97 # — DB (local Docker by default; override in .env for AWS) —————
98 # Local: postgres:5432 / redis:6379 (containers in this compose file)
99 # AWS: uncomment RDS/ElastiCache lines in backend/.env
100 - DATABASE_URL=${DATABASE_URL:-postgresql://midas_pg:midas_local@postgres:5432/midas_dev}
101 - REDIS_URL=${REDIS_URL:-redis://redis:6379/0}
102 - SESSION_REDIS_URL=${SESSION_REDIS_URL:-redis://redis:6379/0}
103 # — S3 (always AWS) —————
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-
compose.aws.yml, line 40 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Configuration)



Password Management: Hardcoded Password**Critical****Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins****Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-compose.aws.yml, line 40 (Password Management: Hardcoded Password)****Sink Details****Sink:****File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-compose.aws.yml:40**Taint Flags:**

```
37 condition: service_healthy
38 environment:
39 - GRAPHRAG_SERVICE_URL=http://graphrag:8001
40 - DATABASE_URL=postgresql://midas_pg:F%3A%2A%21M5MaCfkgTdfT%3AwlgsSh%28_c6k@midas-dev-us-east-1-pg-20260406163456132500000004.cuzwqoeau6l8.us-east-1.rds.amazonaws.com:5432/midas_dev
41 - REDIS_URL=rediss://:wI7VtHBtbQxu5WEXihJbBtElP8oVBXg5@master.midas-dev-redis.ez4lfs.usel.cache.amazonaws.com:6379/0
42 - SESSION_REDIS_URL=rediss://:wI7VtHBtbQxu5WEXihJbBtElP8oVBXg5@master.midas-dev-redis.ez4lfs.usel.cache.amazonaws.com:6379/0
43 - SESSION_ELASTICACHE_SECRET_ARN=arn:aws:secretsmanager:us-east-1:811391286931:secret:midas-dev-us-east-1-redis-auth-20260407123244934300000001-BThXC9
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ecs-app**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/variables.tf, line 311 (Password Management: Hardcoded Password)****Issue Details****Kingdom:** Security Features**Scan Engine:** SCA (Configuration)**Sink Details****Sink:****File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ecs-app/variables.tf:311**Taint Flags:**

```
308 # sqs_queue_name = "bticore-9f369070-standard-queue"
309 # sqs_account_id = "639209084608"
310 # sqs_region = "us-east-1"
311 # backend_url = "postgresql://mlprduser:8rt11.ebXrn_WPibullnE3pDoqbo@sb-mlprd-tenant-9f369070-health.cluster-c7nvtntvktlds.us-east-1.rds.amazonaws.com:5432/mlprduser"
312 # }
313 # }
314
```

Password Management: Hardcoded Password**High****Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins****Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-compose.yml, line 10 (Password Management: Hardcoded Password)****Issue Details****Kingdom:** Security Features

Password Management: Hardcoded Password**High****Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins****Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-compose.yml, line 10 (Password Management: Hardcoded Password)****Scan Engine:** SCA (Structural)**Sink Details****Sink:** ConfigPair**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/docker-compose.yml:10**Taint Flags:**

```
7 container_name: midas-postgres
8 environment:
9 POSTGRES_USER: midas_pg
10 POSTGRES_PASSWORD: midas_local
11 POSTGRES_DB: midas_dev
12 ports:
13 - "5433:5432"
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend.scripts**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py, line 45 (Password Management: Hardcoded Password)****Issue Details****Kingdom:** Security Features**Scan Engine:** SCA (Structural)**Sink Details****Sink:** FunctionCall: __setitem__**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py:45**Taint Flags:**

```
42 "username": "Saiyam Arora",
43 "full_name": "Saiyam Arora",
44 "email": "saiyam.arora@example.com",
45 "password": "SaiyamEXL@2026",
46 },
47 {
48 "username": "MIDAS_Test01",
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py, line 39 (Password Management: Hardcoded Password)**Issue Details****Kingdom:** Security Features**Scan Engine:** SCA (Structural)**Sink Details****Sink:** FunctionCall: __setitem__

Password Management: Hardcoded Password

High

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend.scripts

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/
seed_users.py, line 39 (Password Management: Hardcoded Password)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py:39

Taint Flags:

```
36 "username": "MIDAS_internal",
37 "full_name": "MIDAS Internal",
38 "email": "MIDAS_internal@example.com",
39 "password": "EXL@123456",
40 },
41 {
42 "username": "Saiyam Arora",
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/
seed_users.py, line 51 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionCall: __setitem__

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py:51

Taint Flags:

```
48 "username": "MIDAS_Test01",
49 "full_name": "MIDAS Test 01",
50 "email": "MIDAS_Test01@example.com",
51 "password": "Midas@123456",
52 },
53 {
54 "username": "RPM_user01",
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/
seed_users.py, line 57 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionCall: __setitem__

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py:57

Taint Flags:

```
54 "username": "RPM_user01",
55 "full_name": "RPM User 01",
56 "email": "RPM_user01@example.com",
57 "password": "Midas@123456",
```



Password Management: Hardcoded Password**High****Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.backend.scripts****Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/scripts/seed_users.py, line 57 (Password Management: Hardcoded Password)**

```
58  },  
59  ]  
60
```

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ai_gateway.helm.clickhouse**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ai_gateway/helm/clickhouse/values-midas-dev.yaml, line 50 (Password Management: Hardcoded Password)****Issue Details**

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: ConfigPair
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ai_gateway/helm/clickhouse/values-midas-dev.yaml:50
Taint Flags:

No snippet available

Package: Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.deploy.ai_gateway.helm.langfuse**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ai_gateway/helm/langfuse/values-midas-dev.yaml, line 20 (Password Management: Hardcoded Password)****Issue Details**

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: ConfigPair
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/deploy/ai_gateway/helm/langfuse/values-midas-dev.yaml:20
Taint Flags:

No snippet available

Package: backend.tests.test_rds_secret_merge**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py, line 19 (Password Management: Hardcoded Password)****Issue Details**

Kingdom: Security Features



Password Management: Hardcoded Password

High

Package: backend.tests.test_rds_secret_merge

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py, line 19 (Password Management: Hardcoded Password)

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionCall: __setitem__

Enclosing Method: test_merge_adds_dbname_for_rds_slot()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py:19

Taint Flags:

```
16 self.assertFalse(rds_database_field_absent(d))
17
18 def test_merge_adds_dbname_for_rds_slot(self) -> None:
19     payload = {"username": "u", "password": "p", "host": "h", "port": 5432}
20     merged = _merge_into_sm_payload("rds_postgres", payload, {"dbname": "midas_dev"})
21     r = RDSPostgresSecrets.from_mapping(merged)
22     self.assertEqual(r.database, "midas_dev")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py, line 15 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionCall: __setitem__

Enclosing Method: test_rds_database_field_absent_false_when_dbname_present()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py:15

Taint Flags:

```
12 self.assertTrue(rds_database_field_absent(d))
13
14 def test_rds_database_field_absent_false_when_dbname_present(self) -> None:
15     d = {"username": "u", "password": "p", "host": "h", "dbname": "x"}
16     self.assertFalse(rds_database_field_absent(d))
17
18 def test_merge_adds_dbname_for_rds_slot(self) -> None:
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py, line 11 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)



Password Management: Hardcoded Password

High

Package: backend.tests.test_rds_secret_merge

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py, line 11 (Password Management: Hardcoded Password)

Sink Details

Sink: FunctionCall: __setitem__

Enclosing Method: test_rds_database_field_absent_when_no_db_keys()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py:11

Taint Flags:

```
8
9 class TestRdsSecretMerge(unittest.TestCase):
10 def test_rds_database_field_absent_when_no_db_keys(self) -> None:
11 d = {"username": "u", "password": "p", "host": "h"}
12 self.assertTrue(rds_database_field_absent(d))
13
14 def test_rds_database_field_absent_false_when_dbname_present(self) -> None:
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py, line 25 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionCall: __setitem__

Enclosing Method: test_merge_does_not_overwrite_existing_dbname()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/tests/test_rds_secret_merge.py:25

Taint Flags:

```
22 self.assertEqual(r.database, "midas_dev")
23
24 def test_merge_does_not_overwrite_existing_dbname(self) -> None:
25 payload = {"username": "u", "password": "p", "host": "h", "dbname": "keep_me"}
26 merged = _merge_into_sm_payload("rds_postgres", payload, {"dbname": "other"})
27 r = RDSPostgresSecrets.from_mapping(merged)
28 self.assertEqual(r.database, "keep_me")
```

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 45 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details



Password Management: Hardcoded Password

High

Package: local

deploy/ai_gateway/terraform/modules-midas/secrets.tf, line 45 (Password Management: Hardcoded Password)

Sink: Constant String

Enclosing Method: jfrog_regcred()

File: deploy/ai_gateway/terraform/modules-midas/secrets.tf:45

Taint Flags:

Package: testing.midas_test_suite

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/testing/midas_test_suite.py, line 54 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionCall: __setitem__

Enclosing Method: __init__()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/testing/midas_test_suite.py:54

Taint Flags:

```
51 self.refresh_token = None
52 self.test_user = {
53     "username": "testuser",
54     "password": "test@123",
55     "full_name": "Test User",
56     "email": "test@example.com"
57 }
```



System Information Leak: External (2 issues)

Abstract

Revealing system data or debugging information could enable an adversary to use system information to plan an attack.

Explanation

An external information leak occurs when system data or debug information leaves the program to a remote machine via a socket or network connection. External leaks can help an attacker by revealing specific data about operating systems, full pathnames, the existence of usernames, or locations of configuration files, and are more serious than internal information leaks, which are more difficult for an attacker to access. **Example 1:** The following code leaks Exception information into a text area within a web page:

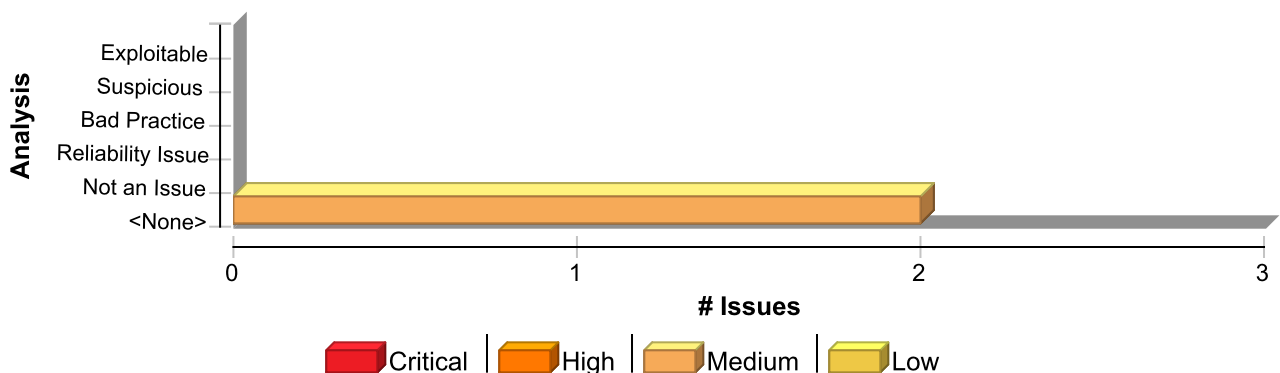
```
...
dirReader.readEntries(function(results){
...
}, function(error){
$("#myTextArea").val('There was a problem: ' + error);
});
...
```

This information can be exposed to a remote user. In some cases, the error message provides the attacker with the precise type of attack to which the system is vulnerable. For example, a database error message can reveal that the application is vulnerable to a SQL injection attack. Other error messages can reveal more oblique clues about the system. In Example 1, the leaked information could imply information about the type of operating system, the applications installed on the system, and the amount of care that the administrators have put into configuring the program.

Recommendation

Write error messages with security in mind. In production environments, turn off detailed error information in favor of brief messages. Restrict the generation and storage of detailed output that can help administrators and programmers diagnose problems. Debug traces can sometimes appear in non-obvious places (embedded in comments in the HTML for an error page, for example). Even brief error messages that do not reveal stack traces or database dumps can potentially aid an attacker. For example, an "Access Denied" message can reveal that a file or user exists on the system. Because of this, never send information to a resource directly outside the program.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
System Information Leak: External	2	0	0	2
Total	2	0	0	2

System Information Leak: External

Medium

Package: .src.pages

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/pages/ModelBuilder.tsx, line 2203 (System Information Leak: External)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: lambda(0)
From: lambda
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/pages/ModelBuilder.tsx:2198

```
2195 timestamp: new Date().toISOString()  
2196 }));  
2197 }  
2198 }).catch((classificationError) => {  
2199 console.error(' Dataset classification error:', classificationError);  
2200 const errMsg = classificationError instanceof Error ?  
classificationError.message : 'Unknown error';  
2201 setMlClassificationError(`AI classification encountered an error. Using  
default "Others" type.`);
```

Sink Details

Sink: setItem()
Enclosing Method: lambda()
File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/src/pages/ModelBuilder.tsx:2203
Taint Flags: SYSTEMINFO

```
2200 const errMsg = classificationError instanceof Error ? classificationError.message :  
'Unknown error';  
2201 setMlClassificationError(`AI classification encountered an error. Using default "Others"  
type.`);  
2202 setChatInputs(prev => ({ ...prev, ['dataset_structure_type' as unknown as number]:  
'others' }));  
2203 sessionStorage.setItem('dataset_classification_error', JSON.stringify({  
2204 error: true,  
2205 message: 'AI classification encountered an error. Using default "Others" type.',  
2206 timestamp: new Date().toISOString(),
```



System Information Leak: External**Medium****Package:** Downloads.bu-analytics-gen-ai-midas-deployment-dev-jenkins.frontend**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/
production-server.cjs, line 94 (System Information Leak: External)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** lambda(0)**From:** lambda**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/productio
n-server.cjs:91

```
88  timeout: 600000,  
89  });  
90  
91  proxy.on("error", (err, req, res) => {  
92    if (res && !res.headersSent && typeof res.writeHead === "function") {  
93      res.writeHead(502, { "Content-Type": "text/plain; charset=utf-8" });  
94      res.end(`Bad gateway: ${err && err.message ? err.message : String(err)}`);
```

Sink Details**Sink:** ~JS_Generic.end()**Enclosing Method:** lambda()**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/frontend/production-server.cjs:94**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
91  proxy.on("error", (err, req, res) => {  
92    if (res && !res.headersSent && typeof res.writeHead === "function") {  
93      res.writeHead(502, { "Content-Type": "text/plain; charset=utf-8" });  
94      res.end(`Bad gateway: ${err && err.message ? err.message : String(err)}`);  
95    }  
96  });  
97
```



Weak Cryptographic Hash (7 issues)

Abstract

Weak cryptographic hashes cannot guarantee data integrity and should not be used in security-critical contexts.

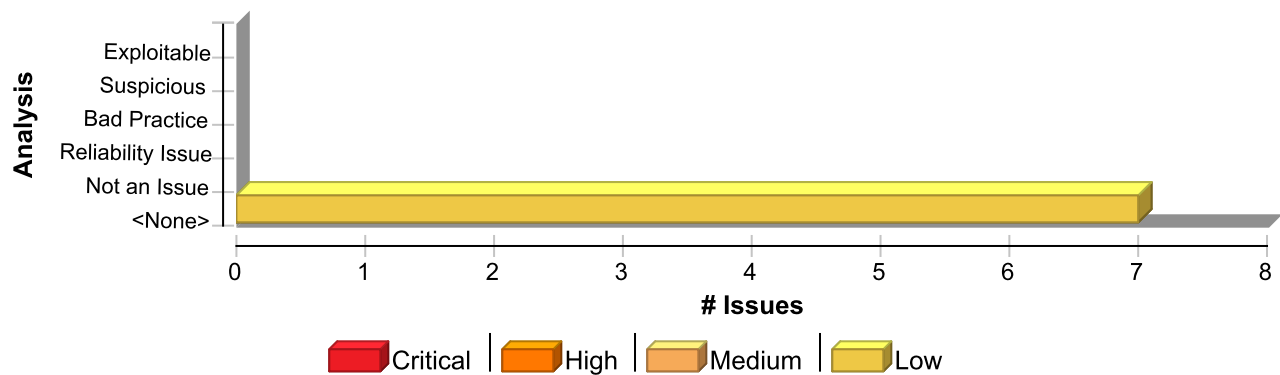
Explanation

MD2, MD4, MD5, RIPEMD-160, SHA-1 and Keccak are popular cryptographic hash algorithms often used to verify the integrity of messages and other data. However, as recent cryptanalysis research has revealed fundamental weaknesses in these algorithms, they should no longer be used within security-critical contexts. Effective techniques for breaking MD and RIPEMD hashes are widely available, so those algorithms should not be relied upon for security. In the case of SHA-1, current techniques still require a significant amount of computational power and are more difficult to implement. However, attackers have found the Achilles' heel for the algorithm, and techniques for breaking it will likely lead to the discovery of even faster attacks.

Recommendation

Discontinue the use of MD2, MD4, MD5, RIPEMD-160, SHA-1 and Keccak for data-verification in security-critical contexts. Currently, SHA-224, SHA-256, SHA-384, SHA-512, and SHA-3 are good alternatives. However, these variants of the Secure Hash Algorithm have not been scrutinized as closely as SHA-1, so be mindful of future research that might impact the security of these algorithms.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Weak Cryptographic Hash	7	0	0	7
Total	7	0	0	7

Weak Cryptographic Hash

Low

Package: backend.app.api.routes

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py, line 6623 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features



Weak Cryptographic Hash

Low

Package: backend.app.api.routes

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py, line 6623 (Weak Cryptographic Hash)

Scan Engine: SCA (Semantic)

Sink Details

Sink: md5()

Enclosing Method: download_processed_dataset()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py:6623

Taint Flags:

```
6620
6621 # Verify that this DataFrame will produce the same statistics as displayed
6622 import hashlib
6623 download_fingerprint = hashlib.md5(
6624     f"{processed_df.shape}_{list(processed_df.columns)}_{processed_df.index.tolist()
6625     [:10]}".encode()
6626 ).hexdigest()
6626 logger.info(f"^^? Download DataFrame fingerprint: {download_fingerprint}")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py, line 5401 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Semantic)

Sink Details

Sink: md5()

Enclosing Method: execute_python_code()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py:5401

Taint Flags:

```
5398
5399 # Create a data fingerprint for the displayed DataFrame
5400 import hashlib
5401 display_fingerprint = hashlib.md5(
5402     f"{df_to_preview.shape}_{list(df_to_preview.columns)}_{df_to_preview.index.tolist()
5403     [:10]}".encode()
5404 ).hexdigest()
5404 logger.info(f"^^? Display DataFrame fingerprint: {display_fingerprint}")
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py, line 5435 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Semantic)

Sink Details



Weak Cryptographic Hash

Low

Package: backend.app.api.routes

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py, line 5435 (Weak Cryptographic Hash)

Sink: md5()

Enclosing Method: execute_python_code()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/api/routes.py:5435

Taint Flags:

```
5432
5433 # Create a data fingerprint for the stored DataFrame
5434 import hashlib
5435 stored_fingerprint = hashlib.md5(
5436     f"{stored_df.shape}_{list(stored_df.columns)}_{stored_df.index.tolist()[ :10] }".encode()
5437 ).hexdigest()
5438 logger.info(f"^^?^^ Stored DataFrame fingerprint: {stored_fingerprint}")
```

Package: backend.app.services.graphrag_client

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_client.py, line 416 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Semantic)

Sink Details

Sink: md5()

Enclosing Method: _summary_signature()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_client.py:416

Taint Flags:

```
413 if not dataset_summary:
414     return ""
415 summary_norm = re.sub(r"\s+", " ", dataset_summary.strip().lower())
416 return hashlib.md5(summary_norm.encode()).hexdigest()
417
418 def _truncate_summary(self, dataset_summary: str, limit: int = 1200) -> str:
419     if not dataset_summary:
```

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_client.py, line 400 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Semantic)

Sink Details

Sink: md5()

Enclosing Method: _get_cache_key()



Weak Cryptographic Hash

Low

Package: backend.app.services.graphrag_client

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_client.py, line 400 (Weak Cryptographic Hash)

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_client.py:400

Taint Flags:

```
397 base = user_query
398 if dataset_summary:
399 base = f"{user_query}||summary:{self._summary_signature(dataset_summary)}"
400 return hashlib.md5(base.encode()).hexdigest()
401
402 def _normalize_query(self, query: str, dataset_summary: str = "") -> str:
403 normalized = (query or "").lower()
```

Package: backend.app.services.graphrag_service

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_service.py, line 130 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Semantic)

Sink Details

Sink: md5()

Enclosing Method: _get_cache_key()

File: Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/graphrag_service.py:130

Taint Flags:

```
127 def _get_cache_key(self, user_query: str, query_type: str) -> str:
128 """Generate consistent cache key"""
129 import hashlib
130 query_hash = hashlib.md5(f"{query_type}:{user_query}".encode()).hexdigest()
131 return query_hash
132
133 def get_cached_context(self, cache_key: str, context_type: str = "planning") -> Optional[str]:
```

Package: backend.app.services.segmentation_stability

Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/segmentation_stability.py, line 682 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Semantic)

Sink Details



Weak Cryptographic Hash**Low****Package:** backend.app.services.segmentation_stability**Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/segmentation_stability.py, line 682 (Weak Cryptographic Hash)****Sink:** md5()**Enclosing Method:** generate_cache_key()**File:** Downloads/bu-analytics-gen-ai-midas-deployment-dev-jenkins/backend/app/services/segmentation_stability.py:682**Taint Flags:**

```
679 "rules": sorted(segment_rules) if segment_rules else []
680 }
681 key_str = json.dumps(key_data, sort_keys=True)
682 return hashlib.md5(key_str.encode()).hexdigest()
683
684
685 def create_analyzer(
```

Description of Key Terminology

Likelihood and Impact

Likelihood

Likelihood is the probability that a vulnerability will be accurately identified and successfully exploited.

Impact

Impact is the potential damage an attacker could do to assets by successfully exploiting a vulnerability. This damage can be in the form of, but not limited to, financial loss, compliance violation, loss of brand reputation, and negative publicity.

Fortify Priority Order

Critical

Critical-priority issues have high impact and high likelihood. Critical-priority issues are easy to detect and exploit and result in large asset damage. These issues represent the highest security risk to the application. As such, they should be remediated immediately.

SQL Injection is an example of a critical issue.

High

High-priority issues have high impact and low likelihood. High-priority issues are often difficult to detect and exploit, but can result in large asset damage. These issues represent a high security risk to the application. High-priority issues should be remediated in the next scheduled patch release.

Password Management: Hardcoded Password is an example of a high issue.

Medium

Medium-priority issues have low impact and high likelihood. Medium-priority issues are easy to detect and exploit, but typically result in small asset damage. These issues represent a moderate security risk to the application. Medium-priority issues should be remediated in the next scheduled product update.

Path Manipulation is an example of a medium issue.

Low

Low-priority issues have low impact and low likelihood. Low-priority issues can be difficult to detect and exploit and typically result in small asset damage. These issues represent a minor security risk to the application. Low-priority issues should be remediated as time allows.

Dead Code is an example of a low issue.

About Fortify Solutions

Fortify is the leader in end-to-end application security solutions with the flexibility of testing on-premise and on-demand to cover the entire software development lifecycle. Learn more at www.microfocus.com/solutions/application-security.

